

摘要

论文聚焦于操作系统平台（Windows、iOS、Android）的软件自动化数字证书签名系统的设计与实现，旨在为企业内部提供统一、安全、高效的数字证书服务。设计实现了 Windows PE、IPA、APK 格式软件的自动化数字证书签名、HLK 测试、WHQL 认证、证书申请与管理以及后台管理，实现一套运营人员便于管理，软件开发者易于使用，根据使用场景负荷可伸缩计算机资源的管理系统。系统采用 B/S 架构，以 Golang 为主要程序设计语言，使用 Vue 等软件技术，设计实现优美的网页。采用 Python、C#等程序设计语言的长处实现本系统相关功能，使用当下流行的开源软件程序 MySQL、Nginx、RabbitMQ、Redis 等实现本系统。统一管理企业的数字证书、操作系统服务商平台账号等资源，提供自动化软件数字证书签名服务。满足企业开发软件的过程中，证书的获取，软件签名等需求。减轻软件开发者负担，提高签名效率，维护企业信息安全，提升企业生产能效。

关键字：自动化软件数字证书签名；系统设计与实现；数字证书管理；Golang；Web 服务器开发

ABSTRACT

The paper focuses on the design and implementation of a software automated digital certificate signing system for operating system platforms (Windows, iOS, Android), aiming to provide unified, secure, and efficient digital certificate services in internal enterprises. It have designed and implemented an automated digital certificate signing for Windows PE, IPA, and APK format software, HLK testing, WHQL authentication, certificate application and management, and backend management system. This system is easy for operators to manage, software developers to use, and can scale computer resources according to usage scenarios. System adopts B/S architecture, with Golang as the main programming language, and uses software technologies such as Vue to design and implement beautiful web pages. It also utilizes the strengths of programming languages such as Python and C# to implement the relevant functions of the system. This system is implemented using popular open-source software programs such as MySQL, Nginx, RabbitMQ, Redis, etc. Unified management of enterprise digital certificates, operating system service provider platform accounts, and other resources, providing automated software digital certificate signing services. Meets the needs of obtaining certificates, software signing, etc. Reduce the burden on software developers, improve signature efficiency, maintain enterprise information security, and enhance enterprise production efficiency.

Keywords: Automated software digital certificate signing; System design and implementation; Digital certificate management; Golang; Web server development

目录

1 引言	1
1.1 研究的背景与意义	1
1.2 研究现状	1
1.3 研究内容和论文组织结构	2
2 相关工具和技术简介	3
2.1 Golang	3
2.2 Vue	3
2.3 MySQL	4
2.4 Redis	4
2.5 RabbitMQ	4
2.6 Nginx	4
2.7 Fastlane	4
2.8 Tusd	5
3 系统分析	6
3.1 系统可行性分析	6
3.2 系统总体需求分析	6
3.3 系统目标用户分析	7
3.4 系统功能需求分析	8
3.4.1 用户管理功能分析	8
3.4.2 应用管理功能分析	8
3.4.3 事件统计功能分析	10
3.4.4 待办管理功能分析	12
3.4.5 证书管理功能分析	13
3.4.6 OpenAPI 凭证管理功能分析	17
3.4.7 签名管理功能分析	18
3.4.8 后台管理功能分析	21
3.5 系统非功能性需求分析	22

4 系统设计 24

4.1 系统架构设计	24
4.1.1 系统部署架构和网络通信设计	24
4.1.2 代码库层次结构设计与第三方依赖库	26
4.2 系统功能设计	29
4.2.1 用户管理功能设计	29
4.2.2 应用管理功能设计	29
4.2.3 事件统计功能设计	29
4.2.4 待办管理功能设计	30
4.2.5 证书管理功能设计	30
4.2.6 OpenAPI 凭证管理功能设计	31
4.2.7 签名管理功能设计	31
4.2.8 后台管理功能设计	32
4.3 系统数据库设计	32

5 系统实现与测试 57

5.1 系统开发测试环境	57
5.2 系统核心代码的实现	57
5.2.1 日志与链路追踪策略实现	57
5.2.2 Web 登录会话鉴权实现	58
5.2.3 OpenAPI 访问鉴权实现	59
5.2.4 数据库事务提交与回滚策略实现	59
5.2.5 分布式定时任务与分布式锁实现	59
5.2.6 服务退出资源释放策略实现	60
5.2.7 HLKX 文件的 EV 签名实现	60
5.2.8 签名文件的上传与下载实现	60
5.3 系统功能实现	62
5.3.1 用户管理功能实现	63
5.3.2 应用管理功能实现	65
5.3.3 事件统计功能实现	68
5.3.4 待办管理功能实现	69

5.3.5 证书管理功能实现	70
5.3.6 OpenAPI 凭证管理实现	82
5.3.7 签名管理实现	84
5.3.8 后台管理实现	93
5.4 系统测试	100
总 结	102
参考文献	103

1 引言

1.1 研究的背景与意义

随着信息技术飞速发展，相比于上世纪，我国信息基础设施规模和技术水平已经取得了显著的提升，移动智能设备和个人微型计算机已经广泛普及，互联网已深入人们生活的各个角落^[1]，涌现出众多 IT 企业，IT 经济在国民经济中占有越来越大的比重。然而，近几年新冠肺炎疫情的影响，使得市场经济受到了重大冲击，许多企业不得不裁员甚至倒闭。大型软件开发企业也从追求快速扩张和投资涉足新领域转向了降本增效、提高生产效率的策略。

软件的数字证书签名^[2-6](以下简称数字签名)是附着在软件上的一块数据，和软件组成一个整体后一起传播，是摘要算法和公钥密码算法的结合应用^{[7]41-46}，它在保护消费者和开发者的权利上发挥了至关重要的作用。我国为促进和规范电子认证业发展，提出了《电子认证服务业“十二五”发展规划》^[8]。数字签名不仅能验证软件的来源信息，同时可确认软件是否被篡改过。利用数字证书可有效地解决在互联网活动中交互双方身份真实性和可靠性的认证问题。它具有法律效力，等价于人们的手写签名，根据我国电子签名法第十三条只要满足相关条件即具有同等法律效力^[9]。

通常，软件的数字证书签名工作由开发者完成，他们需要自行管理数字证书并搭建签名环境执行签名操作。在一些自动化场景下，例如持续集成与发布（CI/CD），开发者不得不考虑自行实现配置一套自动化签名逻辑。这无疑加重了开发者的工作量，减少了其劳动产出。数字证书签名及管理系统（以下简称本系统）替代或简化开发者对软件的数字证书签名工作，减少开发者的工作负荷，使他们可将更多精力放在核心工作上，数字证书的整个生命周期都可在本系统中安全保存，以期提升企业生产效率，保护信息安全。

1.2 研究现状

同类系统产品鲜少见之于市场，大都是企业内用而非对外营业。市场上有类似本系统或具有本系统部分功能的产品：

1. 亚洲诚信公司推出的数字签名工具专业版^[10]，具有对微软 Windows 平

台软件的签名功能，并提供了一套优美的操作界面，同时有证书管理和数字签名测试功能。但缺少对其他操作系统平台的支持。

2. 沃通公司推出的 Windows 徽标（WHQL）认证服务^[1]，提供协助用户完成 HLK 测试和认证服务。但服务需要收取费用，且其流程并不能在自动化场景下使用。

本系统功能覆盖了 Windows、Android、iOS 和 macOS 多个系统平台的软件数字签名，且有自动化 HLK 测试，比市场上提供的同类系统有更全面的操作系统平台支持。同时也具有更完善的数字证书管理服务，友好的系统服务运营功能。深度化地自动化服务支持，这些是外部同类系统所不具有的能力。

1.3 研究内容和论文组织结构

本论文从自动化数字签名这一根本需求出发，设计实现了基于 B/S 架构的数字证书签名及管理系统。为企业提供了自动化数字证书签名解决方案，减轻企业对数字证书管理的痛点，解放开发者在数字签名工作中的苦恼。分析了企业中数字签名和证书管理的需求特点，以此为基础，设计出系统的数据库表结构、需开发的系统功能、系统运行部署架构以及采用的软件技术。使系统满足小微到中大型企业使用场景压力。

第一章介绍了课题研究背景与意义，当下类似系统产品的现况，确定了研究内容和方向。第二章介绍了本系统使用的一些软件工具，和开发本系统所涉及的一些技术工具简介。第三章对本系统的需求进行了详细地论述，说明了本系统开发的各个模块功能和要求。第四章详细阐明了本系统的部署架构和网络拓扑，对各功能模块的设计细节进行了论述，确定设计了本系统的数据库表结构。第五章是本系统的具体实现，阐述了各功能接口实现逻辑，并对功能进行了测试，展示各功能实现效果页面。第六章总结了本系统研究的成果与存在的不足，分析了本系统进一步发展的方向。

2 相关工具和技术简介

2.1 Golang

Golang 是由 Google 开发维护并开源的程序设计语言，它是一款语法简洁、强类型、编译型和内生性支持并发编程的语言^[12-14]。它非常适合 Web 服务器开发，官方提供了丰富的标准库代码。Golang 有别于 Java、C++ 中的面向对象编程技术，它通过结构体匿名字段内嵌、接口、泛型编程的方式，达到复用代码和模拟多态行为目的。它将源码翻译成机器码程序，非常有利于程序的部署运行。Golang 提供了非常实用的模块（module，多个包组成）管理功能，几乎网络上任何 Golang 代码版本控制仓库都能当作代码依赖，且能跨平台交叉编译程序。内生性支持并发编程是它有别于其他传统语言的一大特征，使用内置 chan 数据类型和用户级协程 goroutine，能很快编写出简洁明了的并发通信代码。本系统使用 Golang 语言开发服务器。

2.2 Vue

Vue 是一个开源的 JavaScript 渐进式框架，基于标准 HTML、CSS 和 JavaScript 构建，提供了一套声明式、组件化的编程模型，可用于构建用户界面和单页面应用。它基于标准 HTML 拓展了一套模板语法，使得可以声明式地描述最终输出的 HTML 和 JavaScript 状态之间的关系，并且自动跟踪 JavaScript 状态，在其发生变化时响应式地更新页面。相比于传统的 jQuery 选择 DOM 再更新数据，Vue 更能胜任开发复杂的用户界面。本系统采用 Vue 开发网页。

Vue 的单文件组件（SFC）将逻辑（JavaScript）、模板（HTML）和样式（CSS）封装到同一个文件里，以描述页面上的一部分区域的行为表现。一个界面往往是一个根组件，将其他组件作为其子组件，组成一颗嵌套的、可重用的组件树。单文件组件可以引用其他单文件组件，以达到复用源码目的。引用方称为父组件，被引用方称为子组件。子组件中可以声明属性（props）和事件（emits），父组件使用子组件时，便可传递这些属性和事件。该行为就类似于编写普通的 HTML 标签并填写属性和事件。此外，子组件中声明插槽，父组件还可以向子组件插槽传递模板。以上行为与面向对象编程中类之间发送

信息的心智模型类似，因此便于构建复杂的应用。

2.3 MySQL

MySQL 是一款关系型数据库，广泛地用于网站开发，数据分析和软件开发。社区版本 MySQL 开源免费，使用 C++ 语言实现，支持多种操作系统平台，也提供了很多编程语言 API，很方便地同应用程序集成。它不仅在技术上深度优化索引缓存，也有用户权限管理，加密等多种安全机制，同时具有主从集群模式提高服务可用性和可扩展性。本系统使用 MySQL 持久化保存数据。

2.4 Redis

Redis 是一款键值对数据库，使用 C 语言编写。它将数据存放在内存中，相比于需要持久化数据的数据库，对内存的操作要快很多，因此很适合用来存放临时性数据。Redis 不仅支持丰富的数据类型：字典、集合、有序集合、位图、哈希等，同时也提供发布订阅模式、事务命令，支持集群和哨兵模式部署。Redis 单线程执行命令，结合 Lua 脚本使用，能将多个命令原子性执行，避免了并发数据竞争问题，利用这一特性实现了本系统的 OpenAPI 请求限流逻辑、Web 接口请求防抖逻辑、分布式锁。本系统主要使用 Redis 存放临时性和有状态的数据。

2.5 RabbitMQ

RabbitMQ 是一款消息服务器，它使用 Erlang 语言编写，社区版开源免费。它支持多种消息队列协议，包括 AMQP，支持集群和分布式部署。提供了多种消息路由方式，包括直接路由、主题路由和头路由等。通过消息持久化、传输确认和发布者确认等多种方式来保证消息的可靠性。同时提供了一个易用的管理界面，可以方便地查看和管理消息、队列和交换器等。本系统采用 RabbitMQ 来削峰和异步处理签名任务。

2.6 Nginx

Nginx 是一款轻量级的 Web 服务器、反向代理服务器，由于它的内存占用少，启动极快，高并发能力强，在互联网项目中广泛应用。它由 C 语言编写，开源免费，能够热重启。本系统使用 Nginx 作为网关，将请求转发到后端的多个服务器，提供负载均衡功能。

2.7 Fastlane

Fastlane 是一个用于自动化 iOS 和 Android 应用开发的构建和发布的程序，

它由 Ruby 语言编写。它提供了一系列工具，可以帮助开发者自动化许多繁琐的任务，如管理证书和配置文件、构建和发布应用等。使得开发者可以将更多的时间和精力投入到实际的应用开发中。本系统使用 Fastlane 用于申请 Apple Push 证书、企业类型的 Apple 账号的描述文件。

2.8 Tusd

Tusd 是一款对象存储服务器，通俗地说是一款存取文件的服务器。它基于开源 Tus 协议，采用 Golang 语言编写实现。Tus 协议构建于 HTTP 协议之上，目标简单高效，利于客户端和服务端实现，并且具有断点续传、分片上传和上传鉴权的能力，支持任意大小的文件存放。本系统需要有对象存储服务器，存放签名文件、用户头像和应用图标。

3 系统分析

3.1 系统可行性分析

从技术可行性上分析，本系统须能实现对数字证书的自动化管理和软件自动化数字证书签名，满足企业能够在自动化场景下完成对软件的签名需求。由于各操作系统平台官方都有提供相关的证书服务和签名工具，通过运行代码调用相关签名工具能达到自动化签名目的。系统开发所采用的软件技术，主要是基于 Golang 语言、Vue 和 MySQL 数据库，都是开源自由且免费的软件技术，没有使用授权费用和版权问题，而且该套软件技术使用范围广泛，技术成熟，与本系统开发需求相匹配。因此技术上可行。

从经济可行性上分析，本系统统一管理证书相关资源，避免了企业员工各自购买相关证书服务，节省了企业资金支出。企业中开发者通过本系统完成软件的自动化签名，省去了准备签名环境和执行签名等工作，提高了开发者的生产效率，进而提升了企业生产能效。系统投入运营后将显著地减轻软件开发者对于软件签名的工作量。系统的使用者越多，本系统创造经济价值效益就越高。从本系统的部署运行成本上分析，系统运行只需少量的物理设备资源，可以考虑复用企业已有的设备资源。本系统属于中小型项目，整体开发维护成本偏低。综上，系统在经济上可行。

3.2 系统总体需求分析

数字证书签名及管理系统是一款在企业内部提供自动化软件签名和证书管理的平台，通过统一各类操作系统应用软件签名和证书文件相关资源，减少减轻开发者签名相关工作，提高企业软件开发团队工作效率，降低企业运作管理成本，实现一款一站式、安全、稳定、高效的数字证书服务平台。

企业中有不同的开发团队，负责开发不同的应用软件，为各开发团队在本系统上的使用便捷性可管理性，计划实现应用管理功能和应用事件统计功能。

在开发团队中有普通员工和团队领导，所以应用下要能管理不同用户。为了企业信息安全和管控性，应用下还需有人员权限管理能力，通过待办的形式处理审批权限，所以实现用户管理功能模块和待办管理模块。

用户使用本系统的主要目的是获取证书和签名相关服务，所以本系统计划实现证书管理功能模块和签名管理功能模块，涵盖了三大操作系统平台（Windows、Android、iOS）。由于各平台对证书和签名的实现有所不同，在本系统的实现也有差异。

在企业中有很多需要自动化签名的场景，有从本系统中获取证书、应用等信息的需要，所以本系统需要提供 OpenAPI 服务，计划实现 OpenAPI 凭证管理功能。

和大多数管理系统一样，为了系统的长期运营，需要实现后台管理功能，以便系统运营员能后监控系统使用情况、获取系统运行数据以及证书更新等管理工作。当有证书过期需要替换更新等一些事件出现，为了便于系统运营员通知广播，告知开发者，计划在后台管理功能中实现公告的管理。

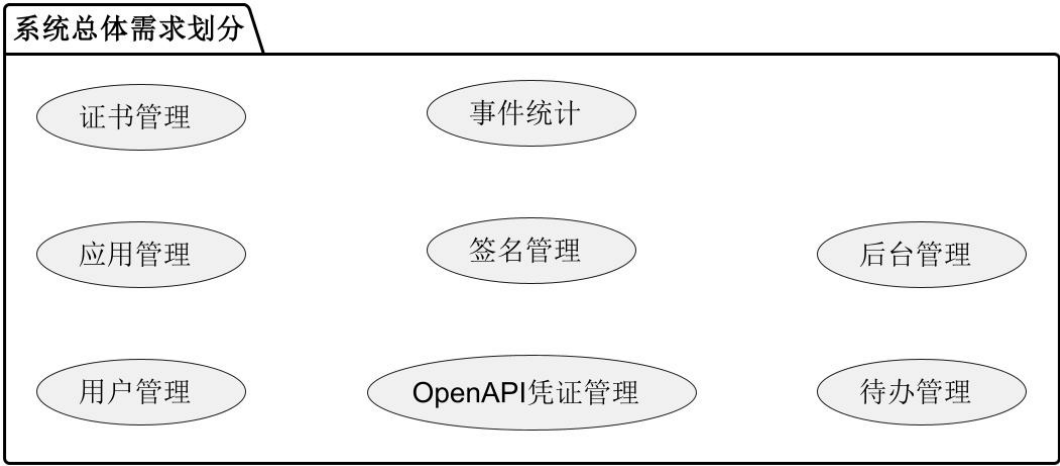


图 3-1 系统需求模块划分图

3.3 系统目标用户分析

软件开发者需要使用本系统的申请证书、使用证书签名软件等服务，是本系统的主要用户群体。软件项目经理在本系统上注册应用、管理应用下的成员和其权限、浏览统计应用事件等等，是本系统的目标用户。系统运营人员在后台管理模块中管理和更新证书、浏览系统运行统计数据、发布管理公告，是本系统的不可或缺的用户。

表 3-1 系统目标用户表

类型	说明
----	----

软件开发者	使用系统的证书和软件签名等服务
软件项目经理	管理应用使用资源
系统运营人员	监控系统使用情况，发布公告，分配公共证书等

3.4 系统功能需求分析

从系统实现目的出发，结合在总体需求中的分析结果，在确保合理、科学、有价值的准则下，本节详细分析了本系统应具备的功能。

3.4.1 用户管理功能分析

为了企业信息安全，便于确认责任人和管理系统，本系统需要用户注册、登录、登出和修改信息的功能。员工在企业中有具有部门组织等信息，所以注册时需要将用户中英文名、部门、密码、头像信息保存到系统中。由于不排除企业中有同名员工，系统中将用户英文名作为唯一识别，确保所有用户的英文名不相同。也因此用户使用英文名和密码登录系统。修改信息时不能修改英文名。对于企业而言，系统的稳定性和安全性是第一位，所以本系统不允许同一用户同时多处登录使用，再次登录时挤下前次的登录会话。

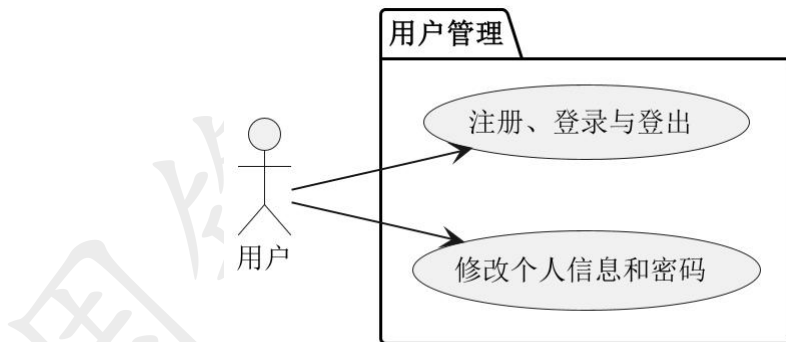


图 3-2 用户管理功能图

3.4.2 应用管理功能分析

由于存在企业中开发维护着多个应用的可能性，为了便于使用者清晰明了地使用服务，用户需要注册本系统应用，让用户通过应用使用本系统功能。注册应用时系统中保存应用名、图标、平台和应用人员，为了避免公共证书等资源乱用泄露，注册的应用须通过系统运营员的审批。由于本系统涵盖三大操作系统平台的证书签名功能，不同平台应用的证书签名功能也不同，所以更新应用信息时不可更改平台类型。为了用户的使用数据不会遗失，方便用户日后翻

找使用数据，留存工作痕迹，本系统不允许删除应用数据，用户可通过无效化应用来冻结应用，无效化后的应用只能查看，不能进行任何修改操作。当用户想解冻应用时，可以有效化应用，提交待办，让系统运营员审批通过。

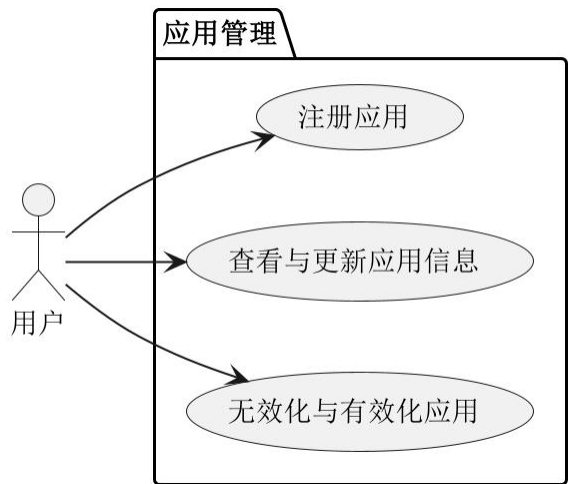


图 3-3 应用管理功能图

由于应用下不同成员有不同操作权限，以保证信息安全和用户行为可控，下表分析列出了不同角色对应的操作权限。

表 3-2 系统角色对应权限表

角色	平台	权限
应用管理员	所有	编辑应用基本信息
		无效化应用
		有效化应用
		申请 OpenAPI 凭证
		编辑 OpenAPI 凭证信息
		删除 OpenAPI 凭证
		重置 OpenAPI 凭证密码
应用管理员、应用成员、系统运营员		浏览应用的基本信息、证书列表、签名任务列表、应用事件和 OpenAPI 凭证列表，以及浏览 Apple 平台的 BundleID 和测试设备信息
应用管理员、应用成员	Windows	上传个人 OV 证书
应用管理员		删除个人证书

		下载个人 OV 证书
		查看个人证书密码
应用管理员、 授权了的应用 成员		提交 Windows PE 文件签名任务
		提交 WHQL 签名任务
应用管理员、 应用成员	Android	上传证书
		申请证书
		下载调试证书
应用管理员		删除证书
		获取证书 Facebook 密码散列
		下载 Google Play 相关证书
应用管理员、 授权了的应用 成员		提交 APK/AAB/补丁包签名任务
应用管理员	Apple	申请 BundleID
		编辑 BundleID 能力
		删除 BundleID
		注册测试设备
		下载证书和 Profile 文件
		删除 Push 证书和 Profile 文件
应用管理员、 应用成员		申请 Profile 文件
		申请 Push 证书
应用管理员、 授权了的应用 成员		提交 IPA 文件签名任务
系统运营员		

3.4.3 事件统计功能分析

事件统计帮助用户浏览应用使用记录，辅助项目经理对软件管理决策，所以记录应用所有写类型操作。每个事件记录包含应用 ID、事件类型、事件来

源、事件触发人、发生时间和事件内容。因为本系统提供了 OpenAPI 功能，所以事件的来源就有了 OpenAPI 和页面之分。

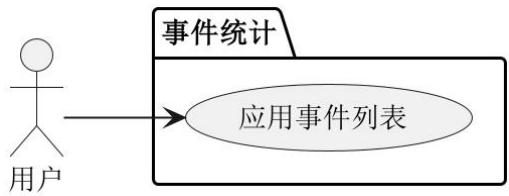


图 3-4 事件统计功能图

下表分析列出了所有的事件类型。

表 3-3 事件类型一览表

平台	类型
所有	应用注册
	应用无效化
	应用有效化
	应用信息修改
	申请 OpenAPI 请求凭证
	修改 OpenAPI 请求凭证
	删除 OpenAPI 请求凭证
	续期 OpenAPI 请求凭证
	重置 OpenAPI 请求凭证密码
Windows	上传个人 OV 证书
	删除个人证书
	下载个人 OV 证书
	提交 PE 文件签名任务
	提交 WHQL 认证任务
Android	上传证书
	申请证书
	删除证书
	下载证书
	获取 Google Play 证书

	获取 Facebook 密码散列
	提交 APK、AAB、补丁包文件签名任务
Apple	申请 BundleID
	修改 BundleID 能力
	删除 BundleID
	申请描述文件
	申请 Push 证书
	下载描述文件和证书
	删除描述文件
	删除 Push 证书
	注册测试设备
	提交 IPA 文件签名任务

3.4.4 待办管理功能分析

在系统运行中存在着一些需要审批的事项，为了能便捷规范地处理事项，通过待办形式，由申请人提交申请，审批人处理。通过分析，有用户注册应用、用户申请加入应用、应用成员申请签名权限、注册苹果测试设备，需要通过待办审批。其中前三者的要审批是为了企业信息安全，后者是为了避免资源浪费。由于苹果账号所能绑定的设备有限，且不能随意解绑。为了更好的待办服务，申请人在提交时可以附上申请缘由，审批人可以查看缘由并可附上审批语。

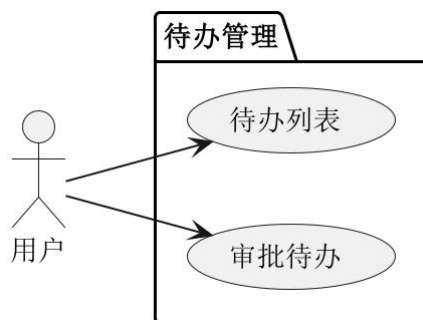


图 3-5 待办管理功能图

下表列出了待办的所有类型。

表 3-4 待办类型一览表

事项	处理人
----	-----

用户注册应用	系统运营员
用户申请加入应用	应用管理员
应用成员申请签名权限	应用管理员
注册苹果测试设备	系统运营员
有效化应用	系统运营员

3.4.5 证书管理功能分析

软件的测试和发布上架都可能需要先打上数字证书签名，为了满足企业软件签名的需要，实现对数字证书相关文件的管理是核心功能。由于不同操作系统平台应用程序的签名有差异，对应证书管理体系也有差异，下面具体分析各平台应提供的证书服务。

在 Windows 平台应用的证书管理功能分析中，通过调研发现，Windows 平台签名证书需要向证书颁发机构购买，所以不提供证书申请功能，而是由系统运营员将购买来的证书通过后台管理添加到本系统，作为公共证书供全部应用使用。为了支持更多证书类型，提供更好服务，同时支持历史遗留下的文件型（OV）证书，和现在流行的 UKEY（EV）证书。为了满足用户使用个人证书签名的需要，系统应提供上传个人 OV 证书功能。对于个人 EV 证书，由于需要插到机器上使用，由系统运营员在后台管理中添加并授权到用户的应用下。

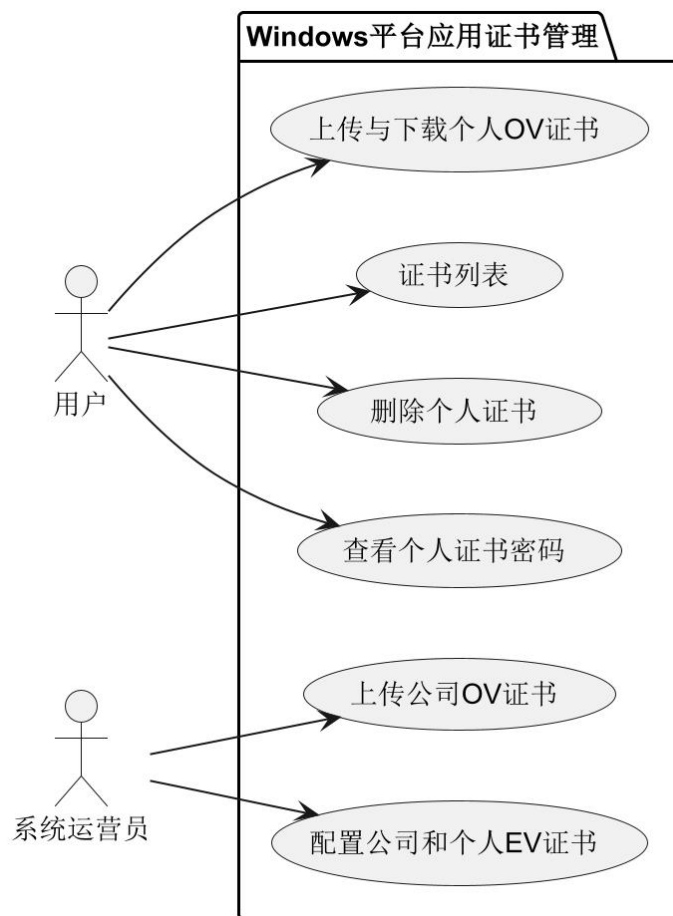


图 3-6 Windows 平台应用证书管理功能图

在 Android 平台应用的证书管理功能分析中，由于安卓应用签名证书可由开发者自行生成和管理，所以本系统计划实现安卓证书的上传。由于安卓证书可随意生成，为了便于管理，限制用户申请时使用的证书主体，证书主体由系统运营员在后台管理中配置。同时区分用户使用目的，将证书分类为发布和调式两种类型。开发者在和 Google Play 开发者中心交互中，需要将安卓证书进行一些转换处理，以便添加到 Google Play 开发者中心。其中有安卓应用上传到 Google Play 中心时用于验证开发者身份的‘上传证书’，用户的密钥库文件经过加密后才能安全的上传到 Google Play 中心的‘部署证书’，当开发者需要更换他们在 Google Play 中心的应用签名密钥时的‘升级签名密钥’。由于用户的证书托管在本系统，也为了本系统能创造更多价值和服务，提供该类文件的生成下载。此外，Facebook 为防止恶意应用冒充合法应用与其服务器通信，需要将应用签名证书的散列值添加到 Facebook 开发者中心，本系

统证书提供该散列值生成，以满足用户需要。

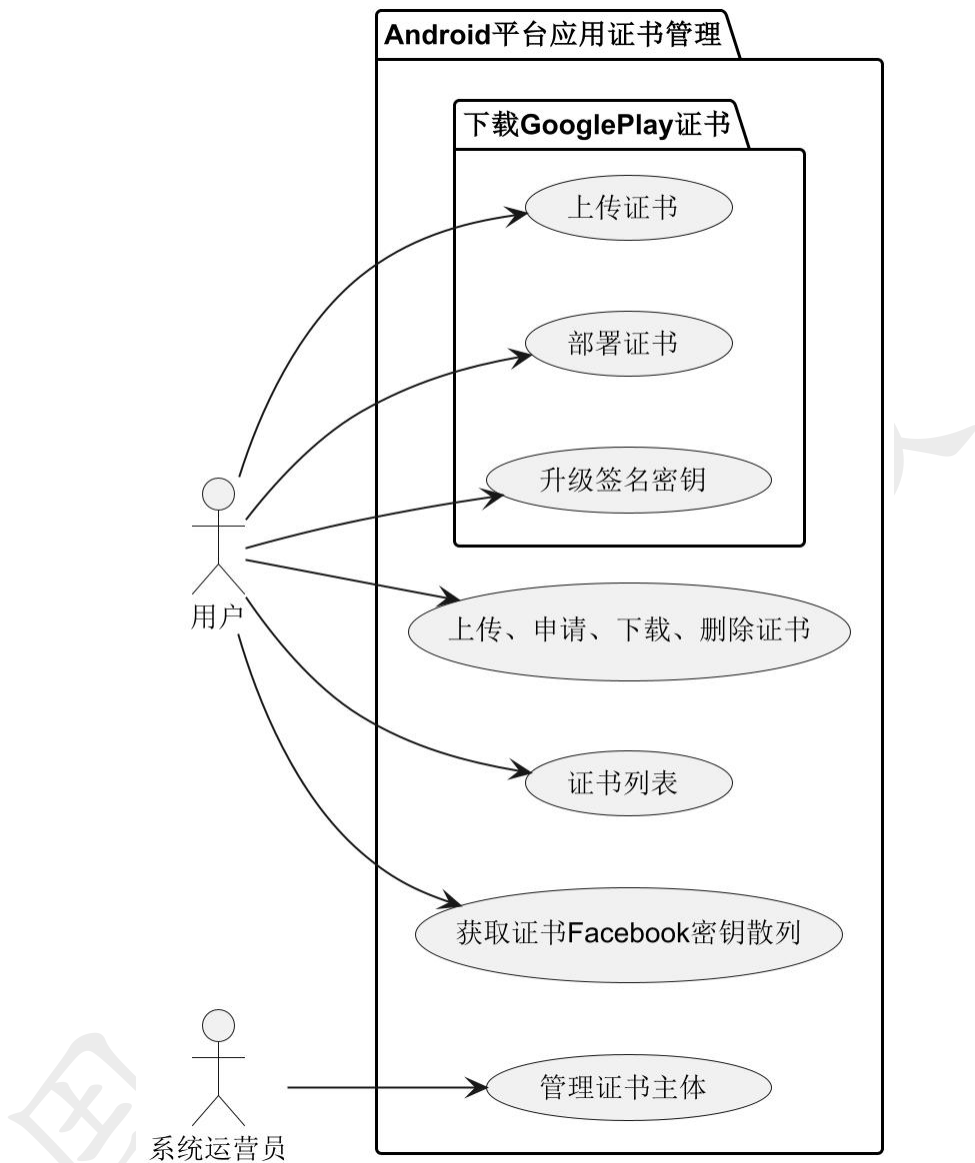


图 3.7 Android 平台应用证书管理功能图

在 Apple 平台应用的证书管理功能分析中，Apple 的证书相关资源都可在 Apple 开发者中心管理，也可通过 App Store Connect API 进行管理。通过对其调研发现，Apple 证书有许多类型，对应用于不同类型的 Apple 设备签名，其中可分类为用于测试和正式环境。由于签名时还需要用到描述文件，为完成签名工作，需要根据不同类型证书申请出描述文件。而描述文件又关联一个具体 Apple 应用，即一个 BundleID。同时 BundleID 关联许多对设备操作的能力项，例如打开 5G 网络。在开发者开发实现工作中，大部分情况下都需要用到部分

能力项，所以系统须实现对这些能力的自助开关。由于测试类型的证书申请的描述文件签名出来的应用能安装上的测试设备有限制，需要在申请描述文件时附上应用需安装的测试设备信息。而测试设备需要事先在 Apple 服务器注册，所以为满足用户测试应用需要，本系统须实现测试设备注册。综上，为满足 Apple 应用签名需要，本系统需要实现 BundleID、证书、描述文件、测试设备的管理功能。其中，由于一份签名证书可申请出多个描述文件，所以将签名证书申请功能放后台管理中，由系统运营员申请，供所有应用使用。由于 Apple 账号分公司级、企业级和个人类型，有些企业除了公司级的可能还需要企业级的 Apple 账号服务，以满足对于企业内测环境描述文件和推送（Push）证书的申请需要，本系统实现相关功能。

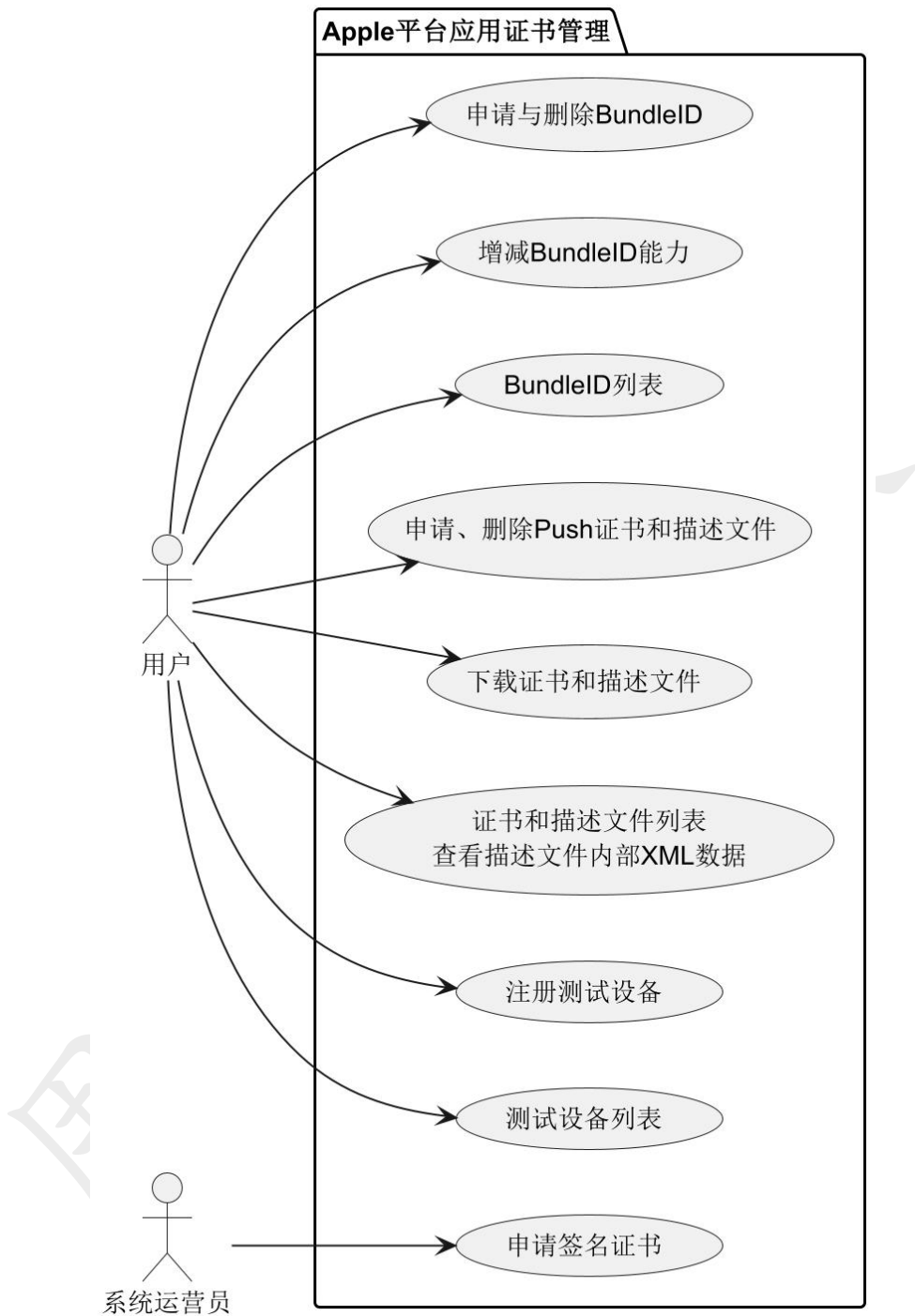


图 3-8 Apple 平台应用证书管理功能图

3.4.6 OpenAPI 凭证管理功能分析

为满足开发者在持续集成发布（CI/CD）环境下的自动化签名需要，本系统提供 OpenAPI 服务。由于需要有对 OpenAPI 的鉴权能力，防止系统被恶意用户攻击，确保系统安全和稳定，所以系统应实现凭证管理的功能。用户在应

用下申请凭证，自动化签名程序持有合法凭证访问系统才能被受理。为了避免凭证的无效请求过多导致系统资源浪费，对凭证进行一定的限制。用户申请凭证时，系统除了保存凭证 ID、密钥外，还应有该凭证可请求的授权项、IP、最高请求频率和过期时间。实现凭证密码重置和续期功能，满足用户忘记密钥和想继续使用凭证的需要。

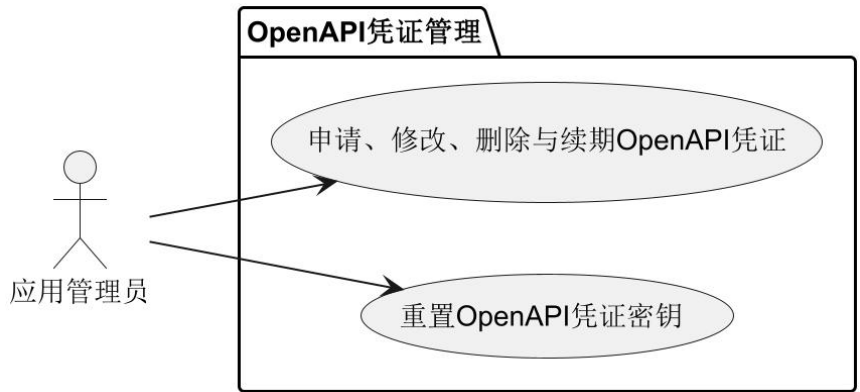


图 3-9 OpenAPI 凭证管理功能图

不同平台应用有不同凭证授权项，下表分析列出了各凭证授权项。

表 3-5 OpenAPI 凭证权限项一览表

平台	权限项
Windows	下载 OV 证书
	查看个人证书密码
	提交 Windows PE 签名任务
	提交 WHQL 认证任务
Android	下载证书
	提交 APK、AAB 和补丁包签名任务
Apple	下载描述文件和证书
	提交 IPA 文件签名任务
所有	获取应用证书信息
	获取应用签名任务信息

3.4.7 签名管理功能分析

为满足企业自动化签名需要，实现本系统的签名功能是核心诉求。为了更多地减轻减少开发者负担，更好地提升企业生产能效，本系统尽可能实现更多

软件类型的签名功能。下面具体分析各操作系统平台的签名功能。

对于 Windows 平台应用软件，其都是以 Windows PE 格式组织的文件，所以系统计划实现对该文件的签名功能。但是微软公司对于驱动程序的签名有更高的要求，驱动程序在系统中运行前必须获取到微软公司的证书签名。由于历史原因，微软公司的合作伙伴中心网站上提供了两套驱动签名服务，分别适应不同的 Windows 系统版本。早期的 Attestation 签名，和现在的 WHQL 认证，本系统计划实现该两类型的自动化签名服务。由于获取 WHQL 认证需要事先自行将驱动程序通过 HLK（Hardware Lab Kit）兼容性测试，本系统实现自动化完成该测试并提交微软获取 WHQL 认证。

对于 Android 平台应用软件，主要是 APK 文件，为满足用户多样的安卓签名方案^[15-16]需要，本系统实现从安卓 v1 到 v4 方案供用户选择。开发者针对不同安卓设备开发的 AAB 包文件，本系统实现该文件签名满足开发者需要。此外需实现 APK 的增量升级补丁包的签名功能，由于补丁包可能是针对更高 AndroidAPI 版本号开发，应提供给用户填入该版本号，避免补丁包用于低版本安卓系统。

对于 Apple 平台应用软件，本系统计划实现 iOS 系统的安装包 IPA 文件的签名功能。

为了避免用户自己编码开发，调用本系统 OpenAPI 实现自动化签名程序。本系统提供统一的自动化签名程序。

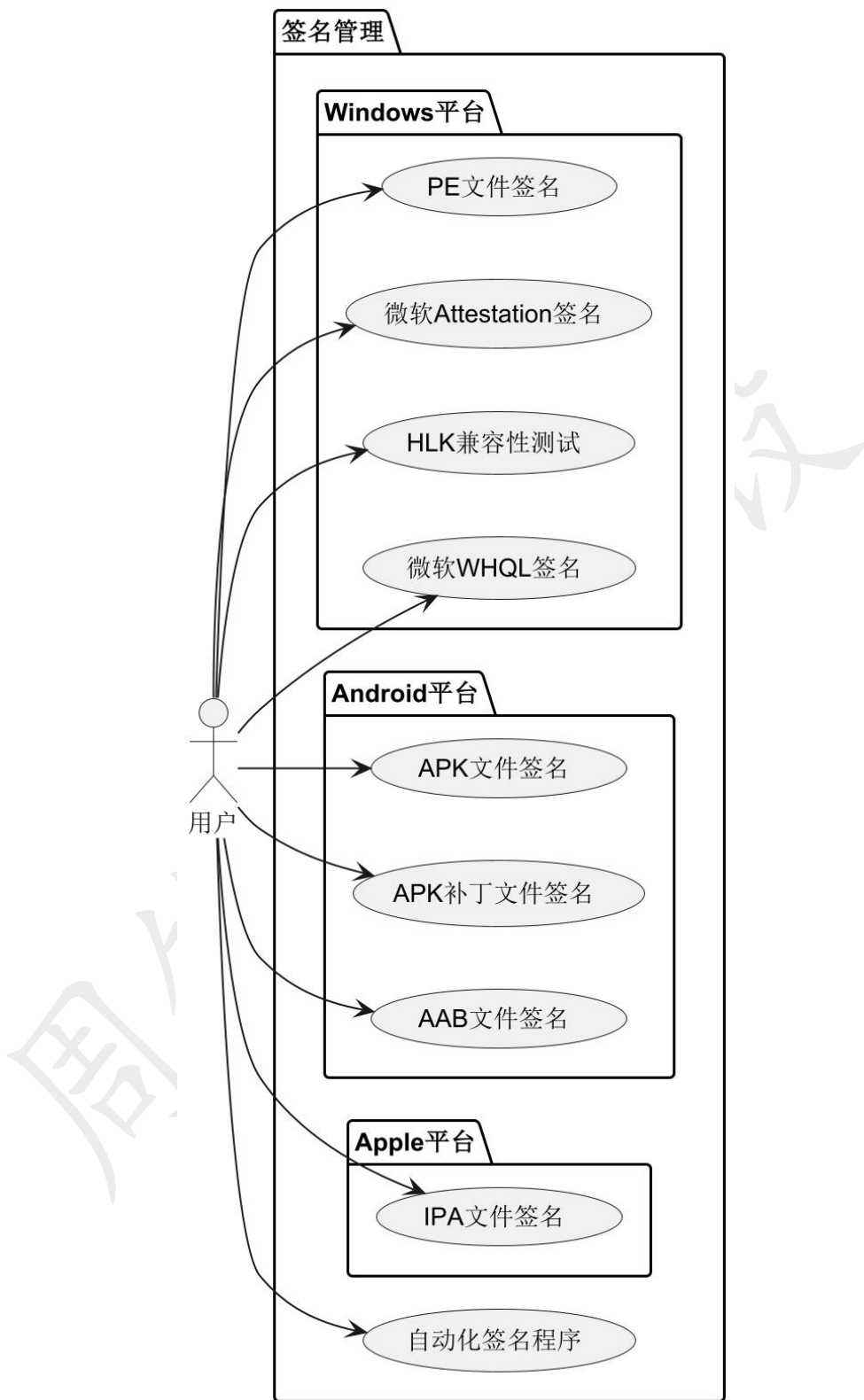


图 3-10 签名管理功能图

3.4.8 后台管理功能分析

后台管理是系统运营人员使用的功能，是系统长期稳定运行不可或缺的功能。系统运营员的身份登录系统才展示进入后台管理的按钮，系统运营员通过后台管理，浏览系统运行数据图表、管理公共证书和发布公告。

为体现系统使用情况和负载压力信息，本系统实现各类型文件的签名耗时和成功率折线图，和应用事件数量柱状图。其中，可以查单个应用也可全部应用的统计数据，可以按日、周或月为一个统计步长。应用事件数量类型有：创建应用、无效化应用、上传 Windows 个人 OV 证书、申请安卓证书、上传安卓证书、申请苹果描述文件、申请苹果推送证书。

对于公共证书管理功能，经上面小节分析，有添加 Windows 公司证书、新增安卓证书主体、申请 Apple 签名证书。

因系统运营员需向用户广播公告信息，实现公告功能。系统运营员编辑公告内容，发布后展示在首页顶部横幅。公告内容可由文字和超链接组成，以便公告提供更多信息。用户可以点击超链接进一步浏览信息。公告可设置生效和失效时间，到时间展示，过时间下架，方便系统运营员管理。

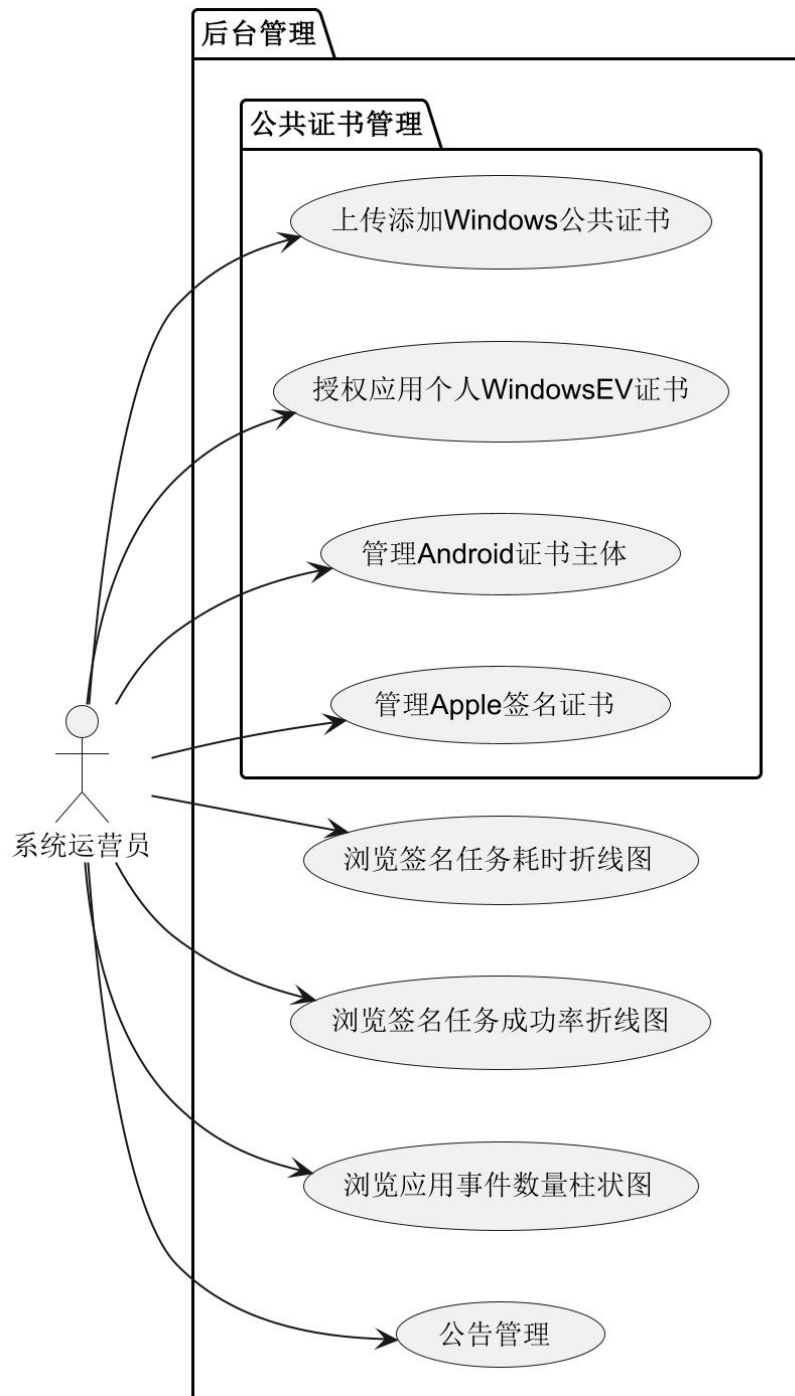


图 3-11 后台管理功能图

3.5 系统非功能性需求分析

从系统性能上分析，本系统除了满足功能性需求外，系统的处理响应速度也应能达到软件系统的基本要求。针对本系统有大量的页面刷新和接口请求，因此系统响应耗时更应能达到用户心理能接受的水平以内。

从系统普适性分析，由于本系统是用于企业内部，企业的网络环境和终端设备不尽相同，因此必须考虑到系统的适应性，无论软件层面还是硬件方面都应尽可能地适应所有企业环境。

从系统安全需求上分析，安全是系统可行的基石，是重中之重。本系统应保证证书相关文件数据安全，不能出现非公司软件打上了公司的签名等泄露签名的情况。

从系统可维护性上分析，系统应尽可能减少需要人为干涉的事项，必须要人维护的事项应尽可能简单明了，操作方便。

从系统的易操作使用上分析，因系统提供给企业员工使用，应尽可能减少他们对系统功能的理解，减轻他们应使用新工具造成的心理负担，有助于提高员工工作效率。提供直观明了的操作界面，让即使不懂软件签名原理的开发者也能很轻松地知道本系统功能是做什么用的。

4 系统设计

4.1 系统架构设计

4.1.1 系统部署架构和网络通信设计

本系统采用 B/S 体系架构实现，该架构中前台浏览器只负责视图处理和数据请求，后台服务器负责数据处理加工，最后数据存放数据库。这种分层的设计思想，明确区分各层各模块服务功能，方便本系统的拓展更新和维护。同时，所有数据处理和存储都在服务器端，客户端只负责视图处理，方便实现权限控制和安全策略，更有效地保护系统数据的安全。

在本系统中使用 Nginx 作为网关将来自 PC 浏览器和 OpenAPI 形式的请求转发到主服务器。主服务器可直接与中间件服务器通信，而签名服务器和 HLK 自动化测试服务器通过网关的中转请求主服务器，间接与中间件通信，以便更好适应不同的企业网络环境。其中，为了更好的安全性，网关以 HTTPS 协议接收来自客户端的请求，而为了更好的性能，网关以 HTTP 协议与内部服务器通信。为了使系统适应不同使用压力场景，主后台服务器可以弹性多台部署，网关将客户端请求负载均衡到主服务器集群。为了避免签名任务量瞬时峰值导致系统奔溃，出现服务数据异常，且各类型文件签名所需环境不尽相同。所以不在主服务中执行签名，而是通过 RabbitMQ 将签名任务消息发送给对应签名机器，将签名逻辑的执行放置到签名服务器中。为使系统通信更轻便明了，使用数据紧凑又直观便于排错的 JSON 数据作为前后端和内部各服务间通信的数据格式。

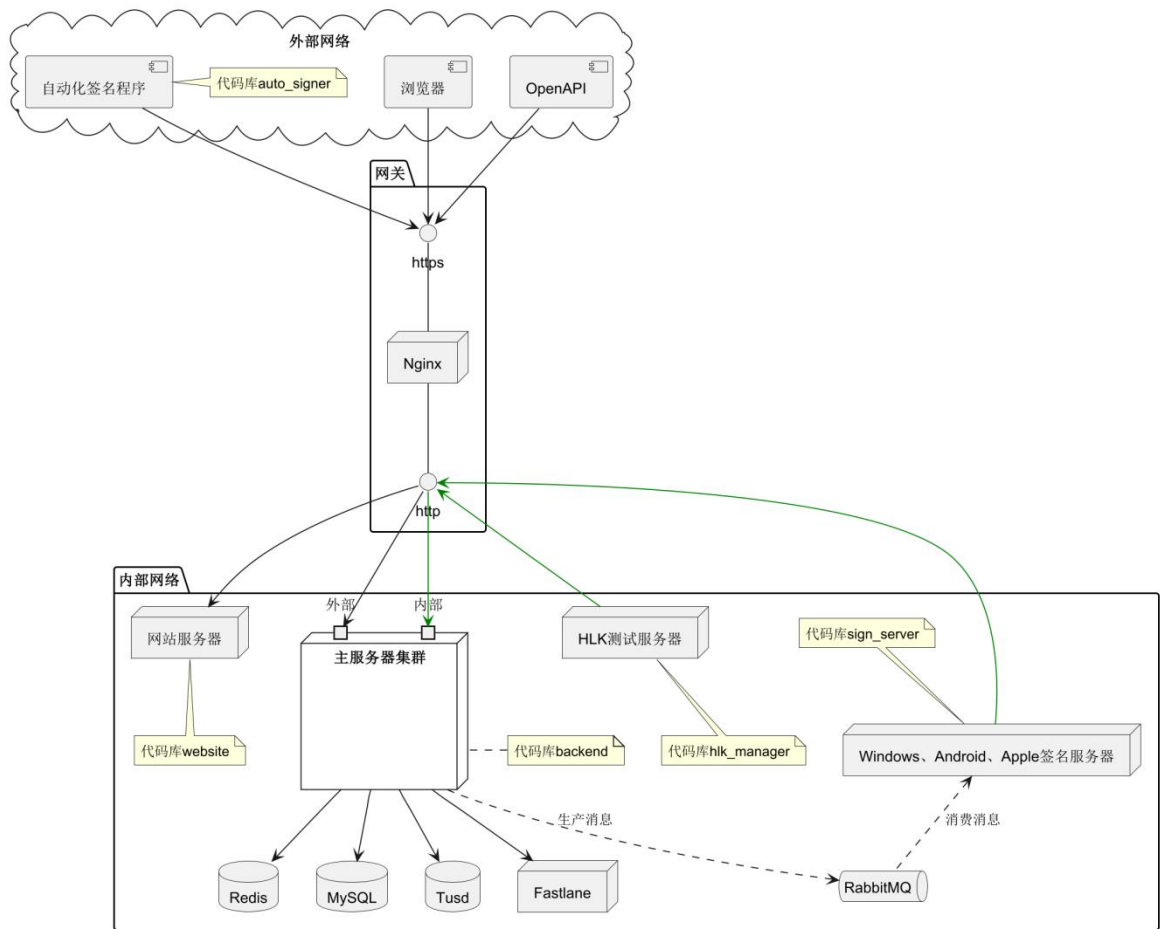


图 4-1 系统架构和网络拓扑图

表 4-1 内部服务器说明

类型	运行代码库	运行系统	说明
主服务器	backend	Linux	负责处理所有业务逻辑
网站服务器	website	Linux	给浏览器提供静态网页文件
Windows 签名服务器	sign_server	Windows	执行对 Windows PE 文件和 HLKX 文件的签名
Android 签名服务器	sign_server	Linux	执行对 Android 应用文件的签名
Apple 签名服务器	sign_server	Linux	执行对 IPA 文件的签名
各中间件服务器		Linux	运行 RabbitMQ、MySQL、Redis、Tusd 服务

网关		Linux	中转外部与内部网络的通信
HLK 测试服务器	hlk_manager	Windows	在 Hyper-V 虚拟机下搭建 HLK 测试集群，完成对驱动文件的测试
Fastlane 服务器	fastlane_proxy	Linux	运行 fastlane，完成对苹果服务器相关请求操作

4.1.2 代码库层次结构设计与第三方依赖库

通过对部署架构的设计，可推出系统需要开发的代码库。本系统采用 Golang 和 Vue 技术实现，因此根据两个语言特性设计代码层次结构。定位清晰、功能明确的代码层次设计有利于系统代码的维护拓展，减少系统异常发生概率。后台服务程序主要使用 Golang 语言编码开发，由于 Golang 语言定义，一个文件夹是一个编译单元，按照一个文件夹代表一个功能处理层次。网页采用 Vue 框架开发，采用组合式语法单文件组件编码，使用 npm 构建工具搭建。下面列出各代码层次具体功能定位，和第三方代码库依赖项。

表 4-2 Golang 代码层次一览表

文件/文件夹	说明
main.go	程序主入口，依次调用 cfg 包初始化配置，调用 log 包初始化日志打印，调用 conn 包初始化中间件服务连接，调用 cron 包启动定时任务，调用 router 包绑定路由并启动 HTTP 服务监听
config.ini	配置文件
route/	负责所有 HTTP 路由信息初始化，对 HTTP 请求路由，将每一个具体的 URL 映射到一个 Golang 方法，同时规定了一个请求需要执行的过滤逻辑函数
filter/	实现过滤和预处理 HTTP 请求，例如记录日志、处理日志打印格式、开关数据库事务、鉴权、限流等逻辑
api/	负责将 HTTP 请求数据解析转化成 Golang 数据类型变量，调用 service 包函数完成业务逻辑，并返回数据给调用方

service/	负责对业务逻辑的编排处理，包括参数权限校验，操作数据库等等
model/	定义了所有数据库实体对应的 Golang 语言结构体
protocol/	定义了所有 HTTP 请求的请求体和响应体数据对应的 Golang 语言结构体
cron/	定义了所有定时任务函数的触发时间逻辑，具体业务逻辑则调用 service 包实现
conn/	实现了与 MySQL、Redis 和 RabbitMQ 服务器的连接和关闭
cfg/	负责解析配置文件，获取配置数据
util/	放置通用函数，例如发送 HTTP 请求、集合数据处理、加解密函数等等
log	放置日志打印、日志格式化、日志持久化滚动等逻辑
ctxs	放置处理请求上下文数据的逻辑
errs	放置系统错误对象处理逻辑
consts	放置静态常量数据

表 4-3 Vue 代码层次功能一览表

文件/文件夹	说明
index.html	页面首页
src/main.js	页面第一个脚本，初始化 Vue 对象，挂载组件
src/App.vue	根部组件
src/views/	放置所有页面视图组件
src/router/	定义了组件路由信息
src/components/	放置可复用的组件
src/api/	使用 Fetch API 和 XHR 对象封装后台请求接口，供组件使用
src/assets/	放置 CSS 样式等静态文件

表 4-3 第三方代码库依赖

名称	语言	说明
github.com/golang-jwt/jwt/v5	Golang	实现 JWT 的解析和创建
gorm.io/gorm		ORM 框架实现对 MySQL 数据库的增删改查
github.com/redis/go-redis/v9		实现对 Redis 缓存库的增删改查
github.com/gin-gonic/gin		实现对 HTTP 请求的路由分发，数据解析绑定等
github.com/rabbitmq/amqp091-go		实现对 RabbitMQ 消息服务器的通信
gopkg.in/natefinch/lumberjack.v2		实现日志持久化和日志文件滚动
github.com/ivfzhou/cron/v3		实现分布式定时任务
github.com/google/uuid		生成 UUID 字符串
software.sslmate.com/src/go-pkcs12		解析 PKCS#12 证书文件
gopkg.in/yaml.v3		解析 YAML 格式文件
github.com/go-ini/ini		解析 INI 格式配置文件
github.com/go-playground/validator/v10		实现对客户端请求参数的校验
gitee.com/ivfzhou/tus_client/v2		实现对 Tusd 服务器文件的查询存取
pywinauto	Python	在 HLK 人工交互测试项中，获取和操作测试机桌面对话框
ant-design-vue	Vue	提供了丰富的 UI 组件
highcharts	Vue	可视化图表库，提供了数据图表功能
vue-router	Vue	Vue 官方组件路由库

materialdesignicons.min.css	CSS	提供了大量的 Icon 图标
-----------------------------	-----	----------------

4.2 系统功能设计

本节将阐述各功能模块的实现方法、采用的技术和数据的处理方式。

4.2.1 用户管理功能设计

用户使用浏览器打开本系统网站，由于没有登录会话将跳转到注册登录页面。引导用户注册后，将信息保存到用户信息表中。为了提高安全性，保存用户信息时，生成随机字符串，同密码一同计算 MD5^{[7]56} 散列值。用户信息表中不存储密码而是该随机字符串和散列值。当用户登录时，通过同样的计算方式得出散列值，对比数据库的散列值就能判断密码是否正确。由于用户头像文件较大，为减轻数据库存储空间压力。对头像文件进行校验，确保文件格式是合法的 PNG/JPG，保存到 Tusd 服务器，然后在文件信息表中维护该文件信息。为维护用户登录会话，注册登录成功后将用户英文名、IP 和分配的会话密钥保存到 Redis 服务器中，并设置过期时间。同时在浏览器 Cookie 中保存英文名和会话密钥。在所有需要获取和校验用户信息的接口中，都将浏览器 Cookie 中会话数据同 Redis 中的对比，确保相同。

4.2.2 应用管理功能设计

用户登入本系统后可以注册应用，跳转到注册页面，填入应用名、平台等信息，保存到应用信息表中。应用与成员的关联信息存放到用户权限表中。应用图标的处理方法同用户头像一样。应用注册更新等行为产生的事件记录到应用事件表中，方便应用成员追溯使用记录。在应用注册和有效化时，添加待办表记录，待系统运营员审批后，更新应用表状态字段。由于编辑应用成员后，存在可能有人失去应用管理员权限，导致失去管理员权限的人审批待办出现系统错误。为避免该异常发生，更新应用信息的同时，应更新还未处理的应用待办表记录，更新其审批人。

4.2.3 事件统计功能设计

在系统需求分析中，申请证书、提交签名等类似写类型操作都会记录事件，保存到应用事件表中。然后用户在应用事件检索页面上按条件筛选，后台从数据库应用事件表中按条件分页检索数据，将数据返回给页面展示。

4.2.4 待办管理功能设计

在页面上展示用户自己可审批和自己提交的待办，后台按条件分页检索待办表。在审批用户注册应用的待办中，待办表中存有对应应用的 ID，系统管理员审批时，更新对应应用的状态字段。在审批用户加入应用的待办中，审批通过就在用户权限表中添加用户对应权限记录。在审批注册苹果测试设备的待办中，待办表中存有对应设备的 ID，审批通过后，请求苹果服务器注册设备，并更新设备表状态字段。在审批应用有效化的待办中，审批通过时更新应用表状态字段。

4.2.5 证书管理功能设计

Windows 平台应用证书管理功能设计。应用成员在应用页面下浏览和管理证书。用户上传个人 OV 证书时，将证书文件内容以 Base64 编码后再传输给后台处理。由于该证书包含私钥数据，为了证书的安全性，在解析获取完证书元数据后，将证书内容使用对称算法加密后，一起保存到 Windows 证书信息表中。在展示应用的证书信息列表时，由于存在公司和个人类型证书，以及授权的 EV 证书，应从 Windows 证书信息表和授权信息表中将所有公司证书和属于应用的个人证书全部检索出来展示。为尽可能防止数据丢失，用户删除证书时，只设置 Windows 证书信息表的删除标识字段，表示删除，而不是物理删除。此外，在 Attestation 和 WHQL 签名中，由于微软要求提交到网站上的文件需要签名，所以在 Windows 证书表中维护该类证书，一并管理。

Android 平台应用证书管理功能设计。在应用证书管理页面中获取 Google Play 相关证书文件，通过运行谷歌公司提供的 pepk.jar 和 JDK 中的 keytool 程序获取到 Google Play 相关证书文件。用户上传证书时，同样采用对证书 Base64 编码后传输。申请证书和获取证书信息，可以通过 keytool 程序实现。获取 Facebook 密钥散列时，根据官方的操作指南获取：先证书计算 SHA1 摘要，再 Base64 编码。由于安卓密钥库包含私钥数据，同样使用对称加密算法加密后再保存到安卓证书信息表中。

Apple 平台应用证书管理功能设计。在应用页面下分别展示 BundleID、证书/描述文件和测试设备列表页面。对 BundleID、签名证书、描述文件和测试设备的相关操作都可以通过 App Store Connect API 实现，但是它不支持申请企业级账号的描述文件和推送证书。为了自动化实现申请，而不用人工去 Apple

开发者中心申请，使用 fastlane 能实现对该类描述文件和证书的申请。将 BundleID、证书、描述文件和测试设备分别保存到对应的信息表中。由于应用下只需申请描述文件，对应证书由系统运营员管理，所以在应用证书/描述文件列表中，除了检索出属于应用申请的描述文件，还从苹果证书表中检索出对应的证书，方便用户浏览使用。在测试设备注册时，生成的待办记录状态为待审批，待系统运营员审批通过后才向苹果服务器发送注册申请。

4.2.6 OpenAPI 凭证管理功能设计

OpenAPI 凭证用于用户在自动化获取本系统服务的场景。用户在应用页面下管理凭证，将凭证和授权信息保存到凭证表和凭证授权表中。以便客户端请求过来时，检索对应表判断请求是否合法。采用 JWT 数据编码和鉴权方式^[17]，客户端使用凭证 ID 和密钥生成 JWT 字符串，后台对其解密鉴权。此外，为了系统有更好的稳定性，在 Redis 中实现令牌桶算法限制用户请求频率。

4.2.7 签名管理功能设计

Windows 平台应用签名功能设计。用户在应用页面下提交签名，查看签名记录和进展信息。在 Windows 签名任务表中保存维护 Windows PE 文件和微软 Attestation 签名任务信息，而在 WHQL 签名任务表中保存 HLK 测试和 WHQL 签名信息。签名机消费主服务器发送的签名信息，与主服务通信，获取签名文件和证书，执行具体签名逻辑。使用 Windows SDK 中的 signtool.exe 程序实现对 PE 文件签名^[18]，而 Attestation 和 WHQL 签名可以购买微软服务，使用它提供的 API 实现自动化签名。通过 PowerShell 语言调用 HLK Studio 类库，能实现 HLK 测试的自动化。由于 HLK 测试有一些人工交互项，需要在测试系统桌面操作对话框。通过 Python 代码库 pywinauto 实现对桌面对话框的读取与操作，完成测试交互项。获取微软签名中，从提交到结束需要较长时间，因此采用定时任务处理。在任务表中维护任务所处状态的字段，定时任务中检索出具体状态的任务再进行对应处理。而在 HLK 测试中，由于测试耗时非常长，包含准备测试、测试中等状态，因此在任务表中维护测试进展状态字段。测试机 HTTP 请求主服务器，主动拉取测试任务、更新任务状态，推进测试进程。

Android 平台应用签名功能设计。用户在应用页面下提交和管理签名任务，任务信息保存在安卓签名任务表中。同 Windows 签名类似，具体执行签名逻辑

辑放到安卓签名机上。签名机通过消息队列获取签名任务，通过 HTTP 与主服务器通信完成更新安卓任务表等操作。运行谷歌 Android Studio 中的 apksigner 和 JDK 中的 jarsigner 完成对文件的签名^[19-21]。

Apple 平台应用签名功能设计。用户在签名页面中提交签名任务，将任务信息保存到苹果签名任务表中。签名机消费主服务器发送的 MQ 签名消息，HTTP 请求主服务器获取到签名文件、证书和描述文件，调用 zsign 程序执行签名逻辑^[22-24]，最后上传结果文件和更新任务表。

4.2.8 后台管理功能设计

Windows 平台应用的公共证书管理功能设计。系统运营员在后台管理页面中添加公司证书、授权个人 EV 证书等行为。公共证书存放在 Windows 证书表中，而个人 EV 证书授权应用信息存放到 EV 授权表中。由于该类证书包含私钥数据，所以加密后保存。

Android 平台应用的公共证书管理功能设计。系统运营员在页面上增加安卓证书主体，主体信息保存到安卓证书主体表中。

Apple 平台应用的证书管理功能设计。系统运营员在后台管理中申请各类型苹果签名证书。通过 HTTP 请求苹果服务器申请与删除证书，同时添加与更新苹果证书表记录。同样，更新删除标识字段表示证书记录删除。

统计图表功能设计。在后台管理页面中展示各签名任务耗时和成功率折线图，以及应用事件柱状图。系统运营员按时间范围等条件检索，通过任务表中字段创建时间减去结束时间得出耗时，根据任务状态判断成功与否，应用事件数量通过统计应用事件表记录获取。

公告管理功能设计。系统运营员在后台管理页面中添加与删除公告，系统页面顶部横幅展示公告。将公告信息存放到公告信息表中，将创建时间最晚且在生效时间内的一条公告作为要展示的公告。

4.3 系统数据库设计

信息系统的数据库设计是一项重要工作，将直接影响系统的数据存储和执行性能。数据库实体描述了现实世界事物及其之间的关系，设计出高效、合理、简洁的数据库结构，以满足系统稳定运行和拓展的需要。通过对系统功能需求的分析设计，可以推导出本系统需要设计的数据库实体，理清各数据实体间的

联系和约束，构造出实体-联系概念模型图。下面分析设计出了各功能模块数据库实体 E-R 模型图，为精简篇幅，不再对各功能模块的数据库实体和关系进行说明。

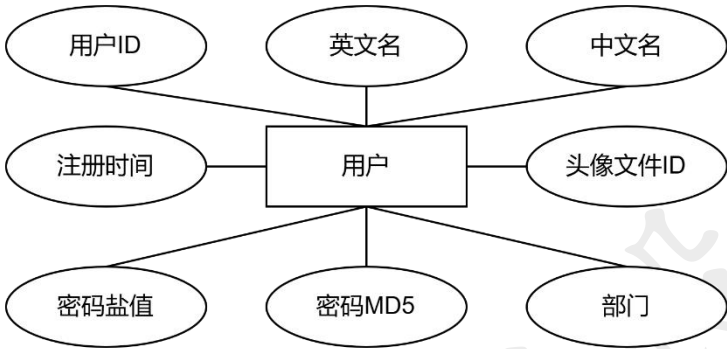


图 4-2 用户功能模块实体 E-R 模型图

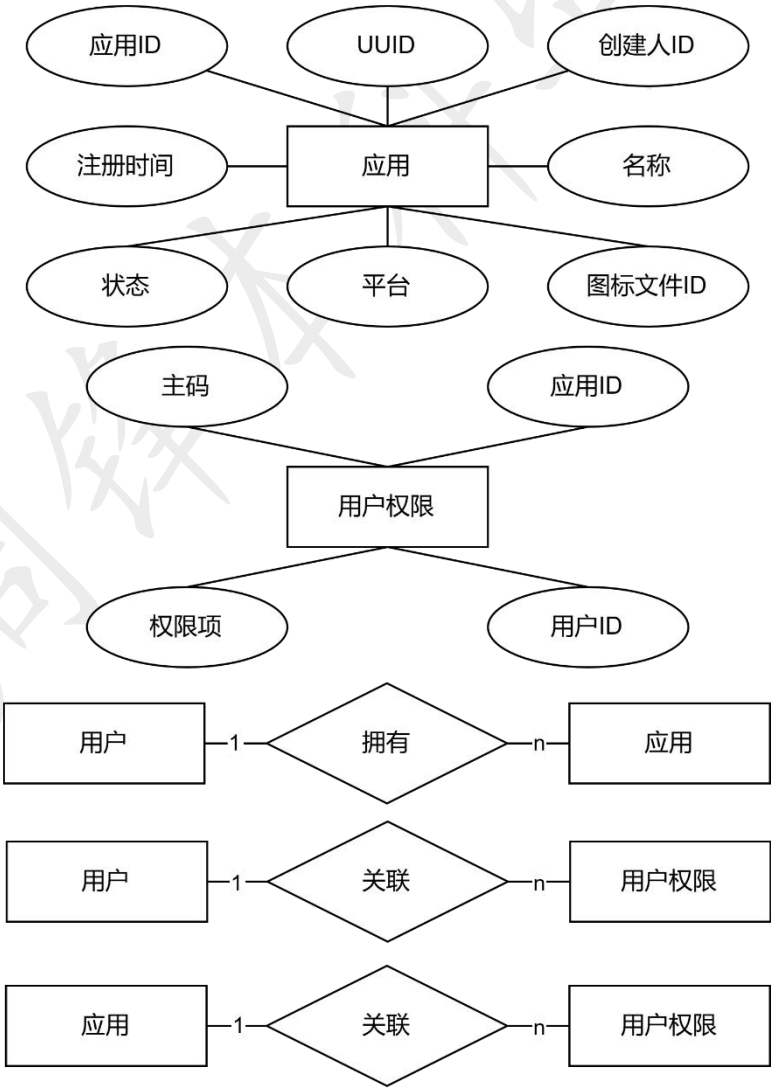


图 4-3 应用功能模块实体 E-R 模型图

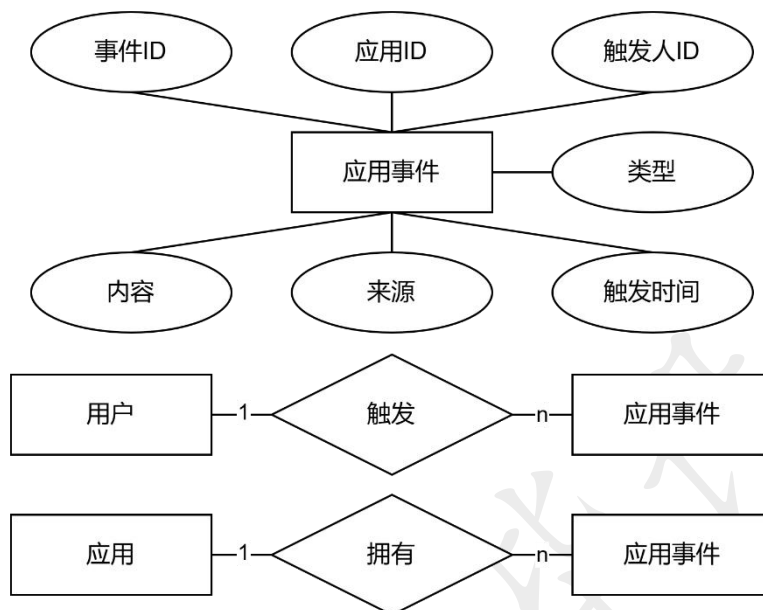


图 4-4 事件功能模块实体 E-R 模型图

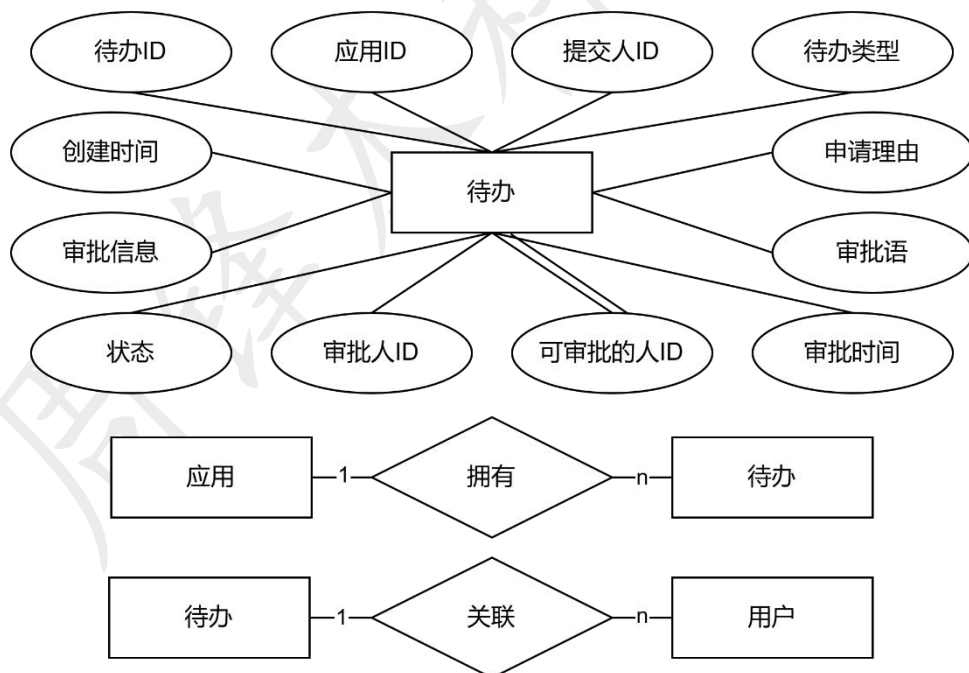


图 4-5 待办功能模块实体 E-R 模型图

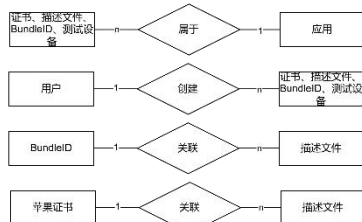
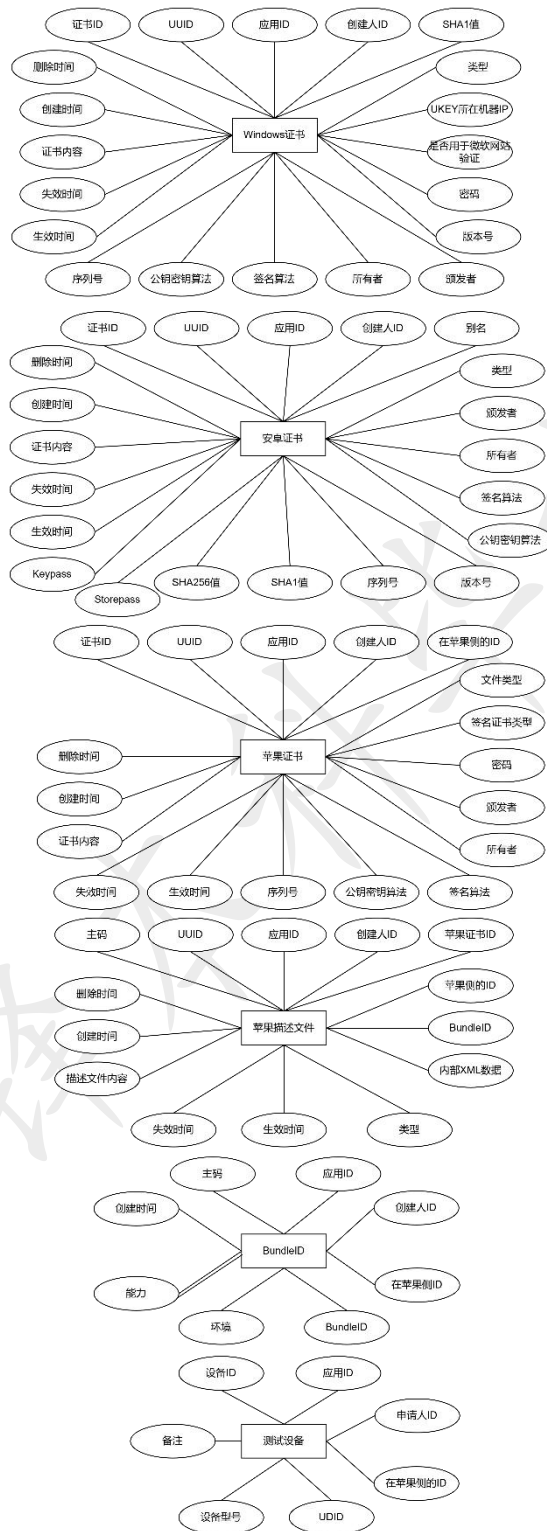


图 4-6 证书功能模块实体 E-R 模型图

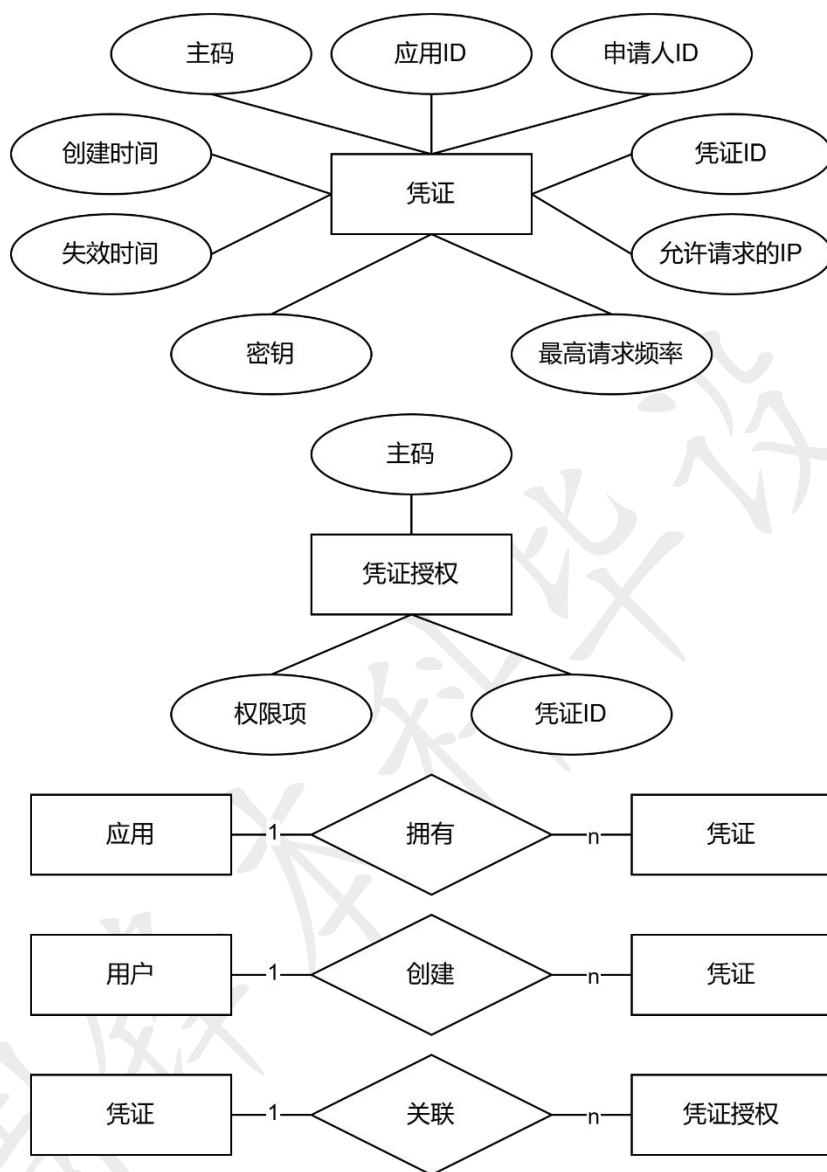


图 4-7 OpenAPI 凭证功能模块 E-R 模型图

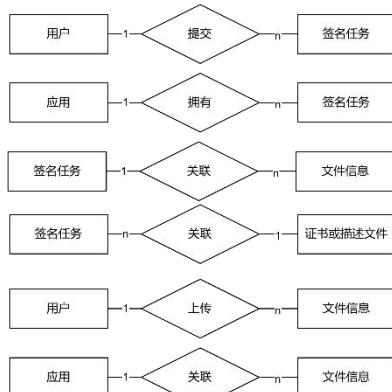
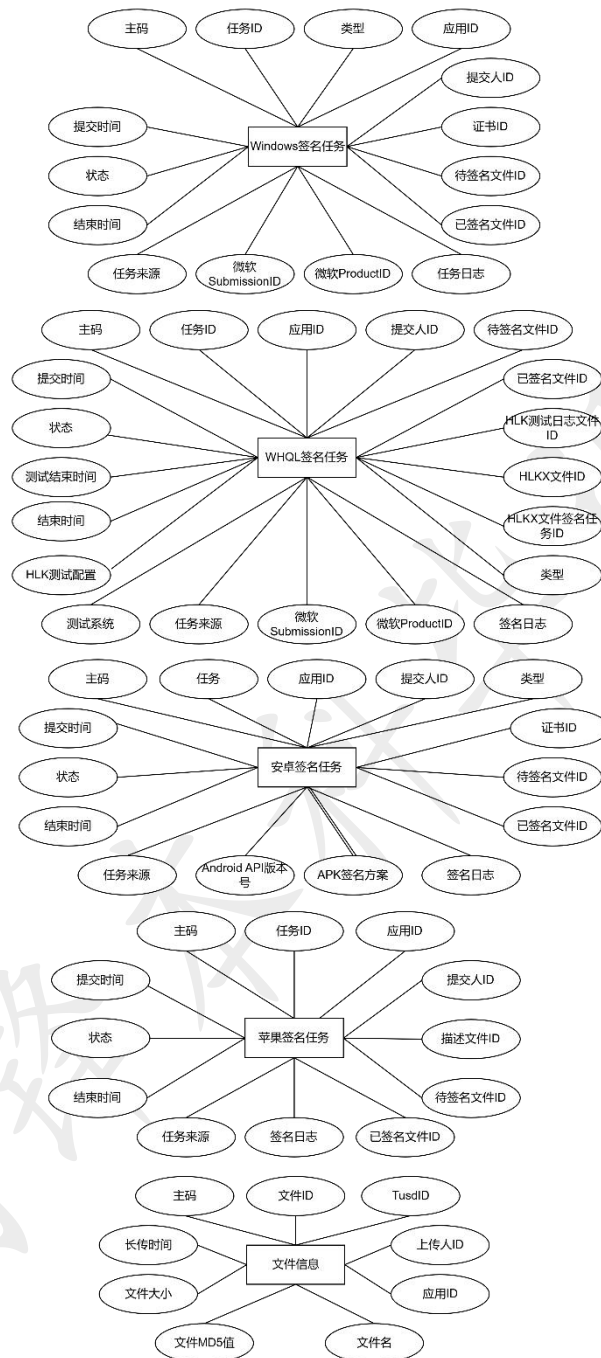


图 4-8 签名功能模块 E-R 模型图

周鑫本科毕设

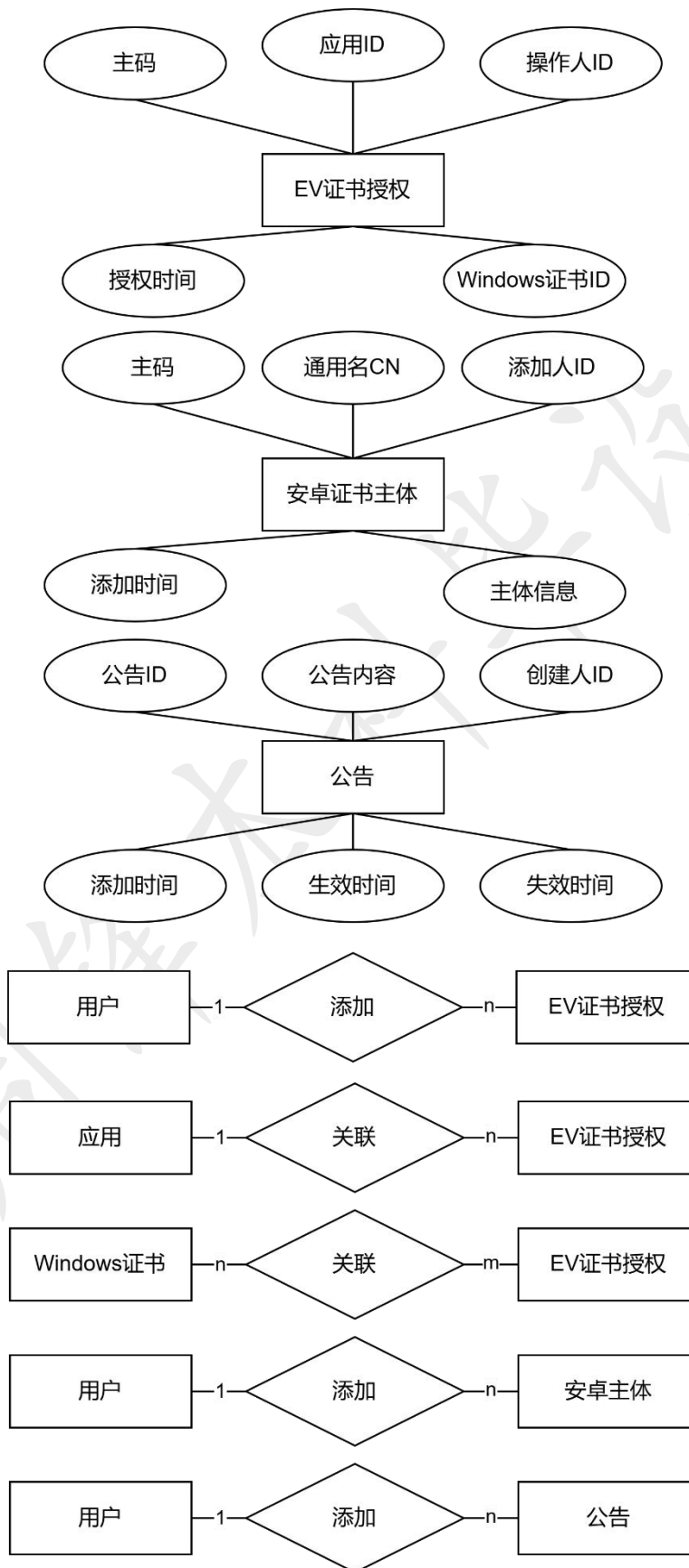


图 4-9 后台功能模块 E-R 模型图

完成系统的实体-联系概念模型的设计后，接下来可以将其转化为对应数据库的逻辑物理结构。由于本系统数据库采用 MySQL 技术，所以下面将使用 MySQL 方言设计数据库物理结构。由于本系统主要提供自动化签名，签名任务和签名文件可预计将非常多，数据库表过多数据记录会造成数据库服务变慢，甚至服务不可用。从系统架构设计中，本系统的主服务器可以弹性部署，以适应不同压力场景。但数据库服务单一，容易成为整个系统瓶颈。为了本系统适应更多企业工况，保存系统稳定运行，将签名任务、文件信息和应用事件按自然月拆分表。按年月时间维度拆分这些大表，即一个月份一张表，表名后加上“_yyyymm”指明是哪个月份的数据。这些表的 ID 也附上年月信息，当查询记录时，可以快速定位到具体表，或者从最新表开始检索直到最早的表。

表 4-4 t_user 用户信息表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
name_en	varchar(32)	非空，唯一	英文名
name_zh	varchar(16)	非空	中文名
avatar	char(38)	非空	头像文件 ID
department	varchar(1024)	非空	部门组织，以/分隔
passwd_digest	char(32)	非空	密码 MD5
passwd_salt	char(128)	非空	密码盐值
created_time	timestamp	非空	注册时间
updated_time	timestamp		更新时间
uidx_name_en	name_en		唯一索引

表 4-5 t_app 应用信息表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
app_id	char(32)	非空，唯一	唯一标识
user_id	int unsigned	外码	创建人 ID

name	varchar(64)	非空	应用名
logo	char(38)	非空	图标文件 ID
platform	tinyint unsigned	非空	平台，1=Windows、 2=Apple、3=Android
status	tinyint unsigned	非空	状态，1=有效、2=无效、 3=审批中、4=审批驳回
updated_time	timestamp		更新时间
uidx_app_id	app_id		唯一索引
idx_created_time	created_time		索引
idx_status	status		索引

表 4-6 t_user_role 用户权限表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
app_id	int unsigned	外码	所属应用 ID
user_id	int unsigned	外码	用户 ID
role	tinyint unsigned	非空	角色，1=系统运营员、 2=应用管理员、3=应用 成员、4=可使用签名服 务
uidx_app_id_user_id	app_id, user_id		唯一索引
idx_user_id	user_id		索引

表 4-7 t_event 应用事件表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
app_id	int unsigned	外码	所属应用 ID
user_id	int unsigned	外码	触发人 ID
type	tinyint unsigned	非空	类型，见表 3-3

created_time	timestamp	非空	事件发生时间
source	tinyint unsigned	非空	来源，1=页面、 2=OpenAPI
content	text		事件内容
idx_app_id	app_id		索引
idx_user_id	user_id		索引
idx_created_time	created_time		索引
idx_type	type		索引

表 4-8 t_todo 待办表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
app_id	int unsigned	外码	所属应用 ID
type	tinyint unsigned	非空	类型，见表 3-4
applier_id	int unsigned	外码	申请人 ID
approver_id	int unsigned	外码	审批人 ID
candidates	varchar(256)	非空	可审批的人 ID， 英文逗号分隔
apply_reason	varchar(256)		申请理由
approve_message	varchar(256)		审批语
information	text		审批对象信息
status	tinyint unsigned	非空	状态，1=待处理、 2=驳回、3=同意
created_time	timestamp	非空	创建时间
finished_time	timestamp		结束时间
idx_app_id_type	app_id, type		索引
idx_applier_id	applier_id		索引
idx_approver_id	approver_id		索引
idx_status	status		索引

idx_created_time	created_time		索引
------------------	--------------	--	----

表 4-9 t_windows_certificate Windows 证书信息表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
certificate_id	char(32)	非空，唯一	唯一标识
app_id	int unsigned	外码	所属应用 ID
user_id	int unsigned	外码	创建人 ID
sha1	char(40)	非空	指纹
type	tinyint unsigned	非空	类型，1=公司 EV、2=公司 OV、3=个人 EV、4=个人 OV
ip	varchar(15)		UKEY 所在机器 IP
is_microsoft_verify_certificate	bit(1)		是否是微软网站的验证证书
password	varchar(16)	非空	密码
version	int unsigned		版本号
publisher	varchar(1024)		颁发者
common_name	varchar(64)	非空	通用名
owner	varchar(1024)		所有者
signature_algorithm	varchar(64)		签名算法
public_key_algorithm	varchar(64)		公钥密码算法
serial_number	char(40)		序列号
not_before	datetime	非空	生效时间

not_after	datetime	非空	失效时间
aes_key_id	int unsigned		证书加密密钥 ID
content	mediumblob		加密了的证书内容
created_time	timestamp	非空	创建时间
deleted_time	timestamp		删除时间
idx_app_id	app_id		索引
uidx_certificate_id	certificate_id		唯一索引

表 4-10 t_android_certificate 安卓证书信息表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
certificate_id	char(32)	非空，唯一	唯一标识
app_id	int unsigned	外码	所属应用 ID
user_id	int unsigned	外码	创建人 ID
alias	varchar(64)	非空	别名
category	tinyint unsigned	非空	类型，1=调试、2=发布
publisher	varchar(1024)		颁发者
owner	varchar(1024)		所有者
signature_algorithm	varchar(64)		签名算法
public_key_algorithm	varchar(64)		公钥密码算法
version	varchar(32)		版本号
serial_number	char(8)		序列号
store_provider	varchar(64)		证书提供方
store_type	varchar(64)		证书格式类型
creation_date	date		证书创建时间
sha1	char(40)		证书 SHA1 摘要值

sha256	char(64)		证书 SHA256 摘要值
storepass	varchar(32)	非空	密钥库解密密码
keypass	varchar(32)	非空	私钥解密密码
not_before	datetime	非空	生效时间
not_after	datetime	非空	失效时间
aes_key_id	int unsigned	非空	证书加密密钥 ID
content	mediumblob	非空	加密了的密钥库
created_time	timestamp	非空	创建时间
deleted_time	timestamp		删除时间
idx_app_id	app_id		索引
uidx_certificate_id	certificate_id		唯一索引

表 4-11 t_apple_certificate 苹果证书信息表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
certificate_id	char(32)	非空，唯一	唯一标识
app_id	int unsigned	外码	所属应用 ID
user_id	int unsigned	外码	创建人 ID
in_apple_id	char(10)	非空	在苹果服务器的 ID
environment	tinyint unsigned		Push 证书环境，1=正式、2=开发、3=企业内测
bundle_id	int unsigned		Push 证书对应的 BundleID
category	tinyint unsigned	非空	文件类型，1=签名证书、2=Push 证书
type	varchar(32)		签名证书类型，由苹果 API 中定义，例如 IOS_DEVELOPMENT 等

password	varchar(16)	非空	密码
publisher	varchar(1024)		颁发者
owner	varchar(1024)		所有者
signature_algorithm	varchar(64)		签名算法
public_key_algorithm	varchar(64)		公钥密码算法
serial_number	char(32)		序列号
not_before	datetime	非空	生效时间
aes_key_id	tinyint unsigned	非空	证书加密密钥 ID
not_after	datetime	非空	失效时间
content	mediumblob	非空	加密了的证书内容
created_time	timestamp	非空	创建时间
deleted_time	timestamp		删除时间
idx_app_id	app_id		索引
uidx_certificate_id	certificate_id		唯一索引

表 4-12 t_apple_profile 苹果描述文件信息表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
profile_id	char(32)	非空，唯一	唯一标识
app_id	int unsigned	外码	所属应用 ID
user_id	int unsigned	外码	创建人 ID
certificate_id	int unsigned	外码	证书表 ID，根据该证书申请的描述文件
in_apple_id	char(10)	非空	在苹果服务器的 ID
bundle_id	int unsigned	外码	描述文件对应的 BundleID
text	text	非空	描述文件中的

			XML 内容
type	varchar(32)	非空	描述文件类型, 由苹果 API 中定义, 例如: IOS_APP_STORE
not_before	datetime	非空	生效时间
not_after	datetime	非空	失效时间
content	mediumblob	非空	描述文件的内容
created_time	timestamp	非空	创建时间
deleted_time	timestamp		删除时间
idx_app_id	app_id		索引
uidx_profile_id	profile_id		唯一索引

表 4-13 t_apple_bundle_id BundleID 信息表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
app_id	int unsigned	外码	所属应用 ID
user_id	int unsigned	外码	申请人 ID
in_apple_id	char(10)	非空	在苹果服务中的 ID
bundle_id	varchar(64)	非空	Apple 应用唯一标识, 域名倒置点号分隔的形式
environment	tinyint unsigned	非空	环境, 1=App Store, 2=企业内测
platform	tinyint unsigned	非空	平台, 1=IOS、2=MAC_OS、3=UNIVERSAL

capabilities	mediumtext	非空	BundleID 的能力项,以英文逗号分隔
created_time	timestamp	非空	创建时间
updated_time	timestamp		更新时间
idx_app_id	app_id		索引
uidx_bundle_id	bundle_id		唯一索引

表 4-14 t_apple_device 苹果测试设备信息表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
app_id	int unsigned	外码	所属应用 ID
user_id	int unsigned	外码	申请人 ID
in_apple_id	char(10)		在苹果服务器中的 ID
udid	varchar(128)	非空	设备 ID
model	varchar(32)		设备型号
remark	varchar(1024)		备注
status	tinyint unsigned	非空	状态, 1=正常、2=待审核、3=未通过
created_time	timestamp	非空	创建时间
updated_time	timestamp		更新时间
idx_app_id	app_id		索引

表 4-15 t_api_account OpenAPI 凭证信息表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
app_id	int unsigned	外码	所属应用 ID
user_id	int unsigned	外码	申请人 ID
account_id	varchar(64)	非空	凭证 ID

ip	varchar(256)	非空	可以放行的 IP、IP 段，*号表示所有，逗号分隔
frequency	int unsigned	非空	每分钟最高请求次数
secret	char(128)	非空	密钥
expired_time	timestamp	非空	失效时间
created_time	timestamp	非空	创建时间
updated_time	timestamp		更新时间
uidx_app_id_account_id	app_id, account_id		唯一索引

表 4-16 t_api_authorization OpenAPI 凭证授权表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
api_accout_id	int unsigned	外码	OpenAPI 凭证信息表 ID
capability	tinyint unsigned	非空	权限项，对应表 3-5
idx_api_accout_id	api_accout_id		索引

表 4-17 t_windows_signing_job Windows 签名任务表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
job_id	char(38)	非空，唯一	任务 ID，前 6 为是年月，后面是 UUID
type	tinyint unsigned	非空	类型，1=PE 签名、2=微软 Attestation 签名、3=PE+微软

			Attestation 签名、 4=HLKX 文件签名
app_id	int unsigned	外码	所属应用 ID
user_id	int unsigned	外码	提交人 ID
certificate_id	int unsigned	外码	Windows 证书表 ID
file_id	char(38)	非空	待签名文件 ID
signed_file_id	char(38)		已签名文件 ID
log	mediumtext		任务日志
product_id	char(17)		微软侧的 ID
submission_id	char(19)		微软侧的 ID
source	tinyint unsigned	非空	来源，1=页面、 2=OpenAPI、3= 内部
finishd_time	timestamp		结束时间
finish_pe_time	timestamp		完成 PE 签名时间
status	tinyint unsigned	非空	状态，1=签名中、 2=等待 Cab 签名、 3=Cab 签名中、 4=待 Attestation 签名、 5=Attestation 签名中、 6=失败、 7=成功
created_time	timestamp	非空	提交时间
updated_time	timestamp	更新时设置为当前时间	更新时间

idx_app_id	app_id		索引
idx_status	status		索引
uidx_job_id	job_id		唯一索引

表 4-18 t_whql_job WHQL 签名任务表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
job_id	char(32)	非空，唯一	任务 ID
app_id	int unsigned	外码	所属应用 ID
user_id	int unsigned	外码	提交人 ID
file_id	char(38)	非空	待签名文件 ID
signed_file_id	char(38)		已签名文件 ID
hlk_log_file_id	char(38)		HLK Studio 日志包文件 ID
hlkx_file_id	char(38)		HLKX 文件 ID
hlkx_sign_job_id	char(38)		HLKX 文件签名任务 ID，对应 Windows 任务表中的 ID
type	tinyint unsigned	非空	类型，1=HLK 兼容性测试+WHQL 签名、2=仅 WHQL 签名
log	mediumtext		任务日志
product_id	char(17)		微软侧的 ID
submission_id	char(19)		微软侧的 ID
service_name	varchar(256)		服务名
test_target	varchar(256)		测试目标
source	tinyint unsigned	非空	来源，1=页面、

			2=OpenAPI
test_system	varchar(32)		测试系统
test_machine_name	varchar(15)		测试机器名
test_config	text		HLK 测试项配置
finished_time	timestamp		结束时间
finish_test_time	timestamp		测试结束时间
status	tinyint unsigned	非空	状态，1=待 HLK 测试、2=测试机初始化中、3=测试机初始化完毕，4=启动 HLK 测试中，5=HLK 测试中，6=HLK 测试完毕、7=HLKX 文件签名中、8=等待 WHQL 认证结果中、9=失败、10=成功
created_time	timestamp	非空	提交时间
updated_time	timestamp	更新时设置为当前时间	更新时间
idx_app_id	app_id		索引
idx_status	status		索引
uidx_job_id	job_id		唯一索引

表 4-19 t_android_signing_job 安卓签名任务表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
job_id	char(38)	非空，唯一	任务 ID，前 6 为

			是年月，后面是 UUID
app_id	int unsigned	外码	所属应用 ID
user_id	int unsigned	外码	提交人 ID
type	tinyint unsigned	非空	类型，1=APK 签名、2=AAB 签名、3=补丁签名
certificate_id	int unsigned	外码	安卓证书表 ID
file_id	char(38)	非空	待签名文件 ID
signed_file_id	char(38)		已签名文件 ID
log	mediumtext		任务日志
signature_schemas	varchar(32)		APK 签名方案，英文逗号分隔
minimum_sdk_level	int unsigned		补丁包签名 SDK API 最低版本号
source	tinyint unsigned	非空	来源，1=页面、2=OpenAPI
finished_time	timestamp		结束时间
status	tinyint unsigned	非空	状态，1=进行中、2=成功、3=失败
created_time	timestamp	非空	提交时间
idx_app_id	app_id		索引
uidx_job_id	job_id		唯一索引

表 4-20 t_apple_signing_job 苹果签名任务表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
job_id	char(38)	非空，唯一	任务 ID，前 6 为是年月，后面是

			UUID
app_id	int unsigned	外码	所属应用 ID
user_id	int unsigned	外码	提交人 ID
profile_id	int unsigned	外码	描述文件表 ID
file_id	char(38)	非空	待签名文件 ID
signed_file_id	char(38)		已签名文件 ID
log	mediumtext		任务日志
source	tinyint unsigned	非空	来源, 1=页面、 2=OpenAPI
finished_time	timestamp		结束时间
status	tinyint unsigned	非空	状态, 1=进行中、 2=成功、3=失败
created_time	timestamp	非空	提交时间
idx_app_id	app_id		索引
uidx_job_id	job_id		唯一索引

表 4-21 t_file 文件信息表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
file_id	char(38)	非空, 唯一	文件 ID, 前 6 位 是年月, 后 32 位 是 UUID
tusd_id	char(32)	非空	在 Tusd 服务器的 ID
user_id	int unsigned	外码	上传者 ID
api_account_id	int unsigned	外码	上传凭证 ID
app_id	int unsigned	外码	所属应用 ID
name	varchar(256)		文件名
md5	char(32)		文件摘要

size	int unsigned		文件大小
type	tinyint unsigned	非空	类型，1=用户头像、2=应用图标、3=Android 签名文件、4=Windows 签名文件、5=Apple 签名文件、6=HLK 日志文件、7=微软方的结果文件
created_time	timestamp		上传时间
idx_md5	md5		索引
uidx_file_id	file_id		唯一索引

表 4-22 t_windows_certificate_authorization 授权应用 EV 证书表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
app_id	int unsigned	外码	所属应用 ID
user_id	int unsigned	外码	操作人 ID
certificate_id	int unsigned	外码	Windows 证书表 ID
created_time	timestamp	非空	授权时间
idx_certificate_id_app_id	certificate_id, app_id		唯一索引

表 4-23 t_android_organization 安卓证书主体表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
name	varchar(32)	非空，唯一	通用名 CN

user_id	int unsigned	外码	添加人 ID
owner	varchar(256)	非空，唯一	所有者，用于 keytool 中的 dname 参数值
created_time	timestamp	非空	创建时间

表 4-24 t_aes_key 证书加密密钥表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
secret	binary(16)	非空	密钥
created_time	timestamp	非空，默认当前时间	创建时间

表 4-25 t_notice 公告信息表

字段名	数据域	约束	说明
id	int unsigned	主码	自增主码
content	text	非空	公告内容
user_id	int unsigned	外码	创建人 ID
expired_time	timestamp	非空	失效时间
activated_time	timestamp	非空	生效时间
created_time	timestamp	非空	创建时间
idx_created_time	created_time		索引

5 系统实现与测试

5.1 系统开发测试环境

系统代码开发完后，需要部署到和生产基本一致的环境下调试测试功能，从而确保系统的可靠性、系统逻辑地正确性。由于个人电脑环境下能模拟出整个部署环境，所以在 Windows 操作系统下开发编码测试。使用 IntelliJ IDEA 编写 Golang、Python、Vue 代码，Visual Studio 编写 C#代码，Visual Studio Code 编写 PowerShell 代码，Chrome 浏览器渲染页面效果。Golang、Python、Java 的 SDK 都在安装在本地。

在 Hyper-V 虚拟机中运行 Debian 系统，部署运行中间件 MySQL、Redis、RabbitMQ、Tusd 和 Nginx 服务。主后台服务器和各签名服务器在本机 IDE 上运行。在 Hyper-V 虚拟机下搭建 HLK 测试环境，hlk_manager 代码库编码完成后放在虚拟机上运行调试功能。

表 5-1 开发环境信息

名称	版本
Windows 操作系统	Windows 10 22H2
IntelliJ IDEA	2024.3.1.1 (Ultimate Edition)
Visual Studio Code	1.96.0
Visual Studio	2022 Community
Chrome	131.0.6778.205
Golang	1.23.2
JDK	23.0.1
Vue	3.4.29
Python	3.13

5.2 系统核心代码的实现

5.2.1 日志与链路追踪策略实现

日志是诊断服务器运行异常原因的极佳工具，同时也是发现系统不足和缺陷的一个途径。良好的日志格式和日志数量，对于日志的浏览和检索是非常重

要的。在代码 `ctxs` 包中维护每个请求的上下文信息，辅助日志生成。在代码 `filter` 包的 `LogFmtFilter` 函数中初始化每个请求链路日志的链路 ID。若本次 HTTP 请求头中有字段 `X-CSMS-Request-Id` 则取其值作为链路 ID，否则随机生成一个。在对外发送 HTTP 请求时，都在 HTTP 请求头上设置 `X-CSMS-Request-Id` 字段值作为链路 ID。所以各个服务器之间，同一个请求链路的日志都会有相同的链路 ID，方便检索出整个请求链路上的日志。本系统统一所有代码库输出的日志格式，每条日志包含时间、级别、链路标识、代码位置等信息

```
<时间> <日志级别> <服务器名> <链路标识> <打印位置> <上下文> <userId/凭证Id> <请求IP> <URL> <堆栈信息> -- <内容>

2024-04-08 23:21:10.001 INFO backend ecbe1af2e151dfa2b6689823c9eebb70 main.go:17 init -- start init
2024-04-08 23:21:10.001 INFO backend 437adfa85065d2883e2977689832c7a8 service/user_service.go:90 1 192.168.137.128 /web/user/info -- get user info
```

图 5-1 日志打印格式

5.2.2 Web 登录会话鉴权实现

需要用户登录后才能浏览操作的 Web 接口都需要先校验登录会话，否则返回提示需要登录后操作。登录鉴权逻辑由在 `filter` 包下 `WebAuthFilter` 函数实现，在 `route` 包中，需要鉴权的路由都加上这个函数过滤。鉴权通过后调用 `gin` 上下文对象 `c.Next()` 函数即可继续处理业务请求，否则调用 `c.Abort()` 中止无权请求。

用户的登录凭证放在 HTTP Cookie 中，使用 Golang 标准库函数 `http.SetCookie` 将登录会话密钥和用户名设置到浏览器，键为 `csms_session` 和 `csms_user`。鉴权时使用 Golang 标准库的 `http.Request` 对象 `req.Cookie()` 获取 Cookie 的值。然后以 `csms_user` 的 Cookie 值作为 Redis String 键名，检索 Redis 获取登陆会话数据。如果不存在该键则提示页面登录会话过期，存在的情况下，反序列化 JSON 数据，获取其中的用户 ID、会话密钥和登录 IP。校验会话密钥是否相等、请求与登录的 IP 是否相等。之后使用 `ctxs` 包下的相关函数将用户英文名存入 `http.Request` 的上下文中，方便后续代码逻辑获取该请求的用户信息。

此处获取请求方 IP 的方法，是使用 Nginx 的 `$remote_addr` 变量设置转发 HTTP 请求头 `X-Real-IP`。主后台服务器中通过检查 HTTP 请求头 `X-Real-IP` 获取客户端真实请求 IP。

5.2.3 OpenAPI 访问鉴权实现

所有 API 请求都需设置 HTTP 请求头 `Authorization` 字段，字段值是 JWT 格式字符串，同时加上 “`Bear`” 前缀。主后台服务器中 `filter` 包过滤函数 `APIAuthFilter` 负责校验 JWT 字符串合法性。使用第三方依赖库 `jwt.Parse` 函数解析 JWT 凭证，从 `iss` 和 `sub` 字段中获取凭证的应用 ID 和凭证 ID，检索数据库凭证信息表获取凭证密钥，把密钥交给 `jwt.Parse` 函数校验凭证合法性。

凭证通过 JWT 合法性校验后，再依次校验请求 IP 和请求频率。对于请求 IP 校验，将 IP 转化成 32 位格式的数字，进行判等或比大小的方式校验。对于请求频率校验，在 Redis 中运行 Lua 脚本执行令牌桶逻辑校验。令牌桶逻辑大致流程如下：每次请求到来时计算距离上次请求的时间差，计算这个时间差可生成的请求量，加上上次剩余的请求量得出当前可用请求量，请求量不能大于允许的最大请求量，如若当前请求消耗的请求量小于可用请求量，则该请求允许通行。这里的请求指的是同一个凭证的请求。

5.2.4 数据库事务提交与回滚策略实现

使用数据库事务来保证服务数据一致，而一个请求可能要经过多个函数，且有些又是共用函数。要在主函数中开启事务，在以下的函数调用中复用此事务会话，普通的过程性编码不能达到此要求。由于每个请求都有一个对应的上下文 `context.Context` 变量，在 `ctxs` 包中维护事务，函数之间调用入参都会传递上下文 `ctx`。因此，将事务会话变量放置在 `ctx` 中，开启与关闭逻辑放置在 `filter` 的 `TransactionFilter` 函数中。所有涉及写类型的请求都添加该过滤函数。`TransactionFilter` 中通过上下文对象判断本次请求成功与否，从而提交还是回滚事务。业务函数通过 `conn.GetDBClient(ctx)` 函数获取数据库操作对象，`GetDBClient` 中先检查 `ctx` 中是否有事务，有则返回这个事务对象。

5.2.5 分布式定时任务与分布式锁实现

由于主后台服务器是多台实例运行，每个定时任务运行的每个触发时刻只能是一台实例且仅运行一次。因此要有机制能避免多台实例运行了一个时刻的某一定时任务。使用 github.com/ivfzhou/cron/v3 代码库，触发定时逻辑的函数时会传递触发时间入参，因此函数中能知道本次运行的触发时间。在定时任务函数执行业务逻辑之前，运行 Redis `setnx` 命令以任务名和触发时间信息作为键名。若 Redis 中不存在这个键则 `setnx` 命令设置成功并返回 `true`，否则返回

false，以此判断是否有其他实例运行了这一时刻的定时任务。

若能运行定时任务，设置 Redis 键过期时间，以避免 Redis 空间溢出。对于每分钟运行一次的定时任务可以设置五分钟过期时间，因为各个实例之间的系统时间可能有偏差。可能存在 Redis 键过期了，但有实例还未曾触发这个时刻的定时任务。

5.2.6 服务退出资源释放策略实现

当服务要退出时，在完全停止运行前，应当处理完所有当前正在处理的任务，并之后关闭所有资源，此称为优雅退出。这是很有必要的，因为当一个逻辑运行一半就被系统杀死会导致服务的数据状态处于不确定状态，存在一定的风险。为了尽可能避免服务退出时导致的数据异常，本系统设计了优雅退出策略。通过 os/signal 包下函数，服务在启动后监听操作系统发送给服务进程的信号，当接收到退出信号时，便停止接受新的 HTTP 请求，停止运行新的定时任务，当存量逻辑任务都处理完毕后，释放 MySQL、Redis 和 RabbitMQ 连接。

服务退出期间拒绝新 HTTP 请求由 filter 包函数 ExitFilter 实现。在 main.go 中监听进程信号，然后向 ctx 发送信息通知 ExitFilter 函数拒绝服务。最后关闭释放资源。

5.2.7 HLKX 文件的 EV 签名实现

HLKX 包文件 EV 签名程序由 winevsigner 代码库实现。C#语言提供了一些类库方便调用 Windows 系统中的 EV 证书，完成对文件签名。首先创建 X509Store 类对象，通过入参的指纹比较区分出要使用的 EV 证书，类 X509Certificate2 代表这个 EV 证书，然后使用 PackageDigitalSignatureManager 类对象完成对 HLKX 文件的签名。

5.2.8 签名文件的上传与下载实现

文件可靠快速地上传是本系统服务质量的关键影响项。有些签名文件可能很大，几个 GB 大小，例如 Android 游戏应用。在大部分工况下，使用分片上传方案能显著地加快上传速度。主后台服务器提供三个接口：初始化分片上传、上传分片、结束上传。客户端上传文件时，首先计算文件的 MD5 散列值，将文件散列值信息、文件名和文件大小发送给后台的初始化分片接口。主后台服务器先根据文件信息检索数据库，判断当月的文件信息表中有没有相同信息的文件，若有则返回前台无需上传信息，后台已有该文件。否则随机生成唯一的

新文件 ID，以 Redis Hash 键将文件信息缓存到 Redis 中。前台并行调用上传分片接口，将文件分片以及分片序号发送给后台。后台将文件分片发给 Tusd 服务器，在 Redis 中以有序集合键记录分片信息。前台上传完分片后，请求结束上传，主后台服务器根据在 Redis 中记录的文件和分片信息请求 Tusd 服务器合并分片，最后在数据库表中保存文件信息。

上传文件可能中断，导致 Redis 和 Tusd 中存在垃圾数据。在定时任务中查询 Redis 获取正在上传的文件任务，将其中超过六个小时还没上传完的任务清理掉，删除 Tusd 中分片，删除 Redis 中的上传信息。

下载文件时，查询文件信息表获取到文件的 TusdID，根据该 ID 请求 Tusd 下载文件，同时响应客户端下载文件。

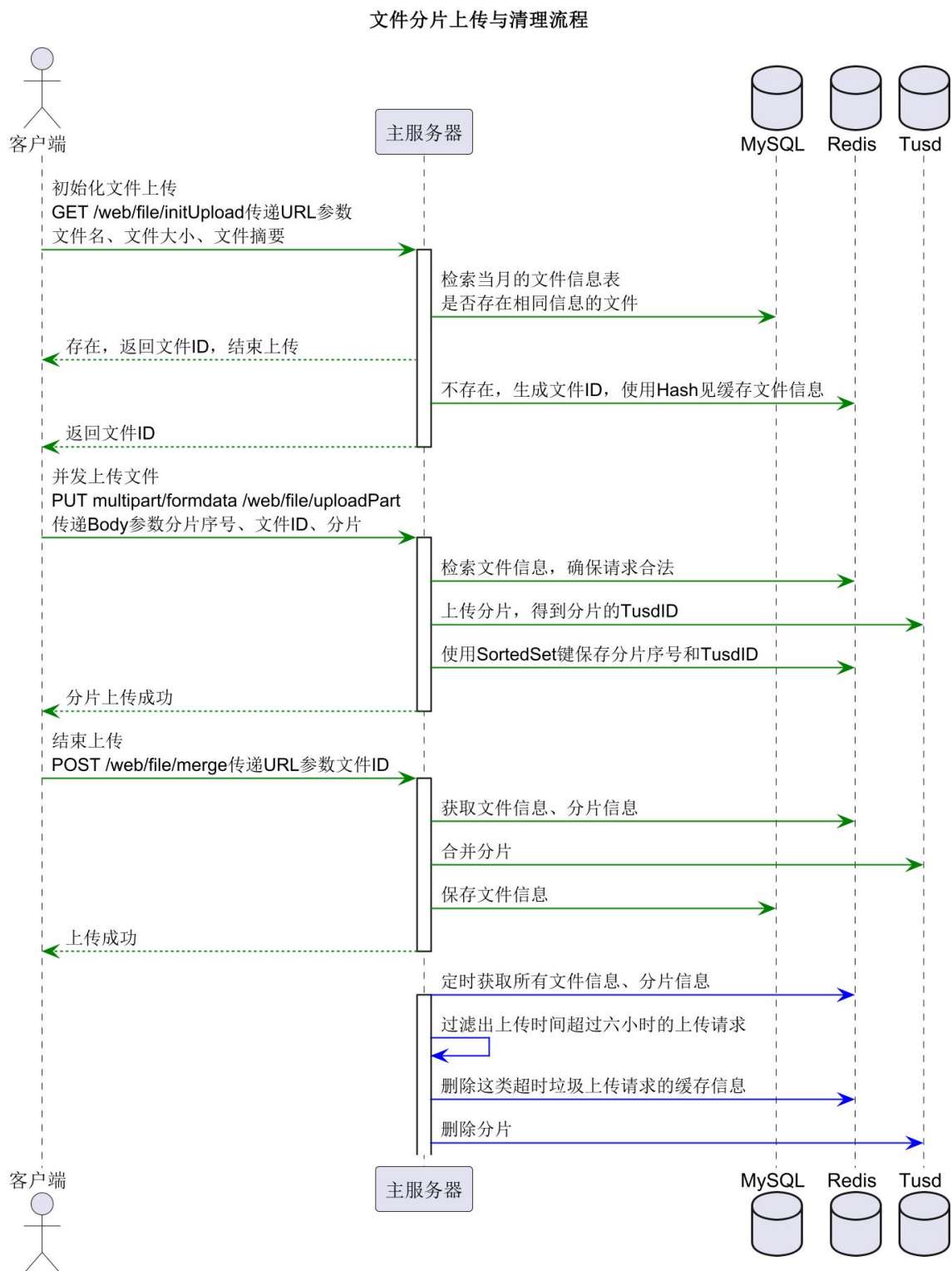


图 4-2 文件分片上传与清理流程图

5.3 系统功能实现

本节将阐述各功能的具体实现逻辑，展示实现效果页面。主要工作是对各

具体功能逻辑进行梳理并编码实现，用文字或时序图的形式详细介绍了算法过程。

由于绝大部分接口都需要校验请求方权限，校验请求参数。为了避免重复叙述，精简篇幅，不再一一说明。对于来自页面的请求，通过检索用户信息表、用户权限表和 Redis 会话信息，判断请求是否具有权限。对于来自 OpenAPI 的请求，则是检索凭证表和凭证信息表，解析 JWT 字符串判断请求是否具有权限。为了避免系统数据异常，尽可能保存系统稳定，请求参数先通过基本性校验后，再进行业务逻辑处理。主要校验维度有数据非空、长度范围和格式。

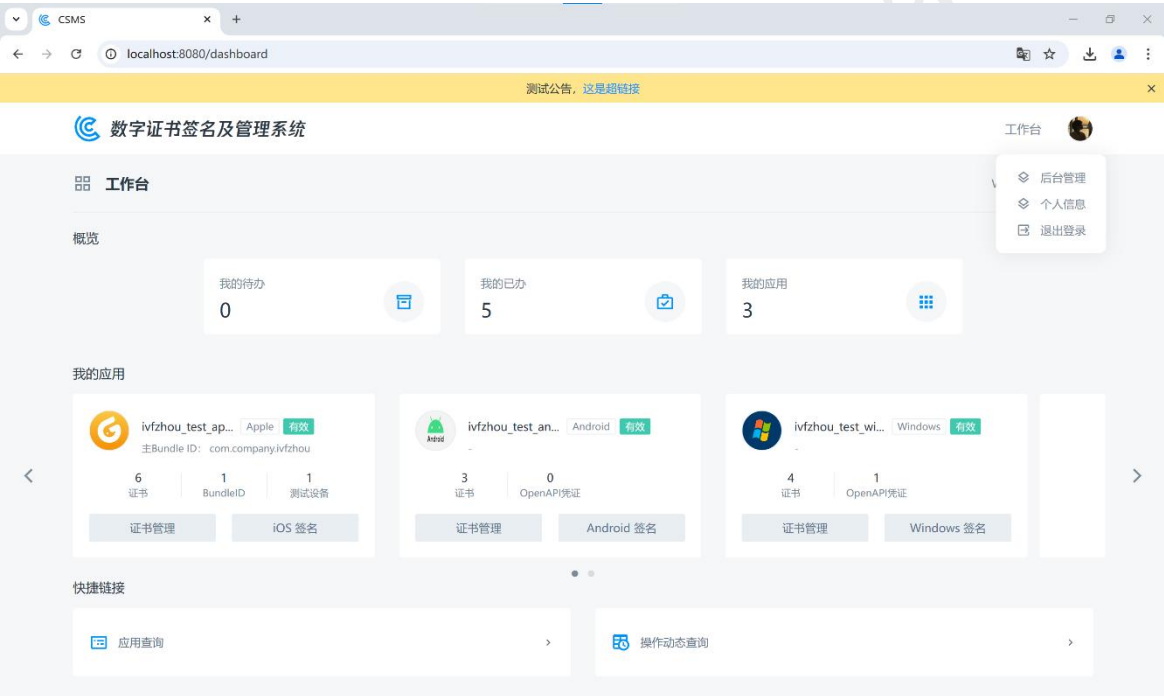


图 5-3 系统首页

5.3.1 用户管理功能实现

注册功能的逻辑流程。使用 `gin.ShouldBind` 方法将请求参数注入到 `protocol.UserRegisterReq` 结构体中。使用 `image.Decode` 函数解析头像文件格式，确保格式正确。调用 `conn.GetDBClient` 函数获取数据库操作对象，检索用户信息表，确保不存在同英文名用户。使用 `tus_client.Upload` 函数将头像文件上传到 Tusd，并将文件信息保存到文件信息表中。借用 `math/rand.Intn` 函数的随机性，生成随机字符串，同用户密码经过 `crypto/md5.Sum` 函数处理获取到密码散列值。最后将相关信息保存到用户信息表中。

登录功能的逻辑流程。根据英文名检索用户信息表获取到用户信息，将密码盐值同用户输入的密码计算 MD5 值，对比确保与用户信息表中的散列值相同。随机生成 128 位字符串作为会话密钥，调用 `conn.GetRedisClient` 函数获取 Redis 操作对象，以用户英文名作为键，会话密钥和请求 IP 作为值保存到 Redis 中，并设置 24 小时过期。最后 `gin.Context.SetCookie` 函数将英文名和会话密钥设置到浏览器 Cookie 中。

修改个人信息和密码功能的逻辑流程。将头像文件上传到 Tusd，数据库保存文件信息。计算出新密码散列值。最后更新用户信息表各项字段值。

登出功能的逻辑流程。把在 Redis 中维护的用户会话信息删除，同时设置删除浏览器 Cookie 相关会话数据。



图 5-4 用户注册页面

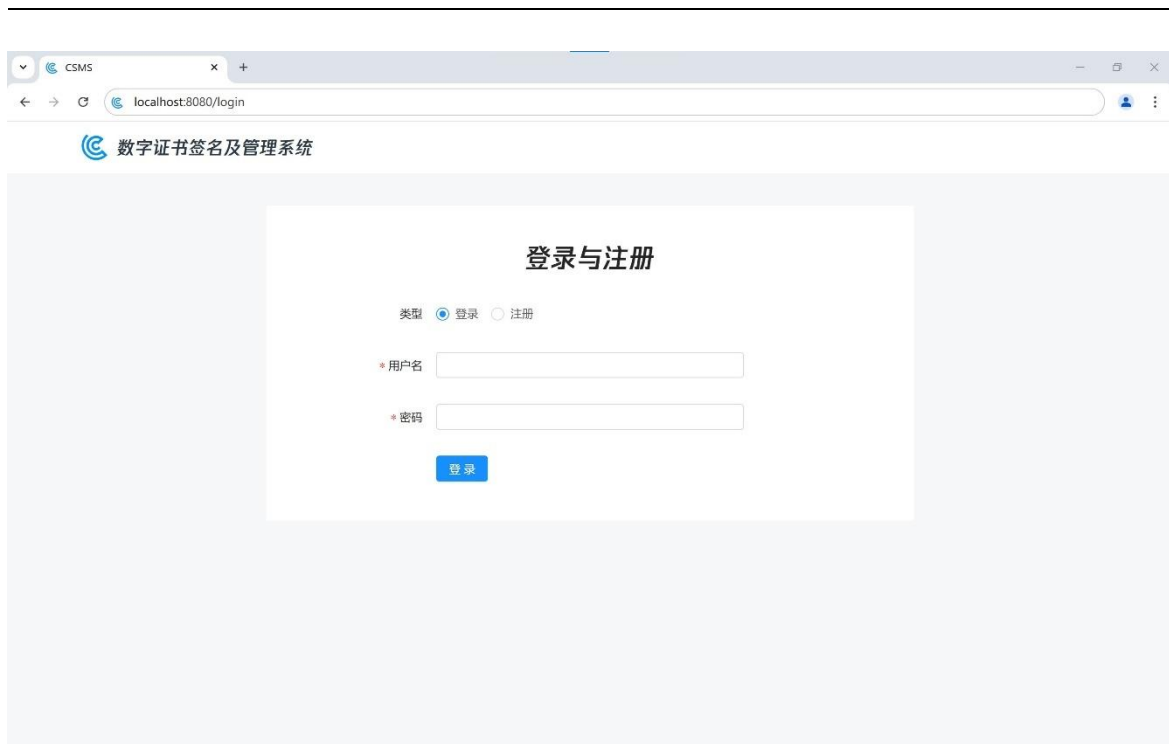


图 5-5 用户登录页面

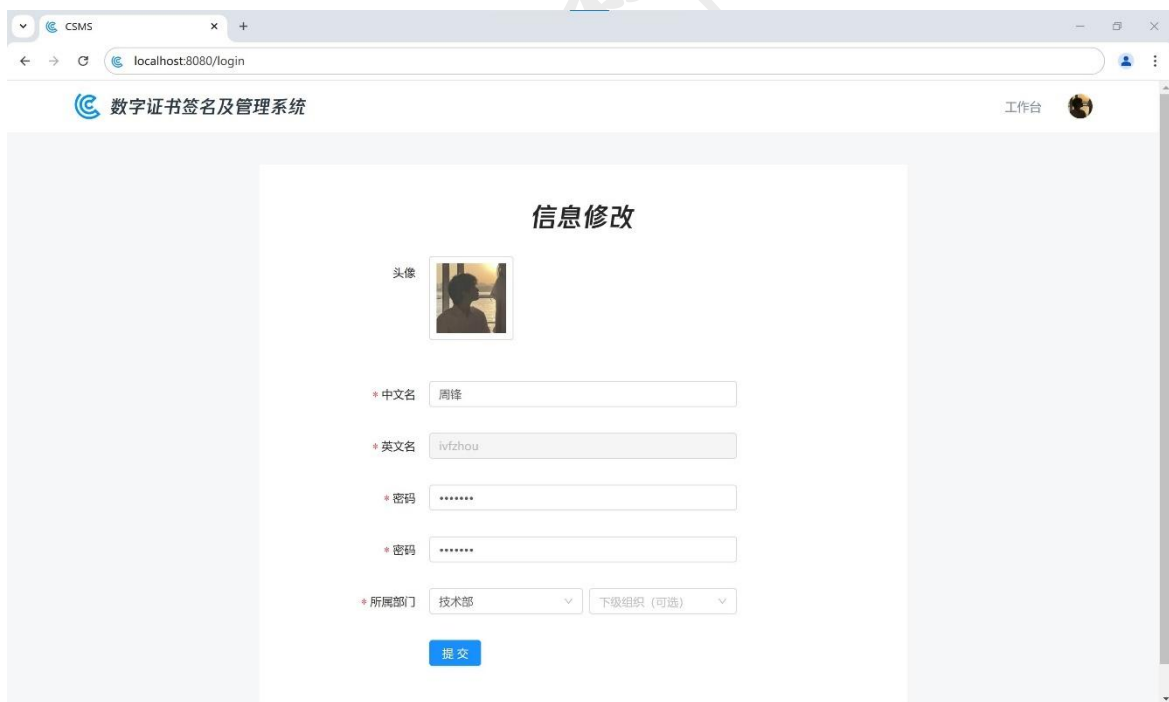


图 5-6 个人信息和密码修改页面

5.3.2 应用管理功能实现

注册应用功能的逻辑流程。解析请求参数中的应用图标文件，确保是合法

的 PNG 或 JPG 格式文件，然后将其上传到 Tusd，文件信息记录到文件信息表。检索用户信息表，确保请求参数中的应用人员都存在于系统。最后，添加应用信息表记录，添加用户权限表记录，添加应用事件表记录，生成给系统运营员审批的应用注册待办。

更新应用信息功能的逻辑流程。解析校验用户提交的应用图标文件，确保合法的 PNG、JPG 格式之一，然后上传到 Tusd，文件信息保存到文件信息表。删除用户权限表中关于应用的成员和管理员记录，然后又根据请求参数添加新的用户权限表记录。检索属于应用的且由应用管理员审批的还未处理的待办，更新其审批人字段。最后，更新应用信息表，添加应用事件表记录。

查看应用信息功能的逻辑流程。根据请求参数中的应用 ID，检索到应用信息表记录。再检索用户权限表，获取到应用人员。最后将数据返回给页面。

有效化应用功能的逻辑流程。根据请求参数中的应用 ID，检索应用信息表记录，确保应用存在，且状态是无效化。然后生成给系统运营员审批的待办，同时添加应用事件记录。

无效化应用功能的逻辑流程。根据请求参数中的应用 ID，将对应应用信息表记录，从有效化状态更新为无效化状态。然后添加应用事件记录。

CSMS

localhost:8080/application/add

数字证书签名及管理系统

工作台

应用注册

* 应用名

logo

+

上传图片

* 应用平台 ☐ Apple(iOS&MacOS) ☐ Android ☐ Windows

* 应用管理员

ivfzhou(周峰)

×

应用成员

提交

图 5-7 注册应用页面

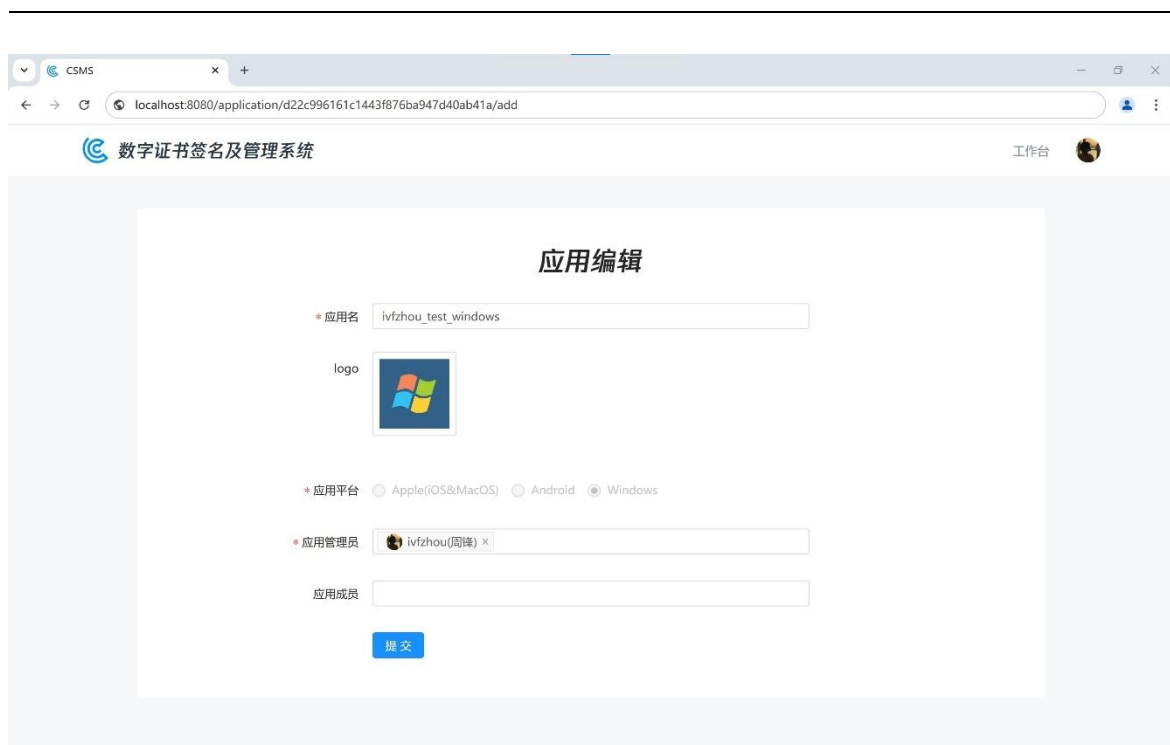


图 5-8 更新应用信息页面

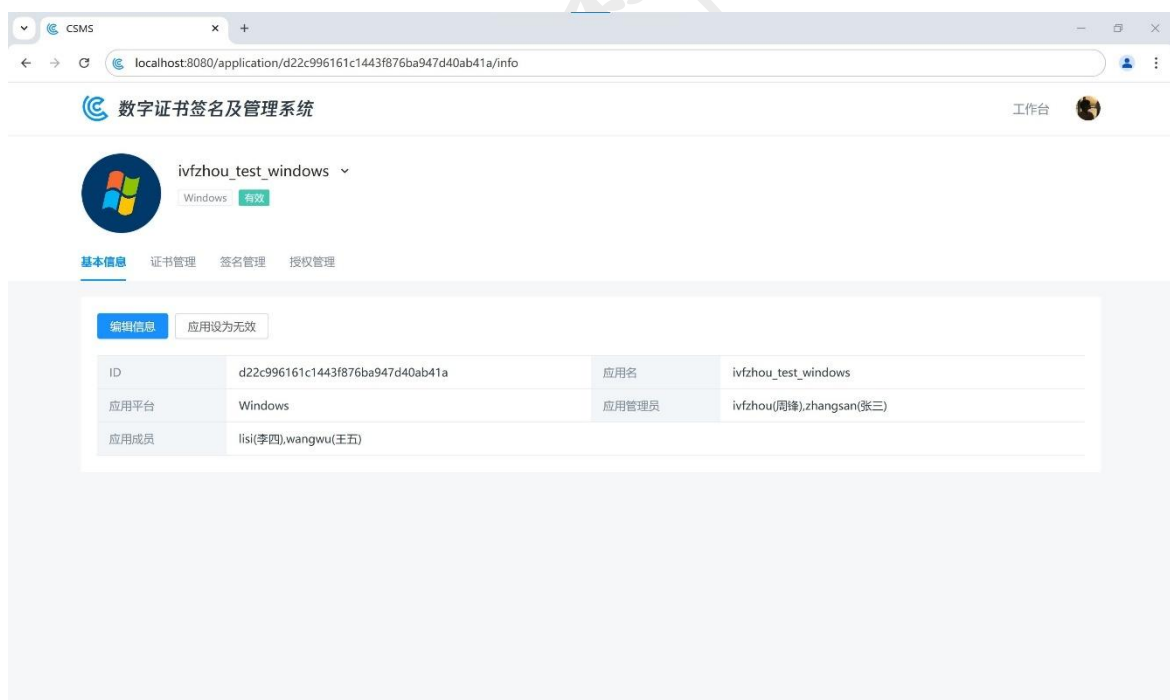


图 5-9 应用基本信息页面

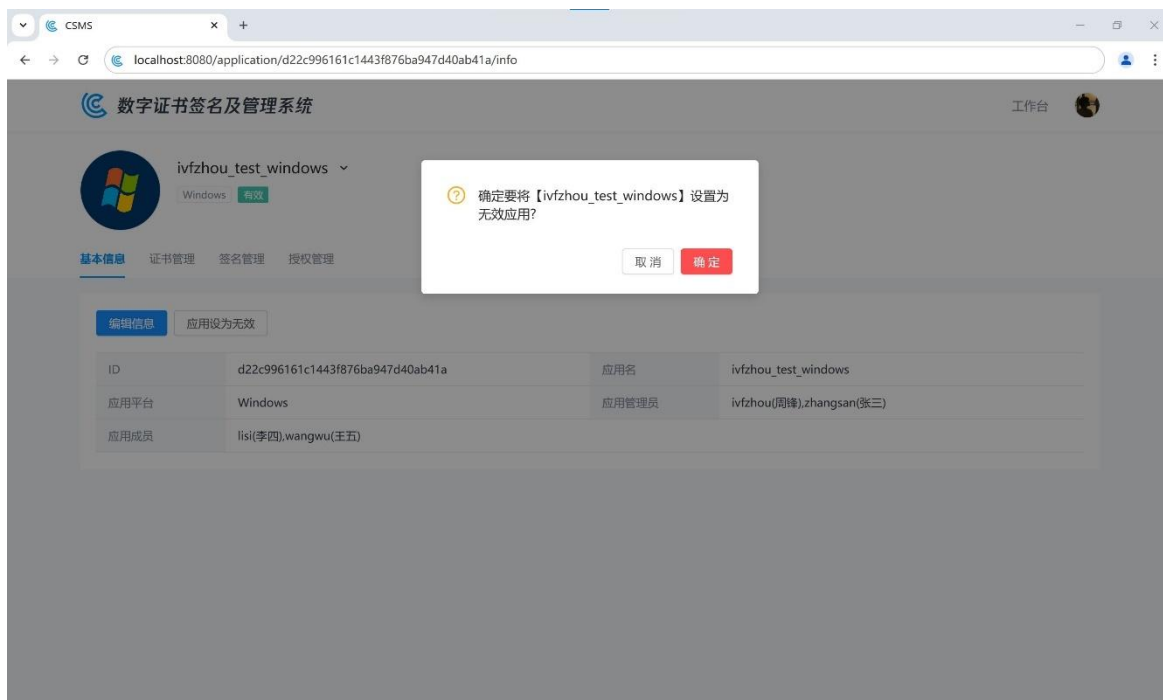


图 5-10 无效化应用页面

5.3.3 事件统计功能实现

应用事件列表功能的逻辑流程。先检索用户权限表，确认用户具有权限的应用。然后根据用户筛选条件组织 SQL 语句，按时间降序，查询应用事件表，将结果返回给页面展示。

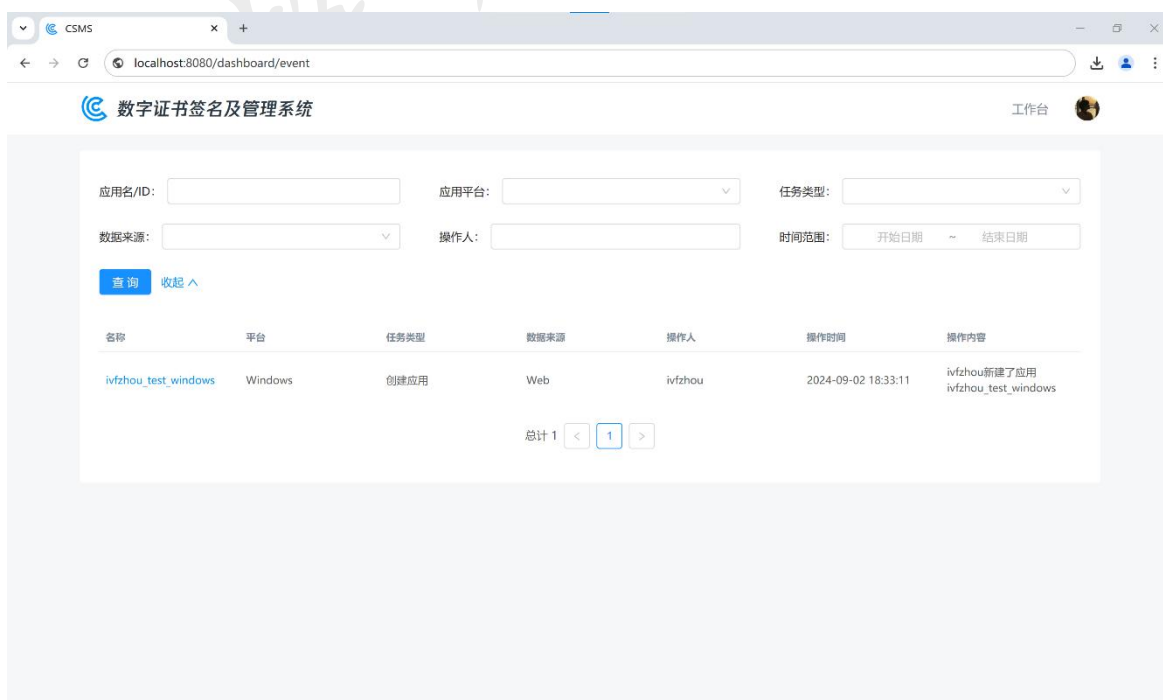


图 5-11 检索查看应用事件页面

5.3.4 待办管理功能实现

检索查看待办功能的逻辑流程。从待办表中，按用户筛选条件，时间降序方式，将用户提交和由用户审批的待办记录分页返回给页面展示。

审批用户注册应用的待办功能的逻辑流程。先根据请求参数中的待办 ID，检索到对应待办记录。确认待办状态处于审批中，用户是处理人之一。然后，待办记录字段 info 是应用 ID，检索应用表，确认应用状态需要审批。最后根据审批通过与否，更新应用表和待办表记录。

审批用户加入应用的待办功能的逻辑流程。同样的校验流程，但在审批通过后，添加用户权限表记录。

审批注册苹果测试设备的待办功能的逻辑流程。同样的校验流程，待办记录字段 info 是设备 ID。在审批通过后，请求苹果服务器注册设备，并更新设备表状态字段。

审批应用有效化的待办功能的逻辑流程。同样的校验流程，审批通过后，更新应用表状态为正常。

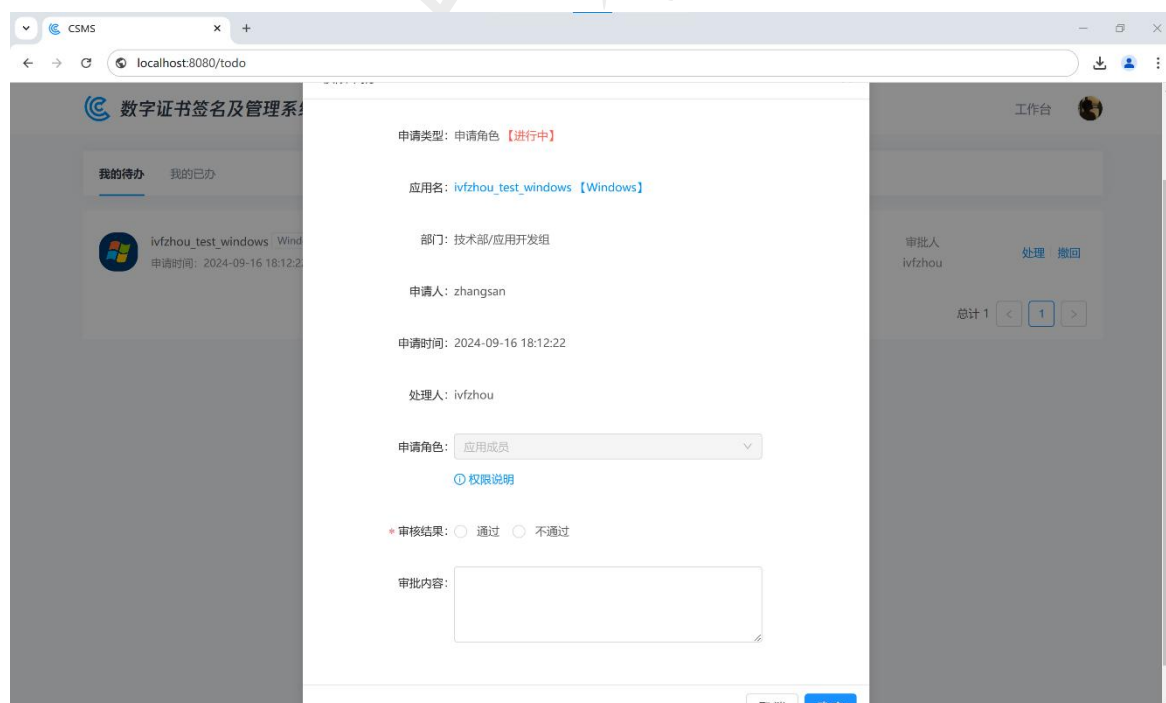


图 5-12 审批待办页面

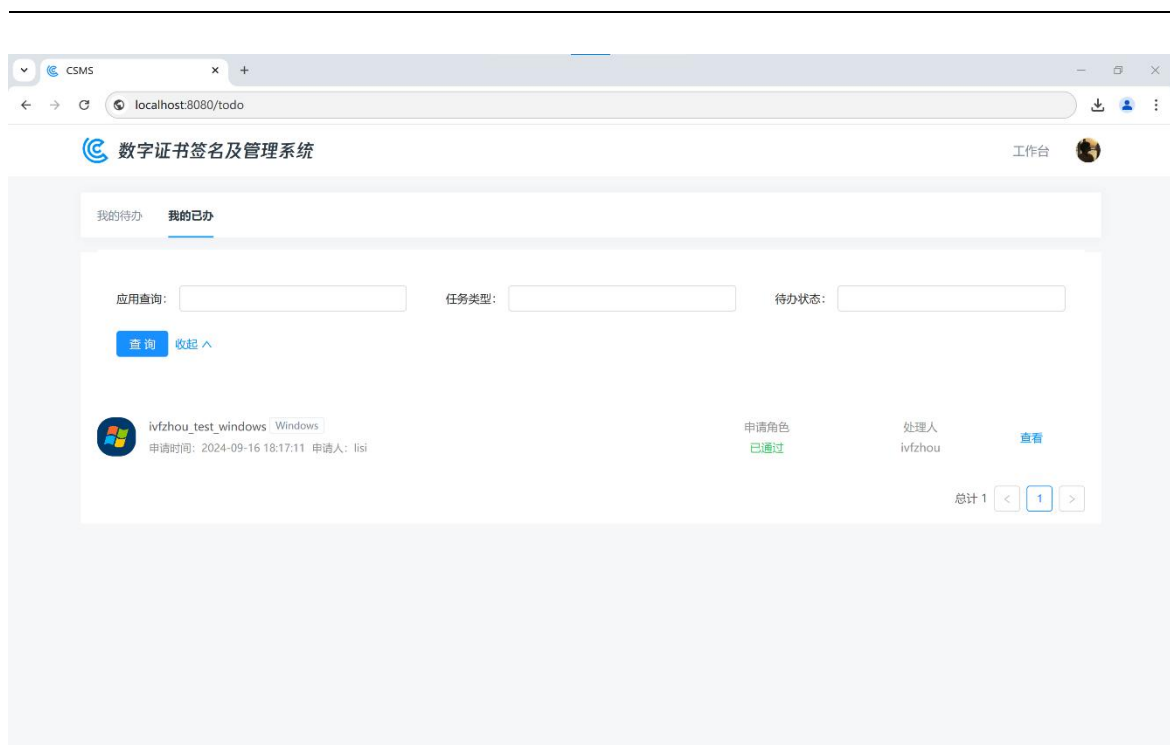


图 5-13 待办列表页面

5.3.5 证书管理功能实现

上传 Windows 个人 OV 证书功能的逻辑流程。调用 `encoding/base64.StdEncoding.Decode` 解码请求参数中的证书 Base64 字符串。之后使用请求参数中的密码，调用 `pkcs12.Decode` 函数解析证书，获取证书信息。在 `cfg` 包中获取到配置文件 `config.ini` 中的证书加密密钥，使用 `crypto/aes` 包下函数加密证书内容。最后添加 Windows 证书表和应用事件记录。

Windows 证书列表功能的逻辑流程。根据请求参数中的应用 ID，检索 Windows 证书表和 EV 证书授权表，获取所有属于应用的证书，以及公司证书。将证书信息返回给页面。

删除 Windows 个人证书功能的逻辑流程。根据请求参数中的应用 ID 和证书 ID，检索到 Windows 证书表记录。确保是个人类型证书。若是个人 OV 证书，则设置记录的 `deleted_time` 字段。若是个人 EV 证书，则删除 EV 授权表中对应的记录。最后添加应用事件表记录。

下载 Windows 个人 OV 证书功能的逻辑流程。根据请求参数中的应用 ID 和证书 ID，检索到 Windows 证书表记录。确保证书类型是个人 OV。然后使用密钥解密证书内容，将证书内容返回给页面，并添加应用事件记录。

查看个人证书密码功能的逻辑流程。用请求参数中的应用 ID 和证书 ID 作条件，查询到 Windows 证书表记录。判断记录属于个人类型，若是个人 EV 类型，则检索 EV 证书授权表，确保有对应用的授权。最后将证书密码返回给页面。

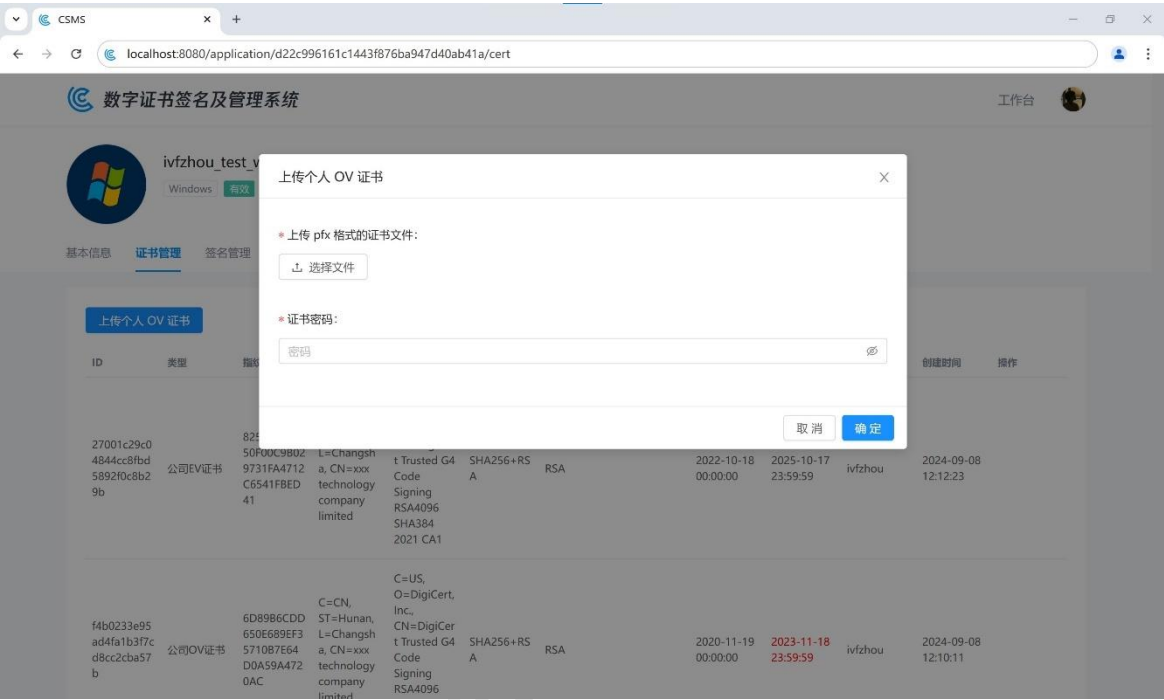


图 5-14 上传 Windows 个人 OV 证书页面

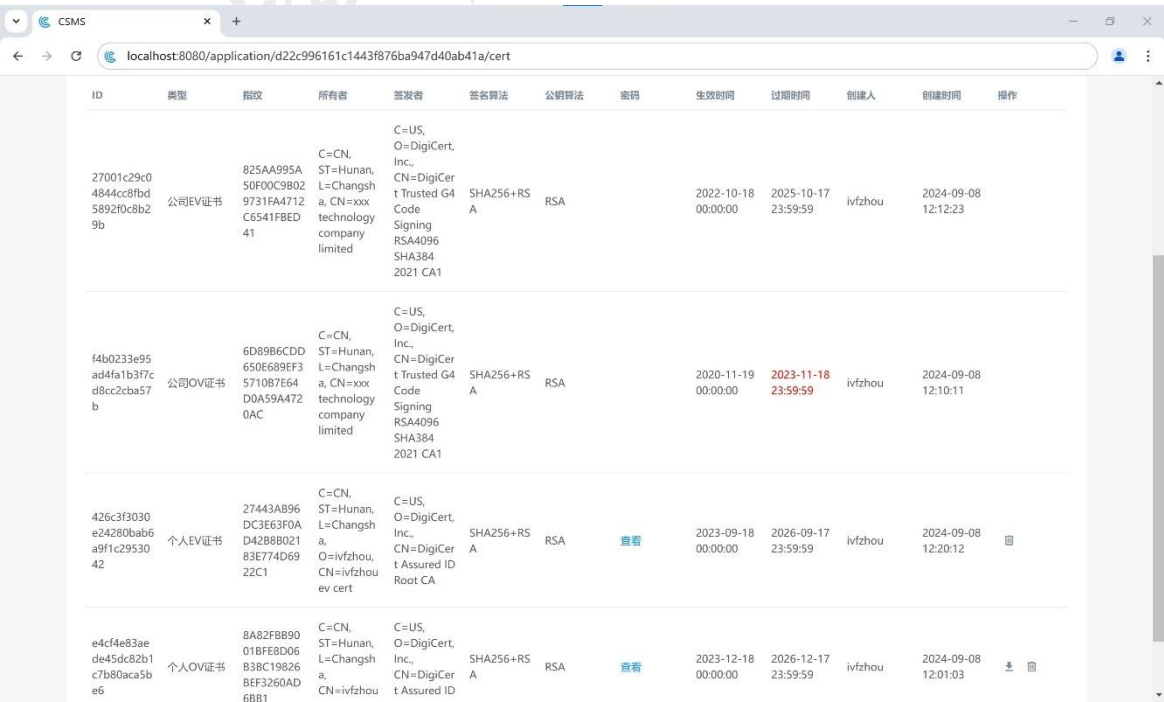


图 5-15 Windows 证书列表页面

获取 Google Play 上传证书功能的逻辑流程。使用请求参数中的应用 ID 和证书 ID，查安卓证书表获取证书数据。确保证书是发布类型。使用配置中密钥解密证书内容，再调用 `os/exec.Command` 函数执行 `keytool` 命令，将密钥库中的证书部分导出。将该导出数据返回给页面，并记录应用事件表记录。

获取 Google Play 部署证书功能的逻辑流程。先用请求参数中的应用 ID 和证书 ID，从安卓证书表中获取到发布类型的证书数据。解密证书内容，会同请求参数中的加密公钥，`java` 运行 `pepk.jar`。最后将命令输出文件返回给页面，记录应用事件表记录。

获取 Google Play 升级签名密钥功能的逻辑流程。根据应用 ID 和新旧证书 ID，获取到两份安卓证书表记录。解密证书内容。同样，会同请求参数中的加密公钥，运行 `java pepk.jar`。最后将命令输出数据返回页面，并添加应用事件记录。

上传 JKS 证书功能的逻辑流程。先将证书内容 Base64 解码，根据请求参数的 `Storepass`、`Keypass`，运行 `keytool` 命令输出密钥库信息。将命令输出字符串按行分隔，再逐行检索匹配的方式获取证书信息。然后加密证书，添加安卓证书表记录、应用事件记录。

申请安卓证书功能的逻辑流程。先查安卓证书主体表，确保请求参数中的主体合法。然后随机生成证书的 `Storepass`、`Keypass`，运行 `keytool` 生成证书和获取证书信息。最后加密证书，添加安卓证书表记录、应用事件记录。

安卓证书列表功能的逻辑流程。根据请求参数中的应用 ID，从安卓证书表中获取所有属于该应用的证书信息，返回给页面展示。

下载安卓证书功能的逻辑流程。根据应用 ID 和证书 ID，从安卓证书表中检索到记录。解密证书内容，返回给页面下载。

删除安卓证书功能的逻辑流程。用应用 ID 和证书 ID 作条件，更新安卓证书表记录的 `deleted_time` 字段。若有 SQL 语句返回有受影响的行数，则添加应用事件表记录。

获取安卓证书 Facebook 密钥散列功能的逻辑流程。先根据应用 ID 和证书 ID 获取到安卓证书表记录。解密证书内容，运行 `keytool` 命令将密钥库中的证书部分以 PKCS#12 格式导出。再对导出数据执行 `crypto/sha1.Sum` 处理，得到

的字节数据 Base64 编码。最后将编码结果返回给页面，并添加应用事件记录。

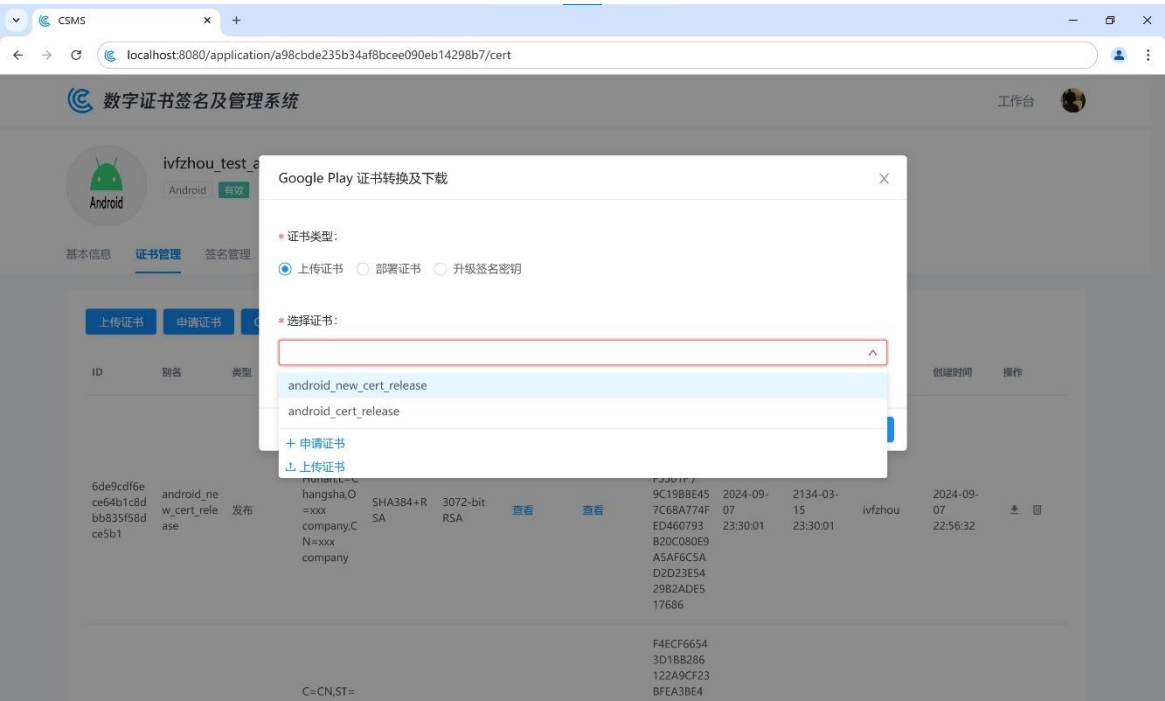


图 5-16 获取 Google Play 上传证书页面

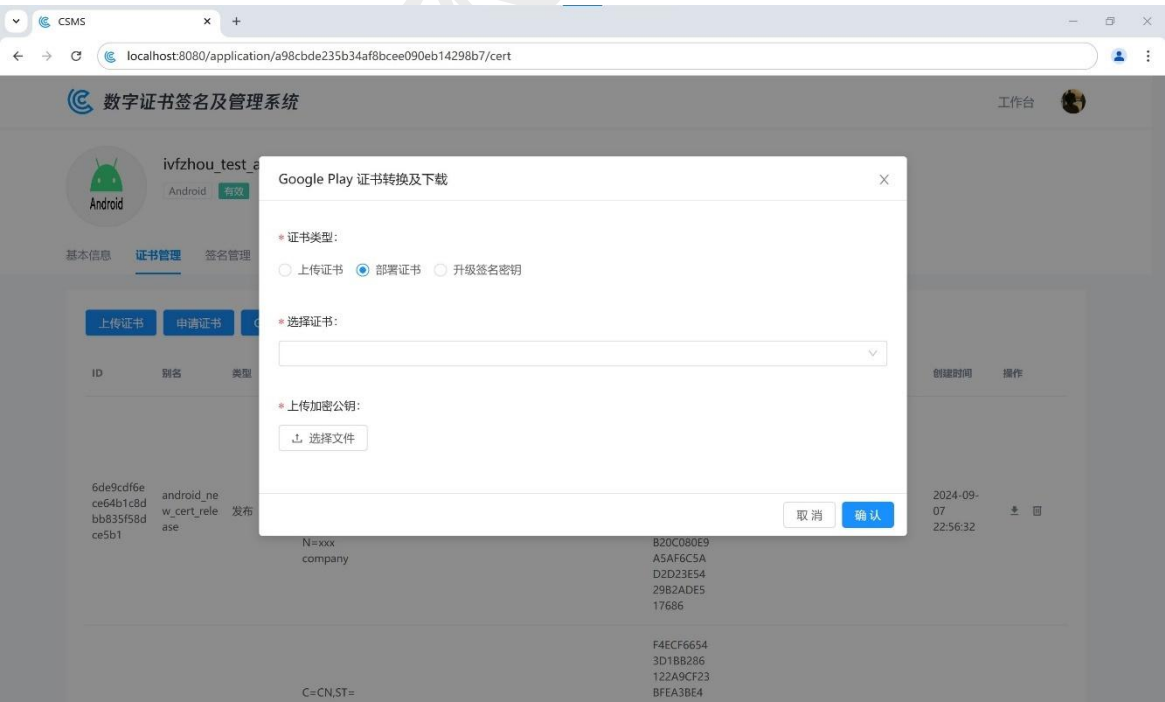


图 5-17 获取 Google Play 部署证书页面

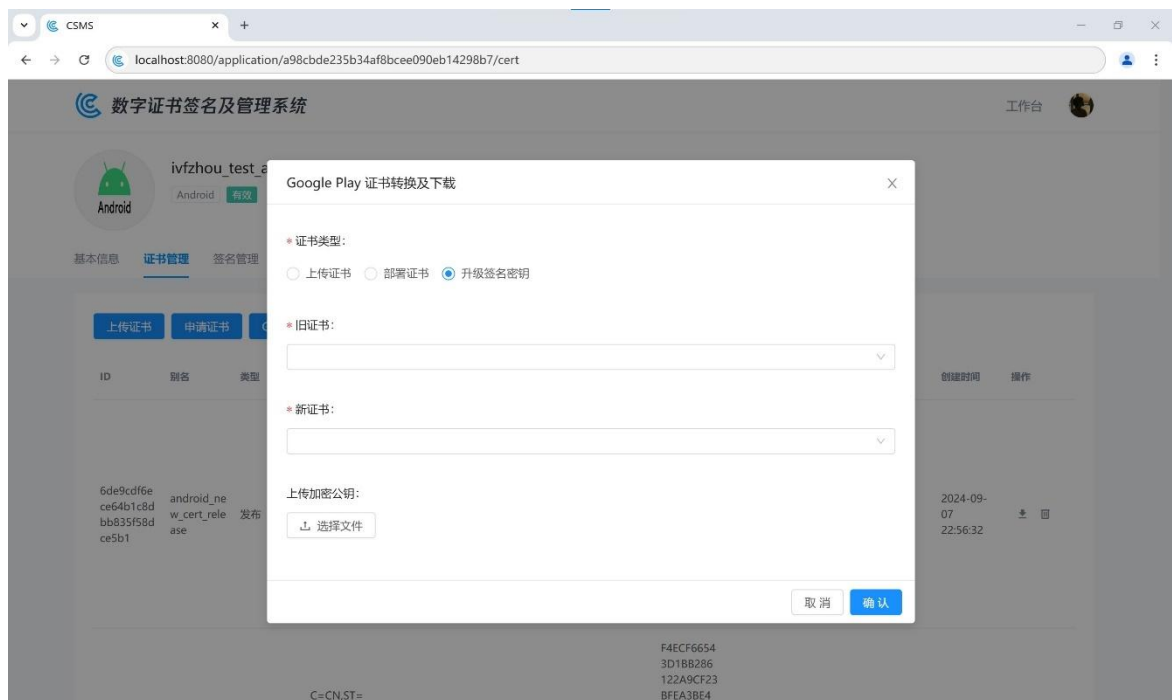


图 5-18 获取 Google Play 升级签名密钥页面

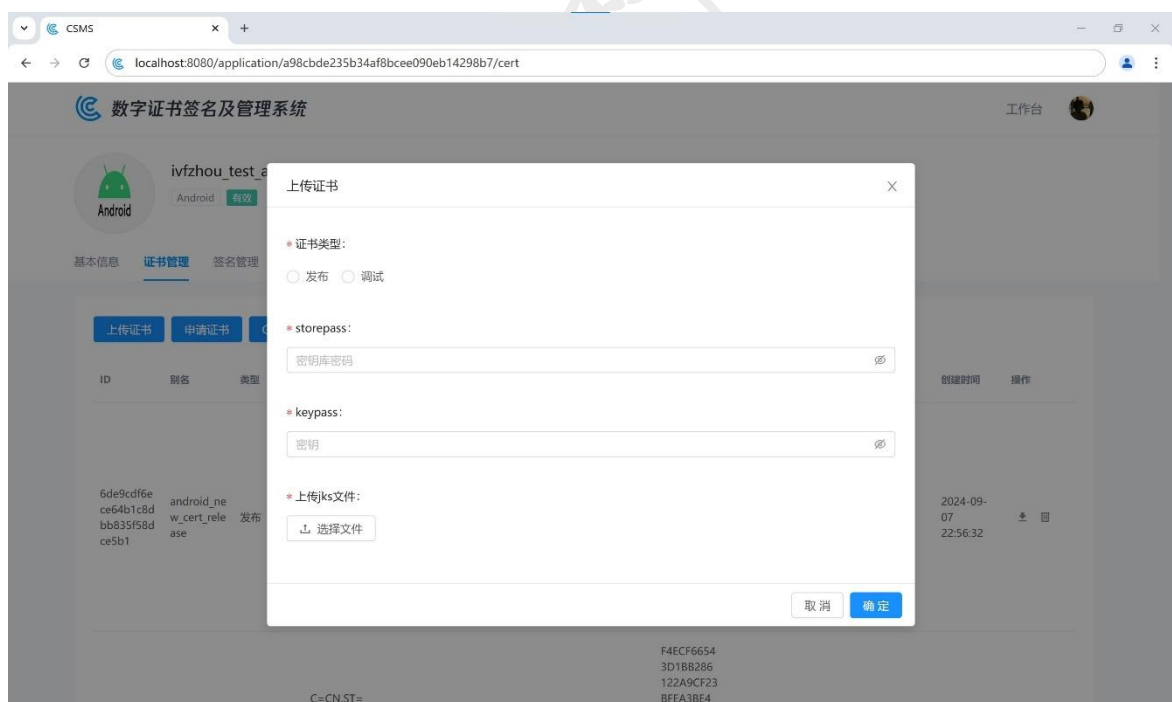


图 5-19 上传 JKS 证书页面

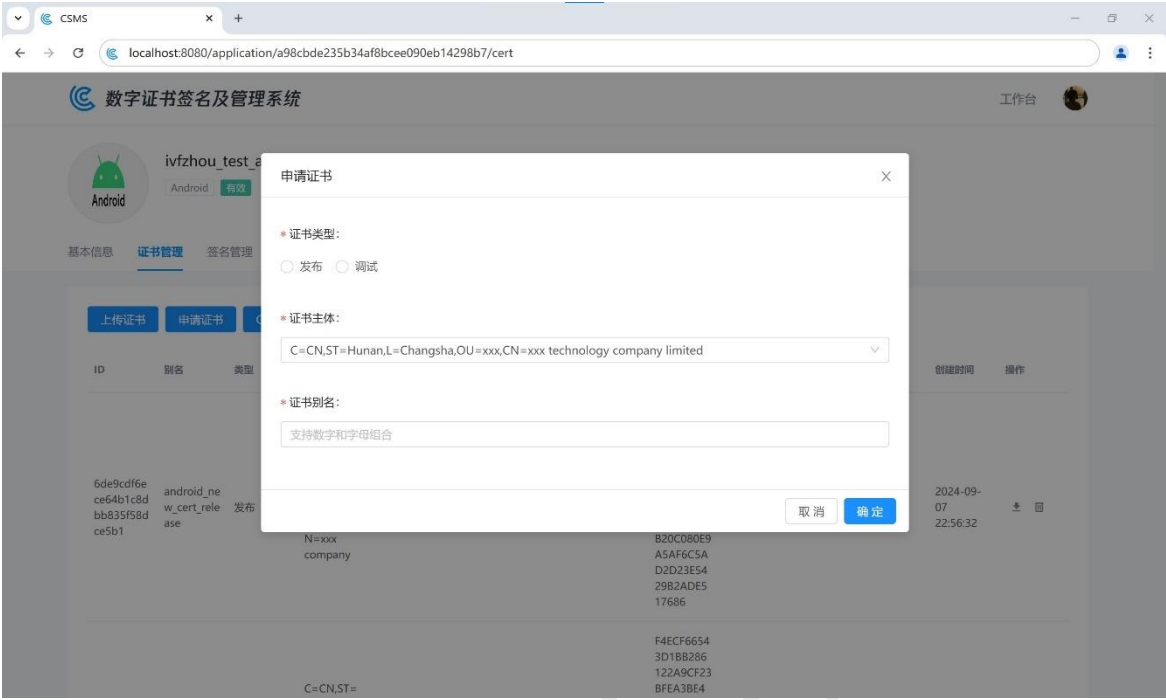


图 5-20 申请安卓证书页面

ID	别名	类型	所有者	签名算法	公钥算法	Storepass	Keypass	SHA1/SHA256	生效时间	过期时间	申请人	创建时间	操作
6de9cdf6ce64b1c8dbb835f58dce5b1	android_new_cert_release	发布	C=CN,ST=Hunan,L=Changsha,OU=xxx company,CN=xxx company	SHA384+RSA	3072-bit RSA			3CAFE25B2613BCDD3F798A2C9CAB8B35DF5501F / 9C198BE457C68A774FED460793B20C080E9A5AF6C5AD2D23E5429B2ADE517686	2024-09-07 23:30:01	2134-03-15 23:30:01	ivfzhou	2024-09-07 22:56:32	回
27f8733e9d64420c962a8fe280157344	android_certificate_release	发布	C=CN,ST=Hunan,L=Changsha,OU=xxx company,CN=xxx company	SHA384+RSA	3072-bit RSA			F4ECF66543D1B8286122A9CF23BFEA3BE4C9FFB9 / 86094EF7390634D565A3931829BF7CD68CF50A466ADA61B4B1F4C9F8E17CD7D7	2024-09-07 23:30:01	2134-03-15 23:30:01	ivfzhou	2024-09-07 22:45:12	回
27f8733e9d64420c962a8fe2801	android_certificate	调试	C=CN,ST=Hunan,L=Changsha,OU=xxx company,CN=xxx company	SHA384+RSA	3072-bit RSA			BB2EA9C26C9EF3CC799F1A69C962107C98599D03 / 76A833CCA982F4E17ACEA7302E	2024-09-07 23:30:01	2134-03-15 23:30:01	ivfzhou	2024-09-07 23:40:00	查看 回

图 5-21 安卓证书列表页面

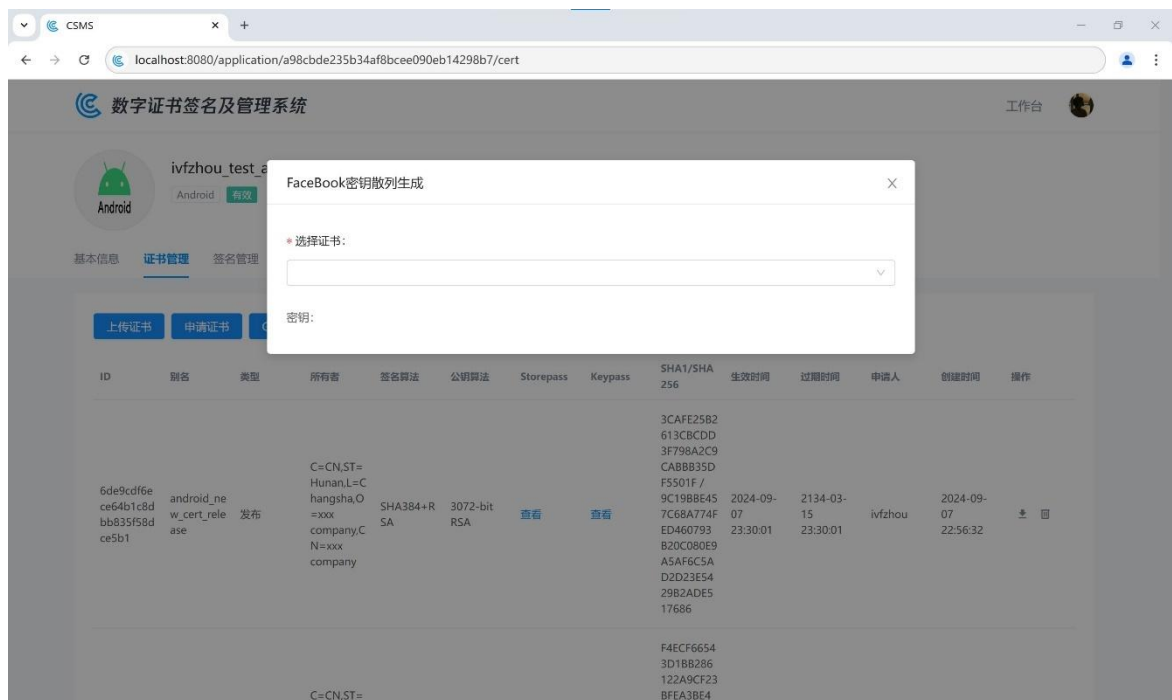


图 5-22 获取证书 Facebook 密钥散列页面

申请 BundleID 功能的逻辑流程。先检查 BundleID 信息表，确保用户提交的 BundleID 没有被注册。根据请求参数的环境类型不同，执行不同的申请逻辑。若环境类型是 AppStore，则从配置文件中获取到 Apple API 的 IssuerID、KeyID 和 PKCS#8 密钥，使用 `jwt.NewWithClaims`、`x509.ParsePKCS8PrivateKey` 等函数生成 JWT 字符串，请求苹果服务器申请 BundleID。若环境类型是企业内测，则向 Fastlane 服务器发送请求，运行 `fastlane` 命令申请 BundleID。最后添加 BundleID 表、应用事件表记录。

删除 BundleID 功能的逻辑流程。先根据应用 ID 和 BundleID 检索 BundleID 信息表，确保记录存在。然后根据不同环境类型分别请求苹果服务器，或者运行 `fastlane` 命令删除 BundleID。最后删除 BundleID 信息表对应记录，添加应用事件表记录。

增减 BundleID 能力功能的逻辑流程。根据应用 ID、BundleID 检索出 BundleID 记录，确保记录存在。然后根据不同环境类型分别请求苹果服务器或者运行 `fastlane` 命令修改能力项。最后更新记录的能力项字段，添加应用事件表记录。

获取 BundleID 列表功能的逻辑流程。从 BundleID 表中检索出属于应用的

所有记录，返回给页面展示。

获取证书/描述文件列表功能的逻辑流程。从苹果证书表中检索出所有属于应用的推送证书，公共签名证书。再从描述文件表中检索出所有属于应用的描述文件。将他们返回给页面展示。

申请描述文件功能的逻辑流程。查询 **BundleID** 表确定用户选择的 **BundleID** 存在。若是企业内测环境的 **BundleID**，则运行 **fastlane** 申请描述文件。否则，根据描述文件类型，获取到对应苹果证书表记录。若是调试类型的描述文件，还检索属于应用的测试设备表记录。整合数据，请求苹果服务器申请描述文件。最后添加描述文件表、应用事件表记录。

申请 **Push** 证书功能的逻辑流程。先检索 **BundleID** 表确保记录存在，属于应用。然后运行 **fastlane** 命令申请 **Push** 证书，加密证书内容。最后保存到苹果证书表中，添加应用事件记录。

删除 **Push** 证书/描述文件功能的逻辑流程。先检索苹果证书表、**BundleID** 表，确保记录存在，属于应用。然后请求苹果服务器进行删除。最后更新设置表的 **deleted_time** 字段，和添加应用事件。

下载证书/描述文件功能的逻辑流程。先检索相关表，确保记录存在，属于应用。证书内容需解密，将证书和描述文件返回页面下载。

注册测试设备功能的逻辑流程。根据设备 **UDID** 先检索设备表，确保设备没有被注册。然后生成给系统运营员审批的待办，并添加事件记录。

测试设备列表功能的逻辑流程。检索设备表，将属于应用的设备分页返回给页面展示。

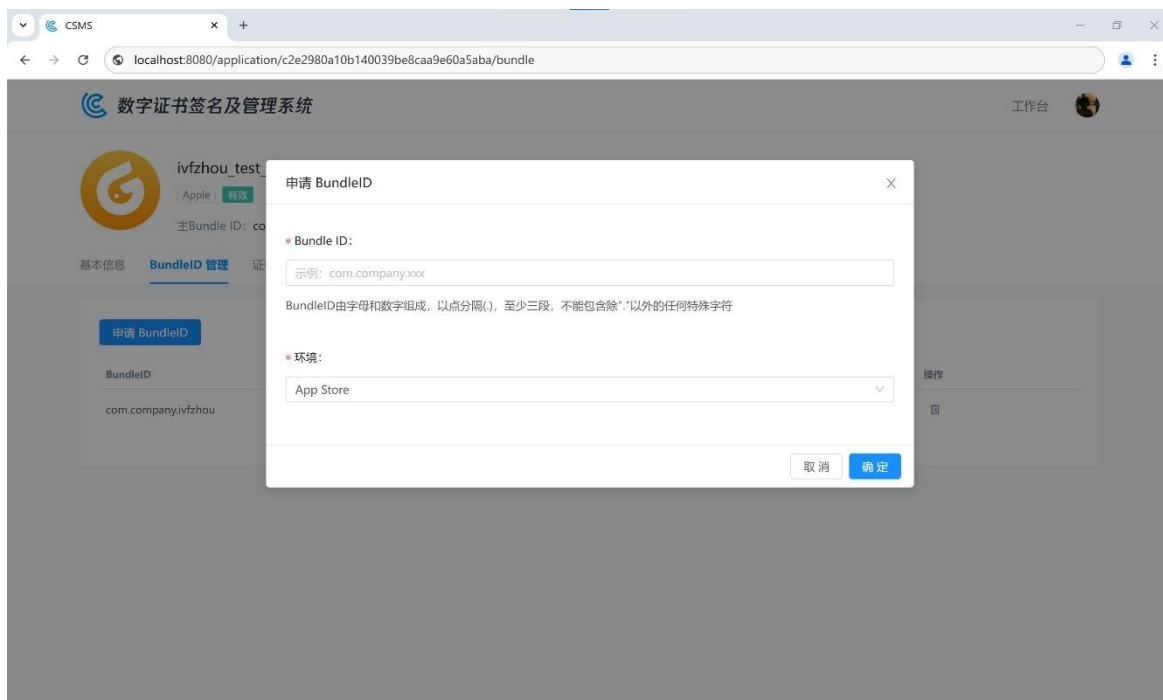


图 5-23 申请 BundleID 页面

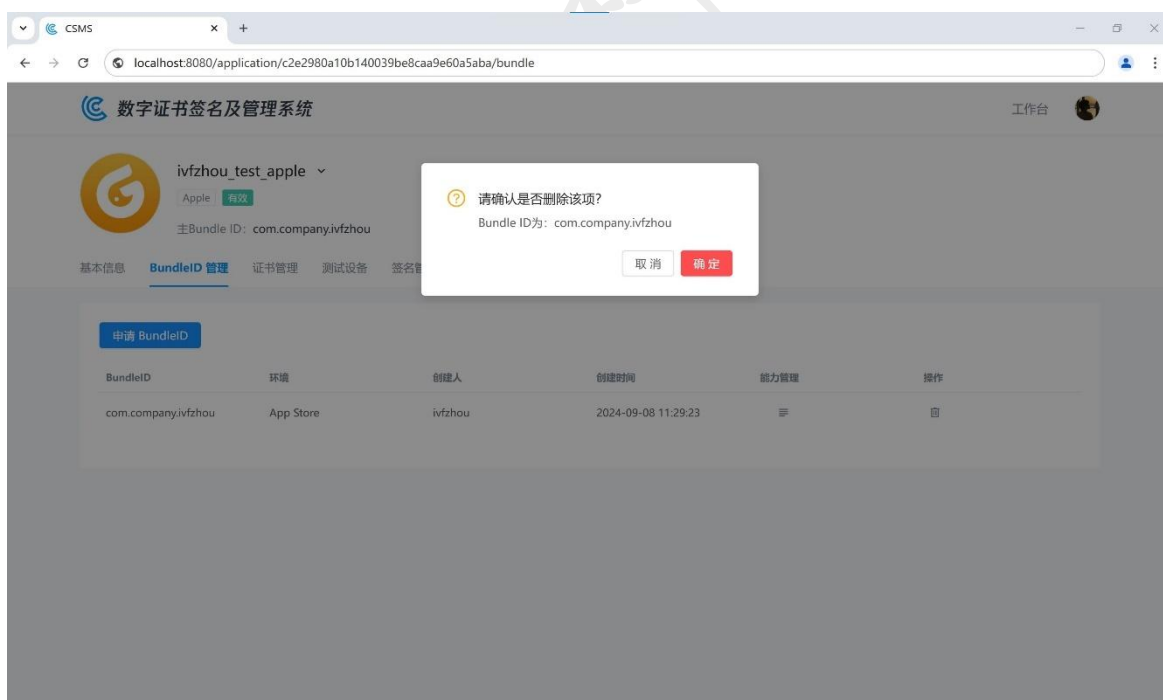


图 5-24 删除 BundleID 页面

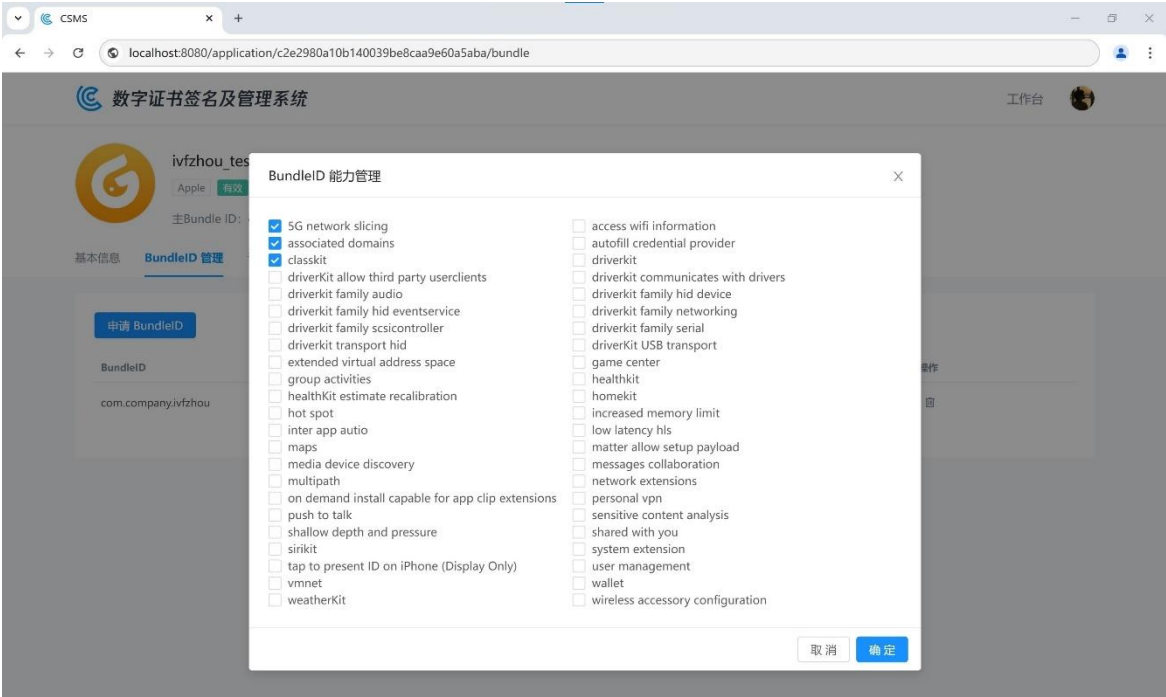


图 5-25 增减 BundleID 能力页面

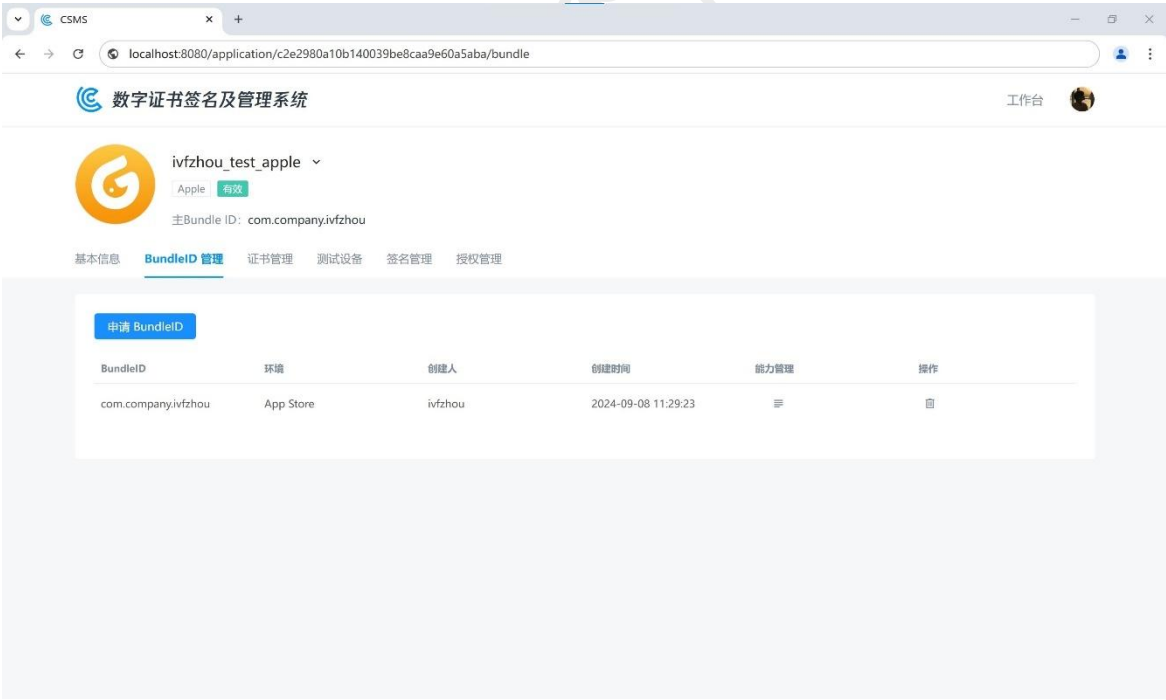


图 5-26 BundleID 列表页面

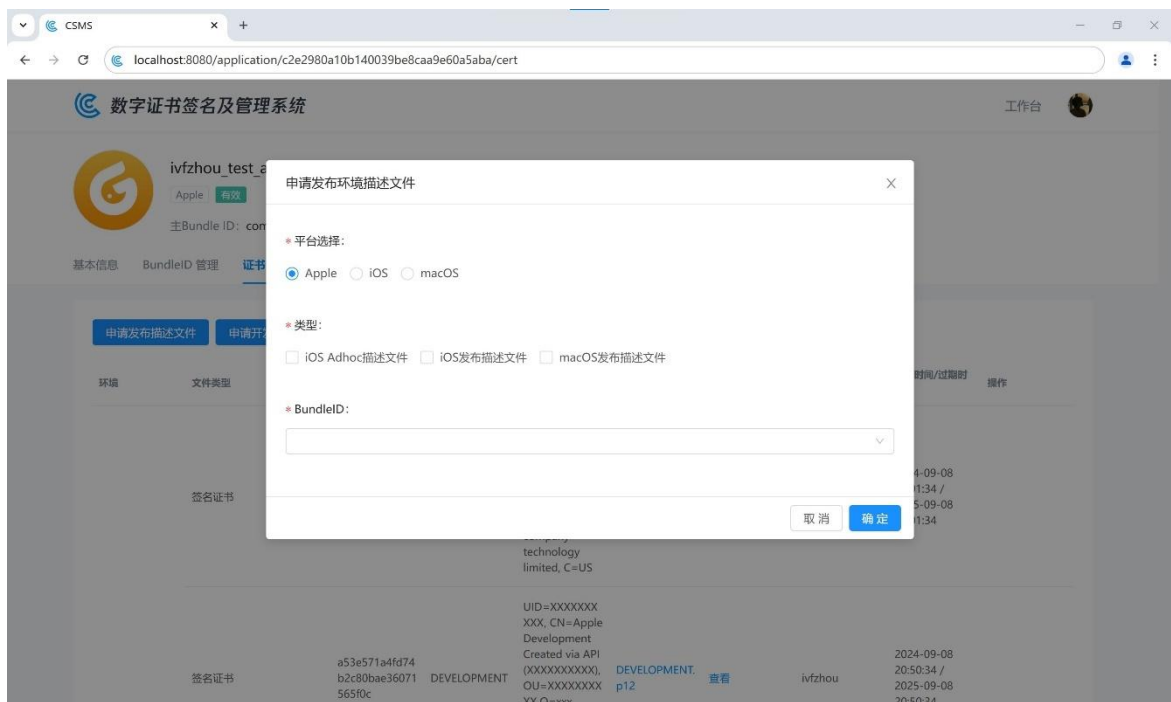


图 5-27 申请描述文件页面

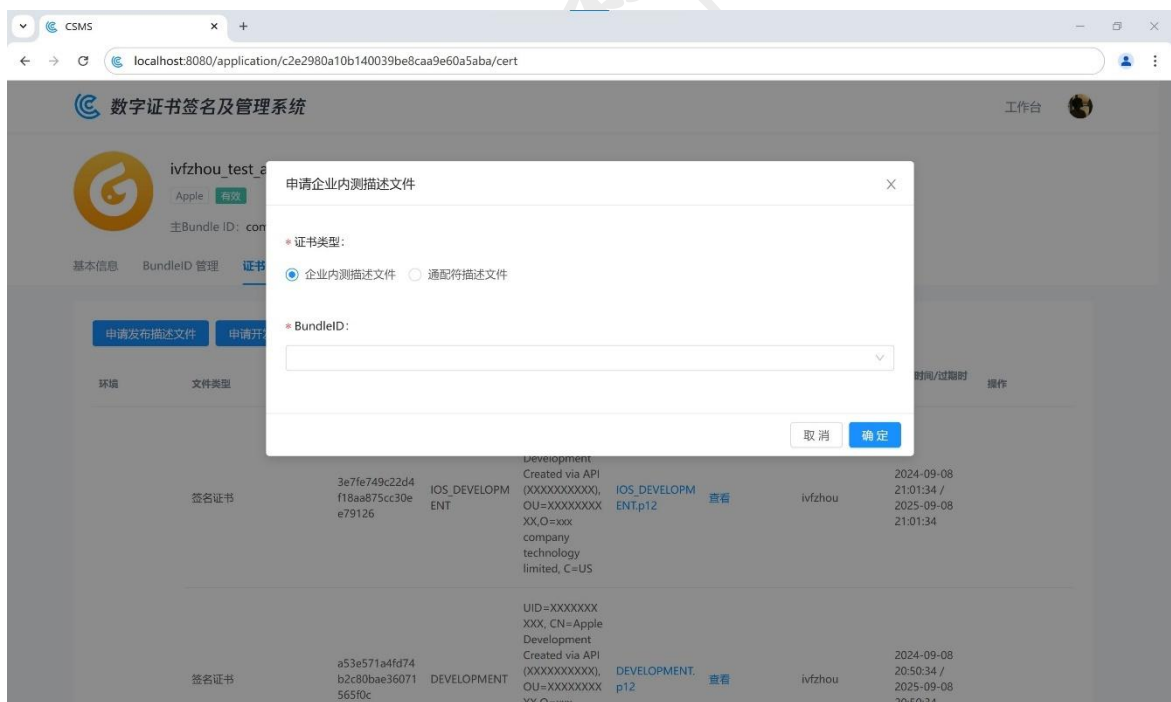


图 5-28 申请企业内测描述文件页面

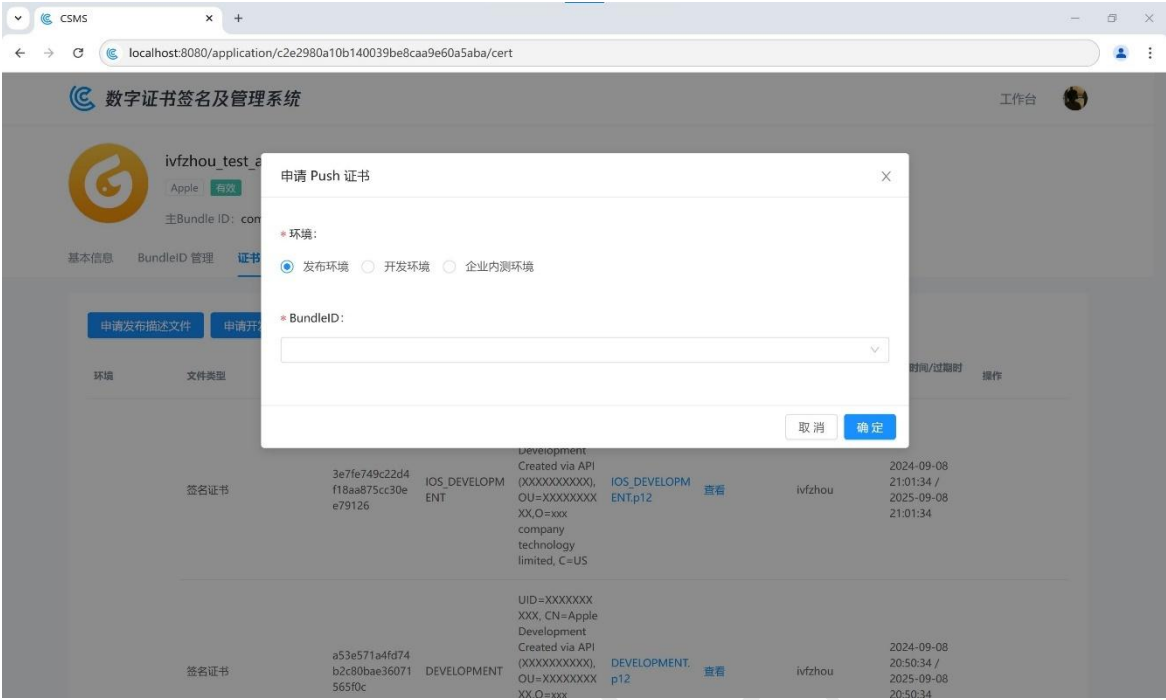


图 5-29 申请 Push 证书页面

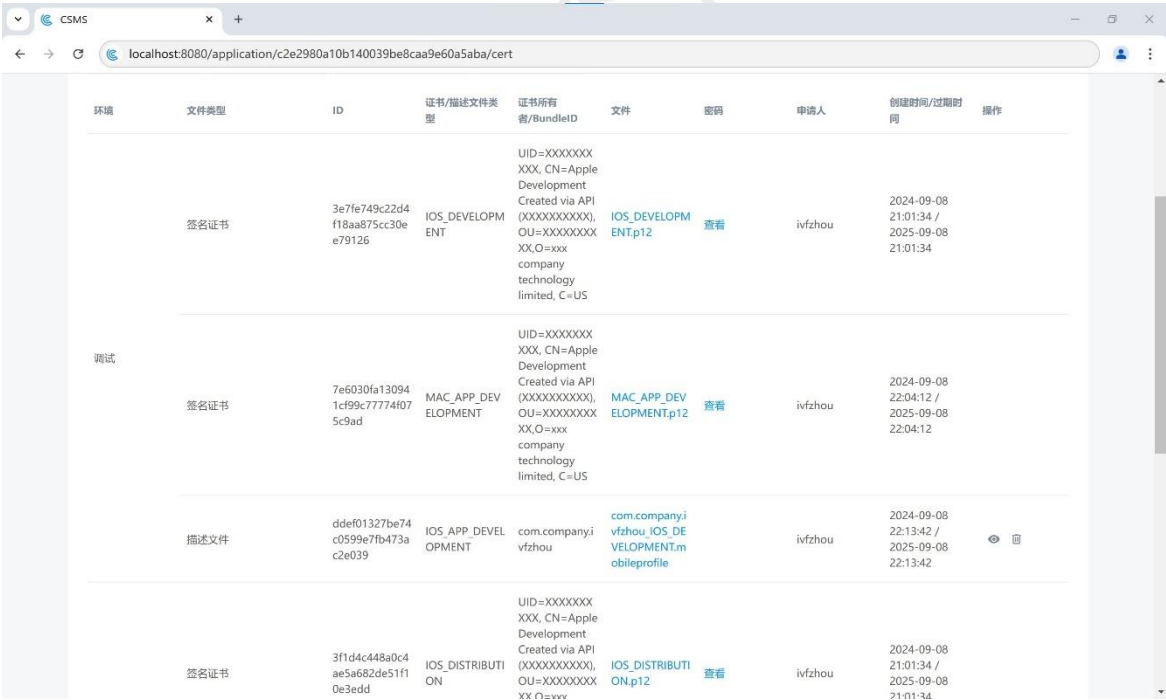


图 5-30 Apple 证书和描述文件列表页面

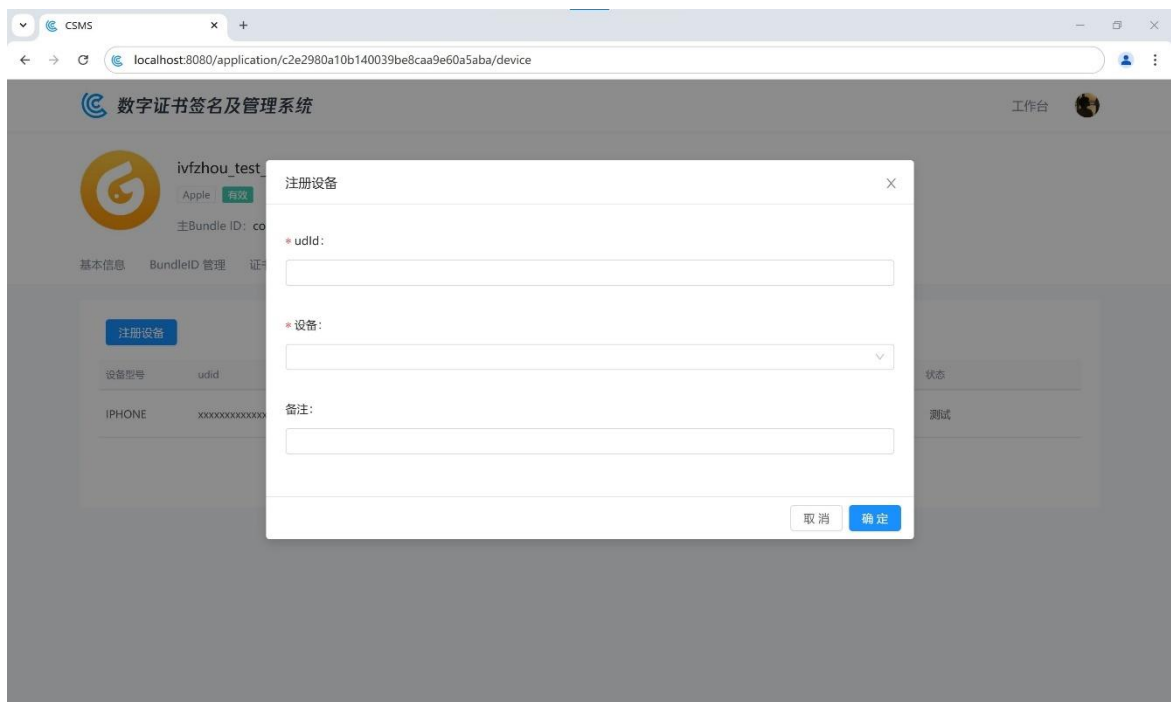


图 5-31 注册测试设备页面

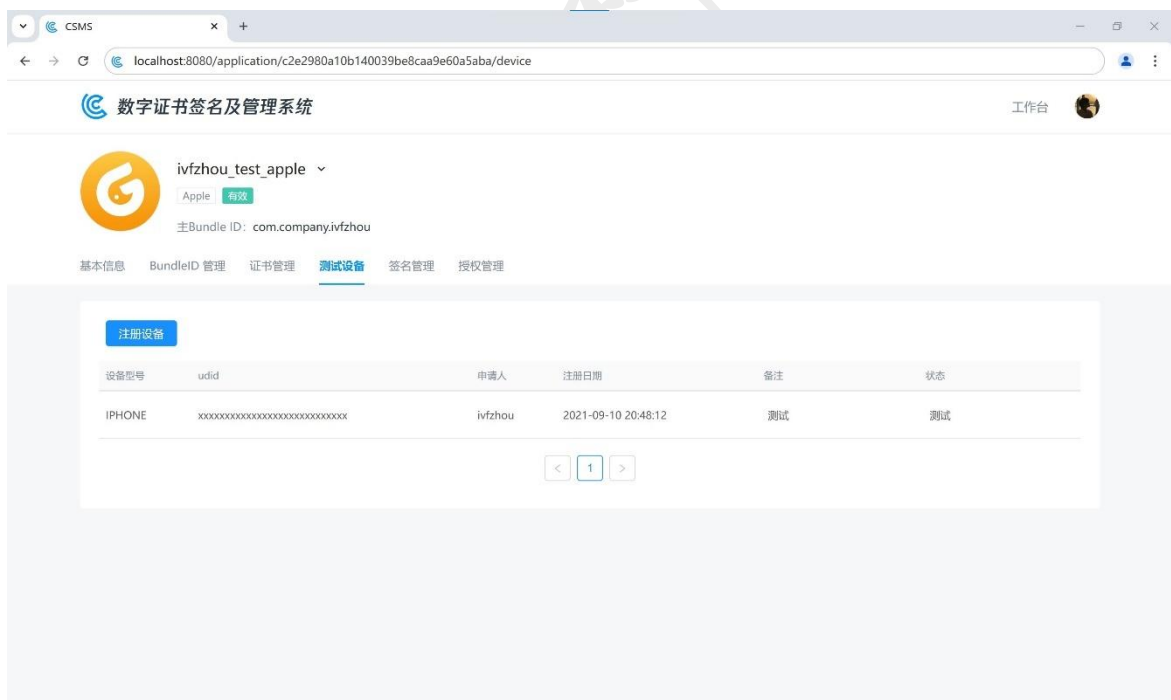


图 5-32 测试设备列表页面

5.3.6 OpenAPI 凭证管理实现

申请功能的逻辑流程。先查凭证表确定应用不存在同凭证 ID 的记录。校

验 IP 参数，按分号分隔，每组再按点号分隔，去除两边空白字符后判断数字是不是 IP 合法数字。若是 IP 段，则将两 IP 转成 32 位数字比较大小。然后随机生成 128 位字符的凭证密钥，最后添加凭证表、凭证授权和应用事件表记录。

修改功能的逻辑流程。根据应用 ID 和凭证 ID，检索到凭证表记录，更新其相关字段。然后将属于凭证的授权项记录全部删除，再根据修改后的数据重新添加。最后记录应用事件。

重置密钥功能的逻辑流程。先查凭证表确保记录存在，属于应用。然后随机生成密钥，且比对不同于老密钥后，更新记录表密钥字段。将新密钥返回给页面展示，并记录应用事件。

删除功能的逻辑流程。同样，先确保凭证存在，属于应用。然后删除记录，和对应的授权项记录。最后记录事件表记录。

续期功能的逻辑流程。根据应用 ID、凭证 ID 查找到记录后，将过期时间 expiration_time 字段更新为一个月后。最后记录下应用事件。

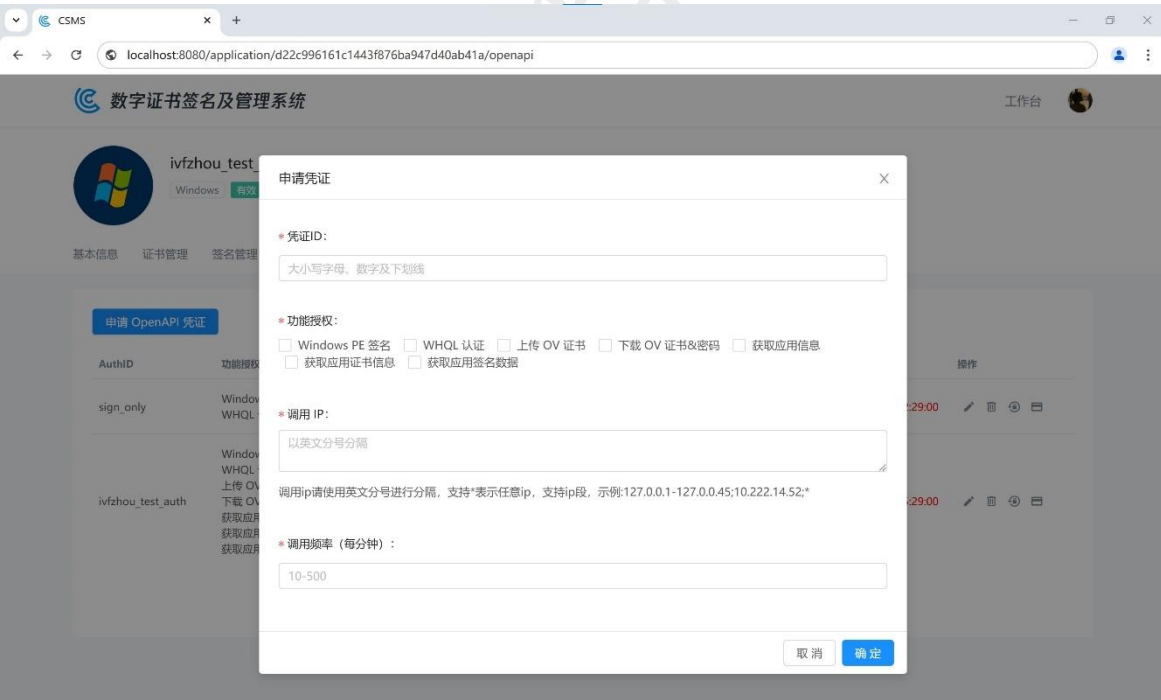


图 5-33 申请 OpenAPI 凭证页面

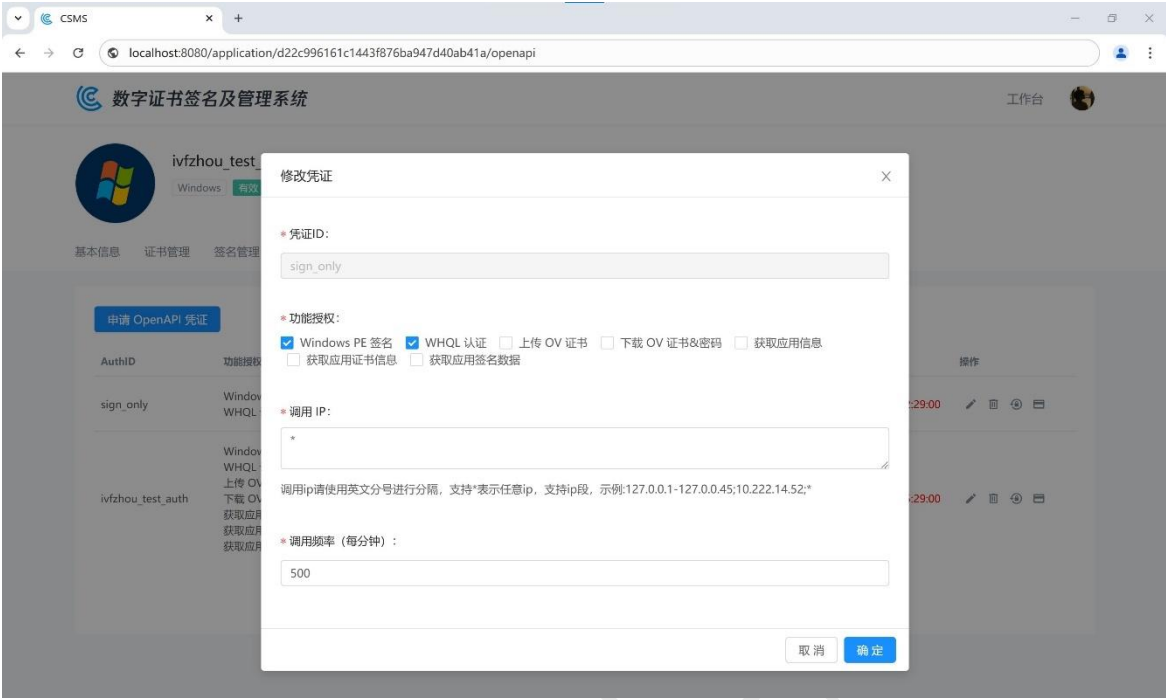


图 5-34 修改 OpenAPI 凭证页面

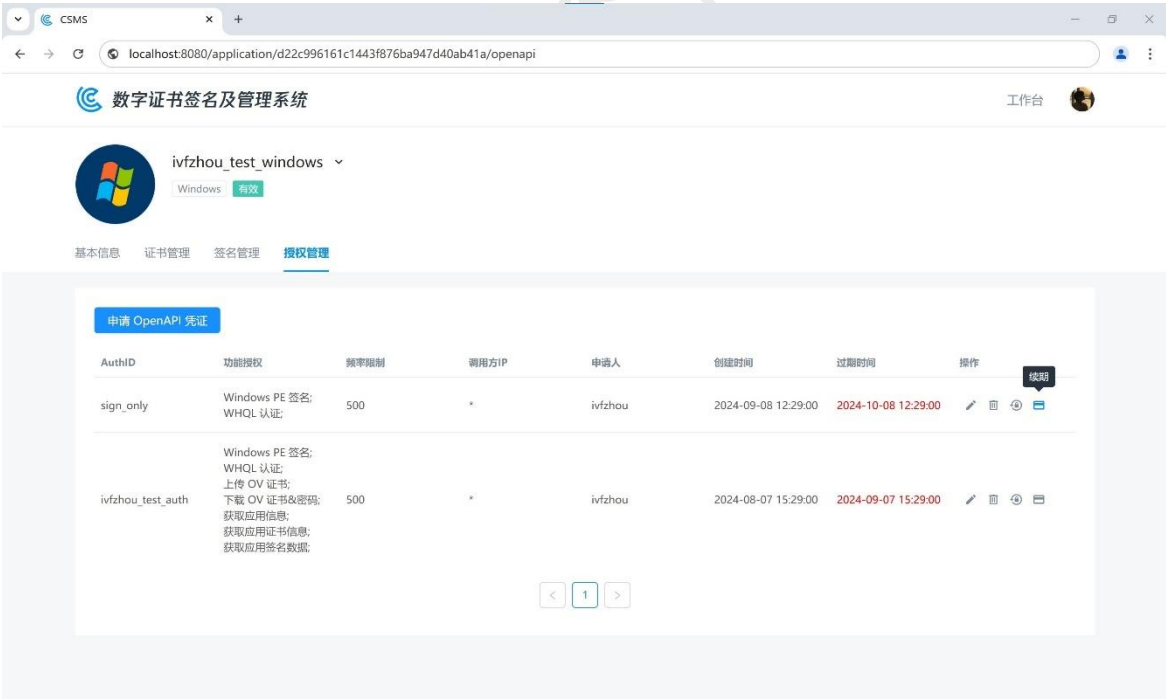


图 5-35 OpenAPI 凭证列表页面

5.3.7 签名管理实现

PE 文件与微软 Attestation 签名功能的逻辑流程。先检索 Windows 证书表

判断用户选择的证书属于应用，或者是公司公共证书。将签名文件上传到 Tusd 中，签名任务信息保存到 Windows 签名任务表中，记录应用事件。若是 OV 证书则向 RabbitMQ 队列 `queue_windows_ov` 发送签名任务 ID，否则向队列 `queue_windows_ev_<certificate_fingerprint>` 发送。对应签名机中消费消息，从主服务那获取签名相关数据，并执行 `signtool.exe` 程序签名，更新任务表，上传结果文件。在 `cron` 包下定时任务中，获取到任务状态处理待 Attestation 签名的记录，使用配置文件中微软接口凭证 `client_id` 与 `client_secret`，请求微软接口提交签名。然后在另一个定时任务中，检索出任务状态处于等待 Attestation 签名结果的记录，同样请求微软接口获取任务状态，下载结果文件。

Windows PE文件和Attestation签名流程

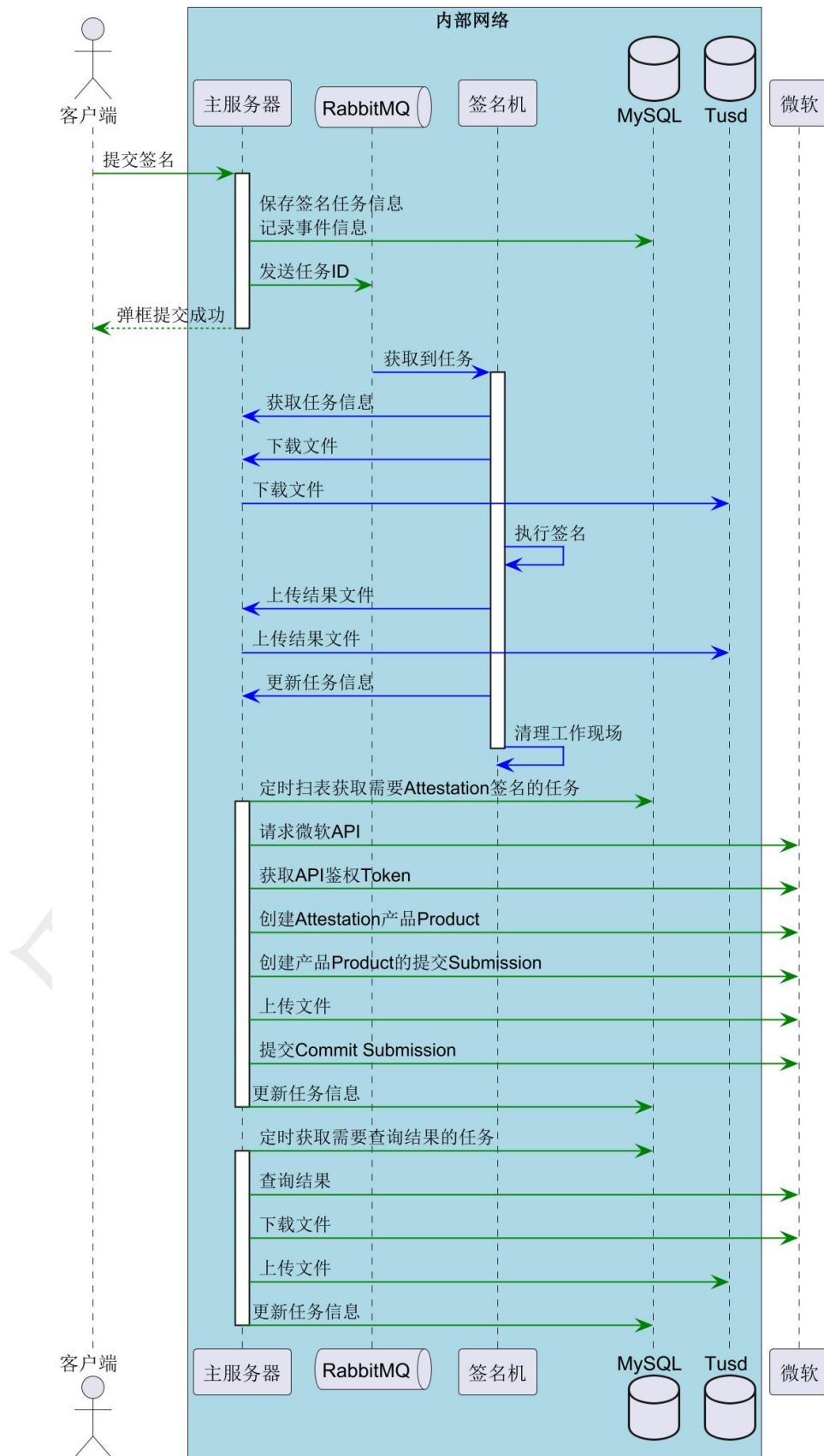


图 5-36 PE 文件与微软 Attestation 签名流程图

微软 HLK 测试与 WHQL 签名功能的逻辑流程。测试和签名文件上传到 Tusd，任务信息保存到 WHQL 任务表中，并记录应用事件。若需要 HLK 测试，由测试机主动请求获取测试任务，安装并运行驱动服务，并更新任务状态。控制机主动获取到需要调度测试的任务，使用 PowerShell 代码运行测试，获取测试结果文件和日志，最后更新任务状态。在获取 WHQL 任务签名时，实现类似 Attestation 签名，在定时任务中请求微软服务器完成。



图 5-37 HLK 测试流程图

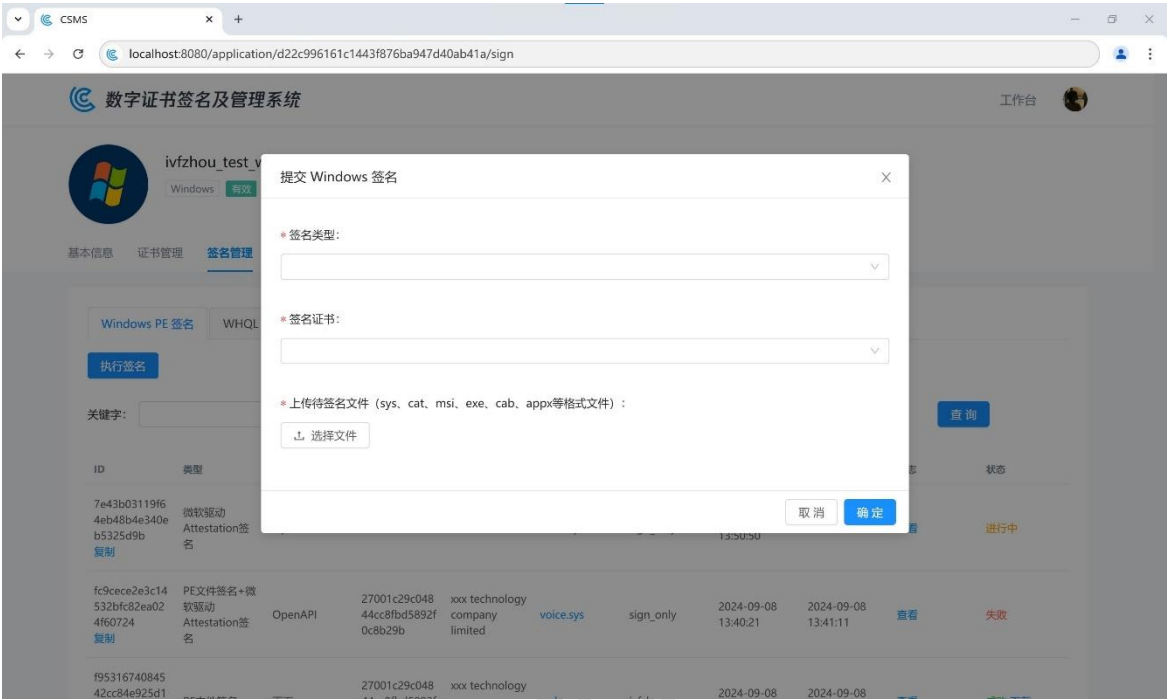


图 5-38 提交 Windows PE 签名页面

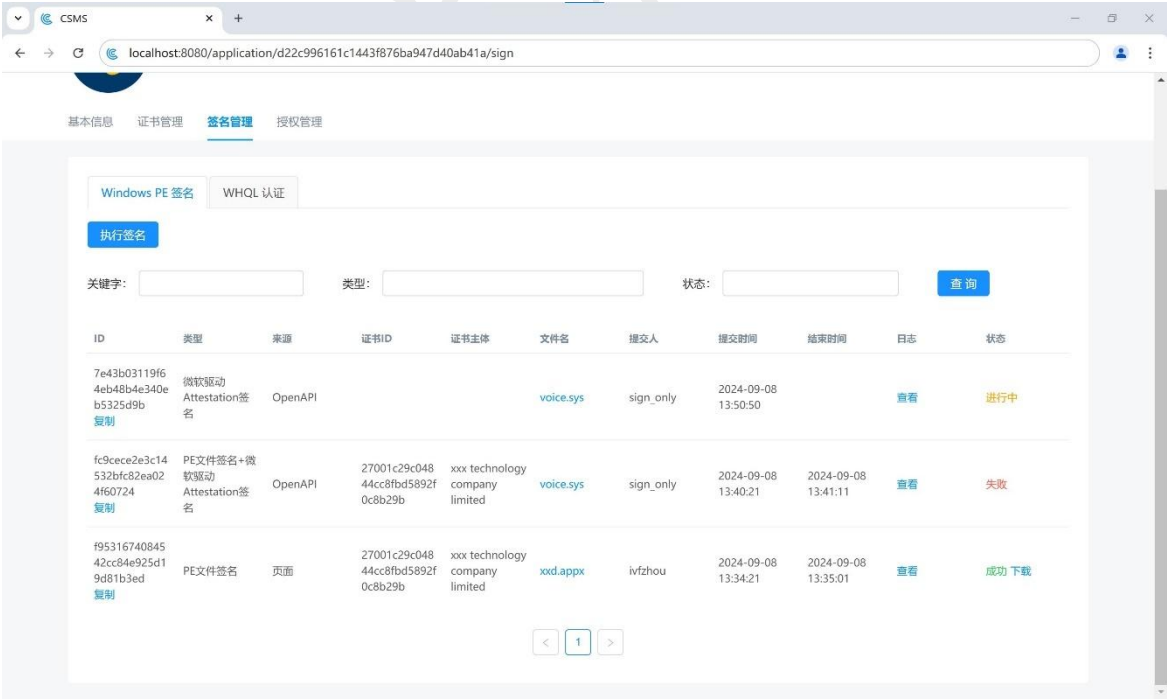


图 5-39 Windows PE 文件签名任务列表页面

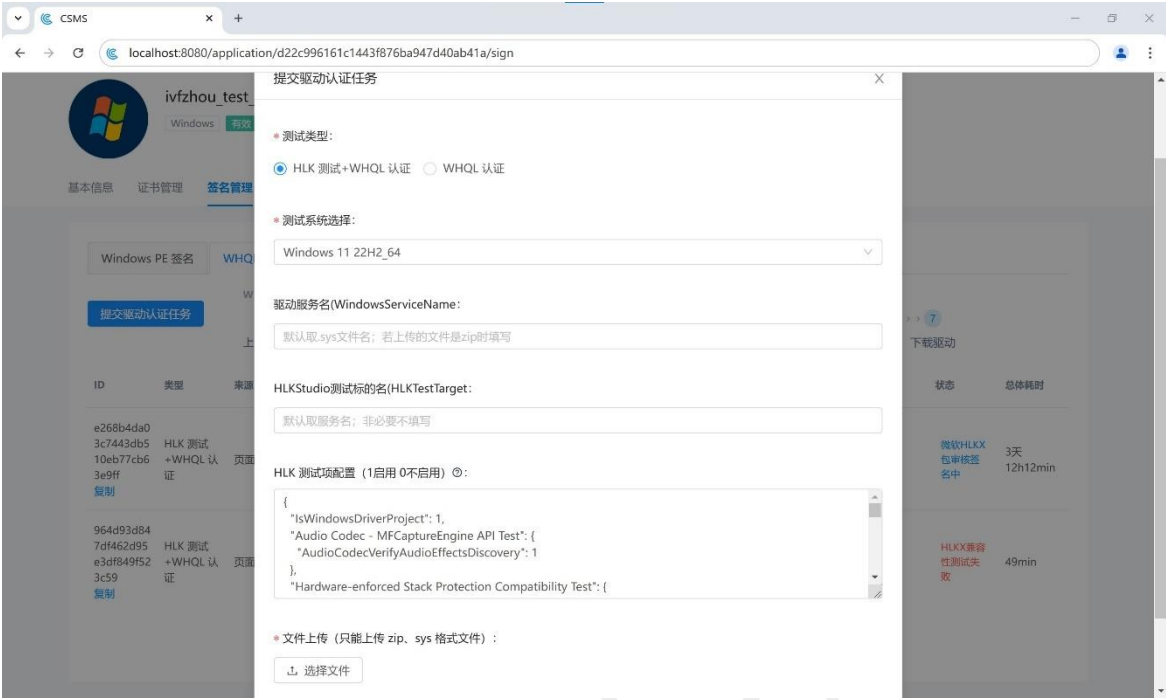


图 5-40 提交 WHQL 签名页面

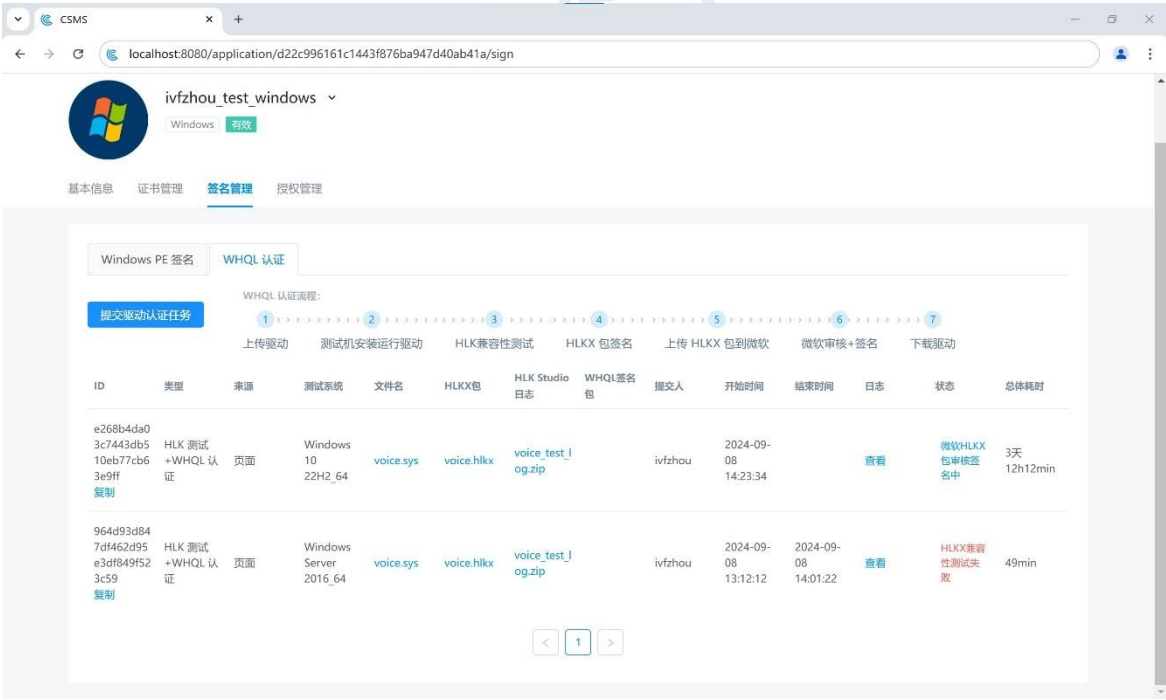


图 5-41 WHQL 签名任务列表页面

APK、AAB 和补丁包文件签名功能的逻辑流程。签名文件保存到 Tusd。查询安卓证书表、文件信息表确保记录存在，属于应用。然后在安卓签名任务

表中保存记录，记录应用事件。向 RabbitMQ 队列 queue_android 发送任务 ID，签名机中消费到消息，从服务器获取签名数据，调用 apksigner 完成对 APK 和补丁包文件签名，调用 jarsigner 完成对 AAB 包文件签名。最后上传结果文件到 Tusd，更新任务信息。

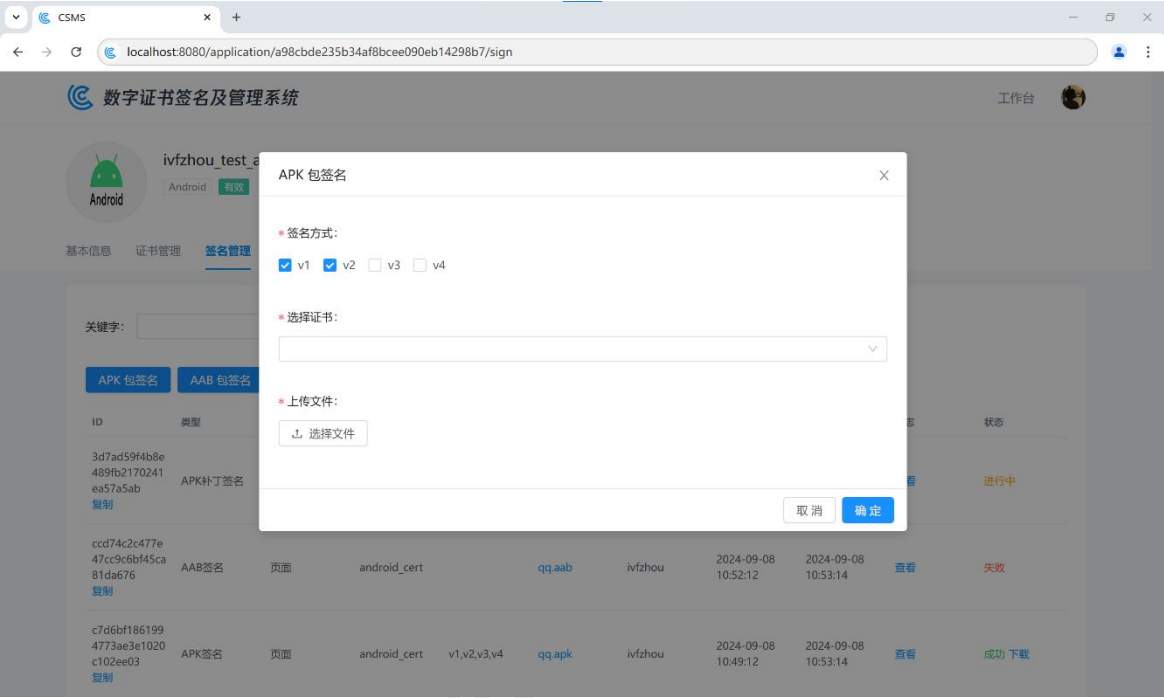


图 5-42 提交 APK 文件签名页面

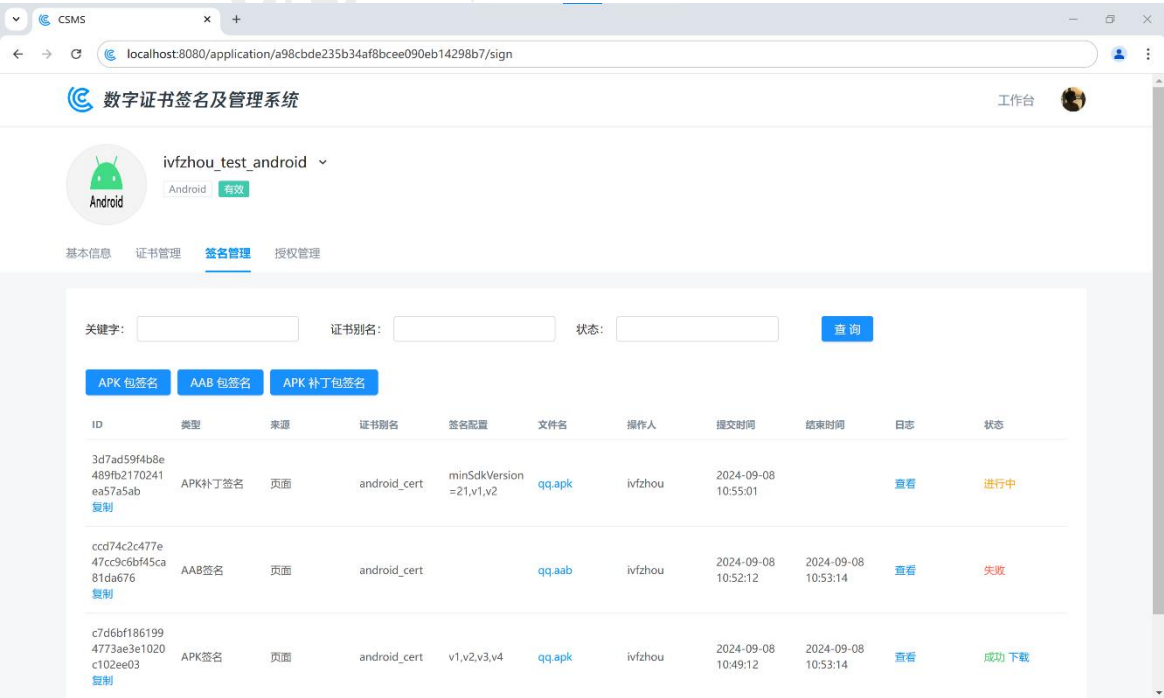


图 5-43 Android 签名任务列表页面

IPA 文件签名功能的逻辑流程。和安卓签名类似，但在签名时运行 zsign 实现。

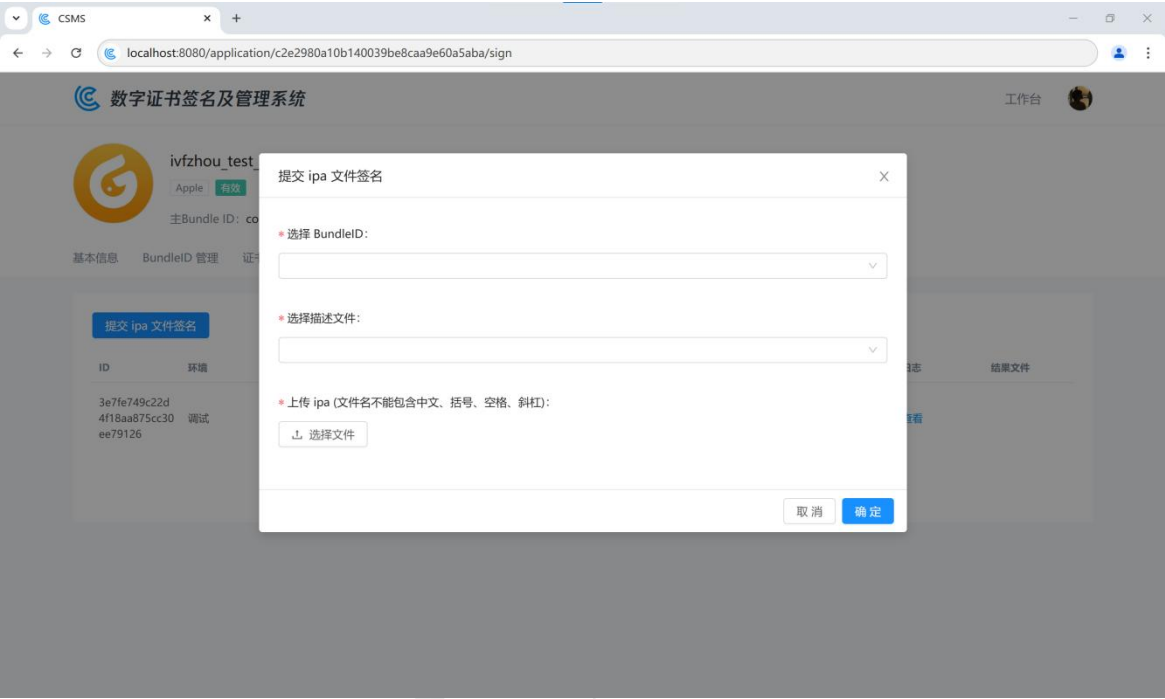


图 5-44 提交 IPA 文件签名页面

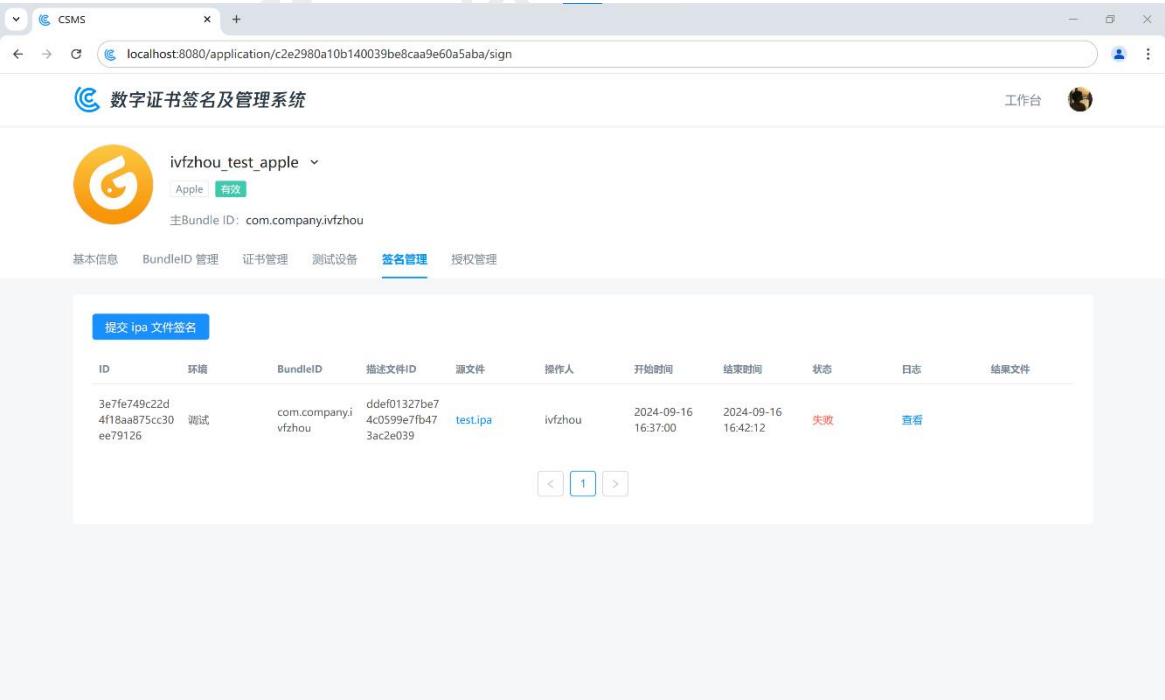


图 5-45 IPA 文件签名任务列表页面

5.3.8 后台管理实现

上传 Windows 公司 OV 公共证书功能的逻辑流程。浏览器将证书内容 Base64 编码，服务器中解码证书内容，获取证书信息。检索 Windows 证书表中确保不存在同指纹的记录。然后加密证书内容，保存到 Windows 证书表中。

添加 Windows 公司和个人 EV 证书功能的逻辑流程。在确保 Windows 证书表不存在同指纹的情况下，将信息保存到 Windows 证书表中。

获取 Windows 公司证书列表功能的逻辑流程。检索 Windows 证书表，将是公司和 EV 类型的证书全部返回给页面展示。

删除 Windows 公司证书功能的逻辑流程。将请求参数的证书 ID 作为 SQL 语句条件，更新记录的 deleted_time 字段。

下载 Windows 公司证书功能的逻辑流程。根据证书 ID 检索 Windows 证书表记录，解密证书内容，返回给页面下载。

授权个人 Windows EV 证书功能的逻辑流程。根据请求参数中的应用 ID 和证书 ID，添加到 EV 授权表中，完成授权。

授权 Windows EV 证书应用列表功能的逻辑流程。按时间降序，和用户的筛选条件组织 SQL 语句，分页查询 EV 授权表，返回数据给展业展示。

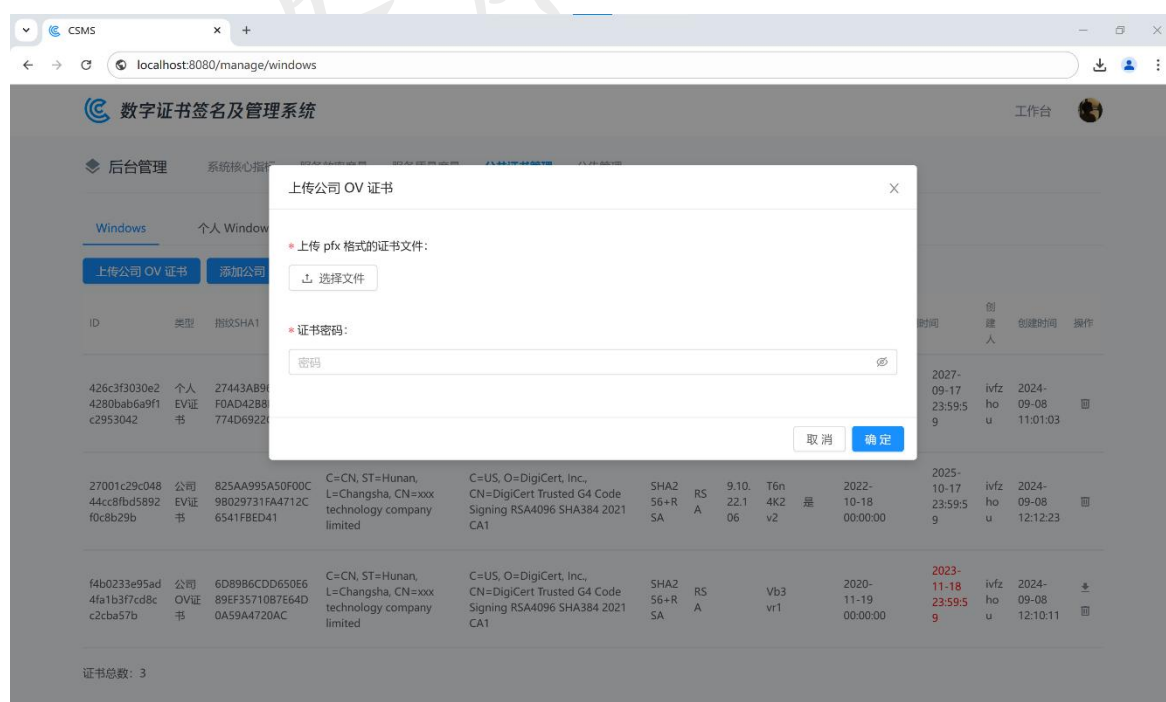


图 5-46 上传 Windows 公司 OV 公共证书页面

数字证书签名及管理

添加公司 EV 证书

* 指纹SHA1:

* 所有者:

* 颁发者:

* 签名算法:

* 公钥算法:

* 密码:

* UKEY机器IP:

* 生效时间:

* 过期时间:

* 微软校验签名: ☐

取消 确定

工作台

ID	类型	指纹SHA1
426c3f3030e2 4280bab6a9f1 c2953042	个人 EV证 书	27443AB F0AD428 774D692
27001c29c048 44cc8fbd5892 f0c8b29b	公司 EV证 书	825AA99 98029731 6541FBED
f4b0233e95ad 4fa1b3f7cd8c c2c8a57b	公司 OV证 书	6D8986C 89EF3571 0A59A47

证书总数: 3

创建时间	创建人	创建时间	操作
2027-09-17 23:59:59	ivfz ho u	2024-09-08 11:01:03	
2025-10-17 23:59:59	ivfz ho u	2024-09-08 12:12:23	
2023-11-18 23:59:59	ivfz ho u	2024-09-08 12:10:11	

图 5-47 添加 Windows 公司 EV 证书页面

数字证书签名及管理系统

后台管理 系统核心指标 服务效率度量 服务质量度量 公共证书管理 公告管理

Windows 个人 WindowsEV 授权 Android Apple

上传公司 OV 证书 添加公司 EV 证书 添加个人 EV 证书

ID	类型	指纹SHA1	所有者	颁发者	签名算法	公钥算法	UKEY 机器 IP	密码	微软校验签名	生效时间	过期时间	创建人	创建时间	操作
426c3f3030e2 4280bab6a9f1 c2953042	个人 EV证 书	27443AB96DC3E63 F0AD4288802183E 774D6922C1	C=CN, ST=Hunan, L=Changsha, CN=ivfzhou ev cert	C=US, O=DigiCert, Inc., CN=DigiCert Assured ID Root CA	SHA2 56+R SA	RS A	9.10. 22.1 06	TUqj Ql6 O	是	2024-09-18 00:00:00	2027-09-17 23:59:59	ivfz ho u	2024-09-08 11:01:03	
27001c29c048 44cc8fbd5892 f0c8b29b	公司 EV证 书	825AA995A50F00C 98029731FA4712C 6541FBED41	C=CN, ST=Hunan, L=Changsha, CN=xxx technology company limited	C=US, O=DigiCert, Inc., CN=DigiCert Trusted G4 Code Signing RSA4096 SHA384 2021 CA1	SHA2 56+R SA	RS A	9.10. 22.1 06	T6n 4K2 v2	是	2022-10-18 00:00:00	2025-10-17 23:59:59	ivfz ho u	2024-09-08 12:12:23	
f4b0233e95ad 4fa1b3f7cd8c c2c8a57b	公司 OV证 书	6D8986CDD650E6 89EF35710B7E64D 0A59A4720AC	C=CN, ST=Hunan, L=Changsha, CN=xxx technology company limited	C=US, O=DigiCert, Inc., CN=DigiCert Trusted G4 Code Signing RSA4096 SHA384 2021 CA1	SHA2 56+R SA	RS A		Vb3 vr1		2020-11-19 00:00:00	2023-11-18 23:59:59	ivfz ho u	2024-09-08 12:10:11	

证书总数: 3

图 5-48 Windows 公司证书列表页面

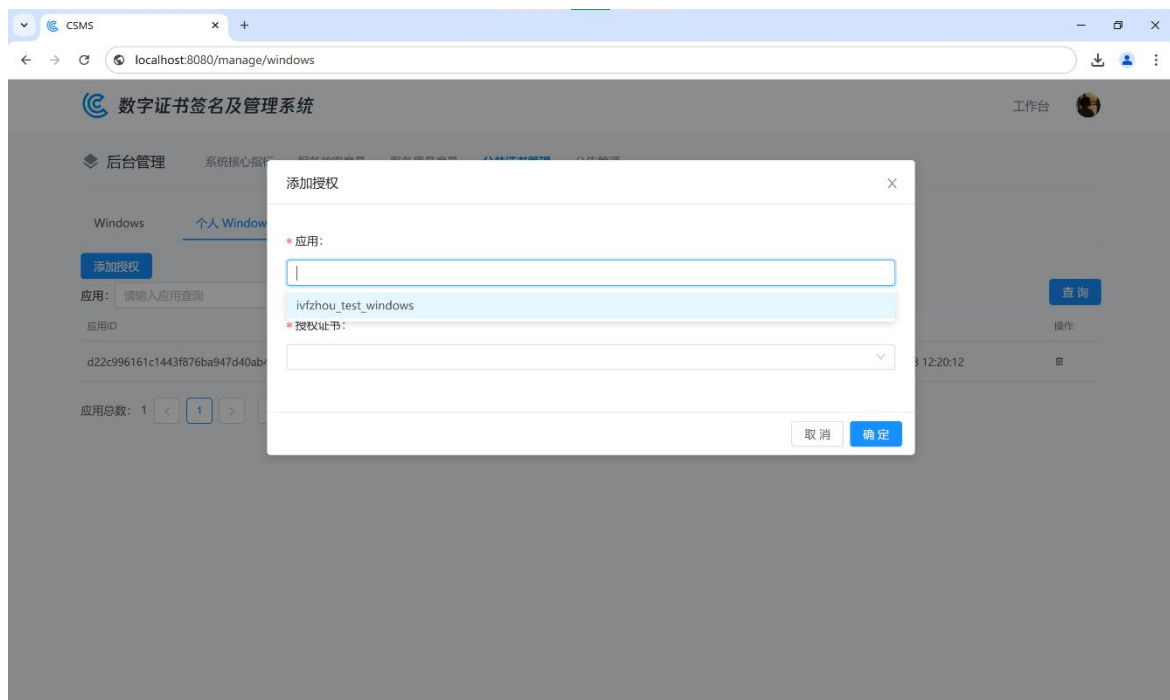


图 5-49 授权应用个人 Windows EV 证书页面

添加安卓证书主体功能的逻辑流程。先检索主体表，确保通用名不重复。然后将系统运营员输入的数据添加到安卓证书主体表中。

删除证书主体功能的逻辑流程。根据请求参数中的主体 ID，删除主体表中对应记录。

证书主体列表功能的逻辑流程。按时间降序将所有主体表记录查出，给页面展示。

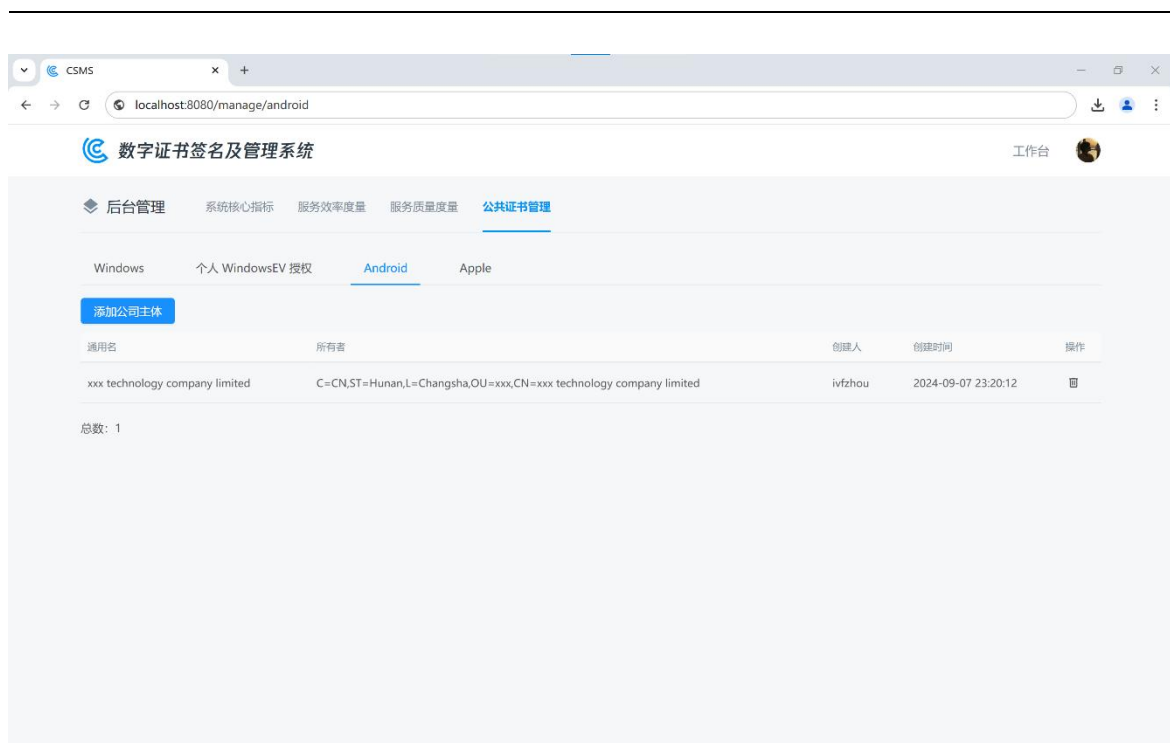


图 5-50 Android 证书主体列表页面

申请 Apple 签名证书功能的逻辑流程。先运行 `openssl` 命令生成 RSA 私钥和证书请求 CSR，然后请求苹果服务器申请证书。解析证书，获取信息。运行 `openssl` 命令，将其同私钥合并成一个文件。最后加密证书内容，保存到苹果证书表中。

Apple 签名证书列表功能的逻辑流程。从苹果证书表中，检索出所有签名证书，返回给页面展示。

删除 Apple 签名证书功能的逻辑流程。根据证书 ID 检索苹果证书表，确保证书存在，是签名证书。然后更新设置其 `deleted_time` 字段。

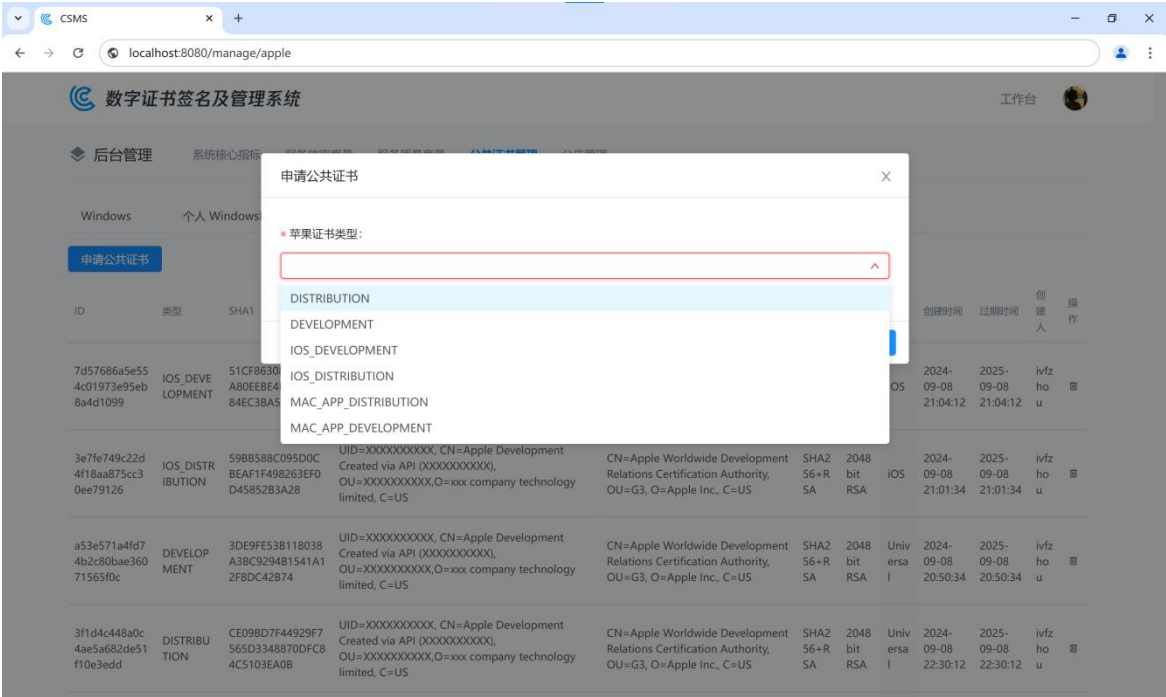


图 5-51 申请 Apple 签名证书页面

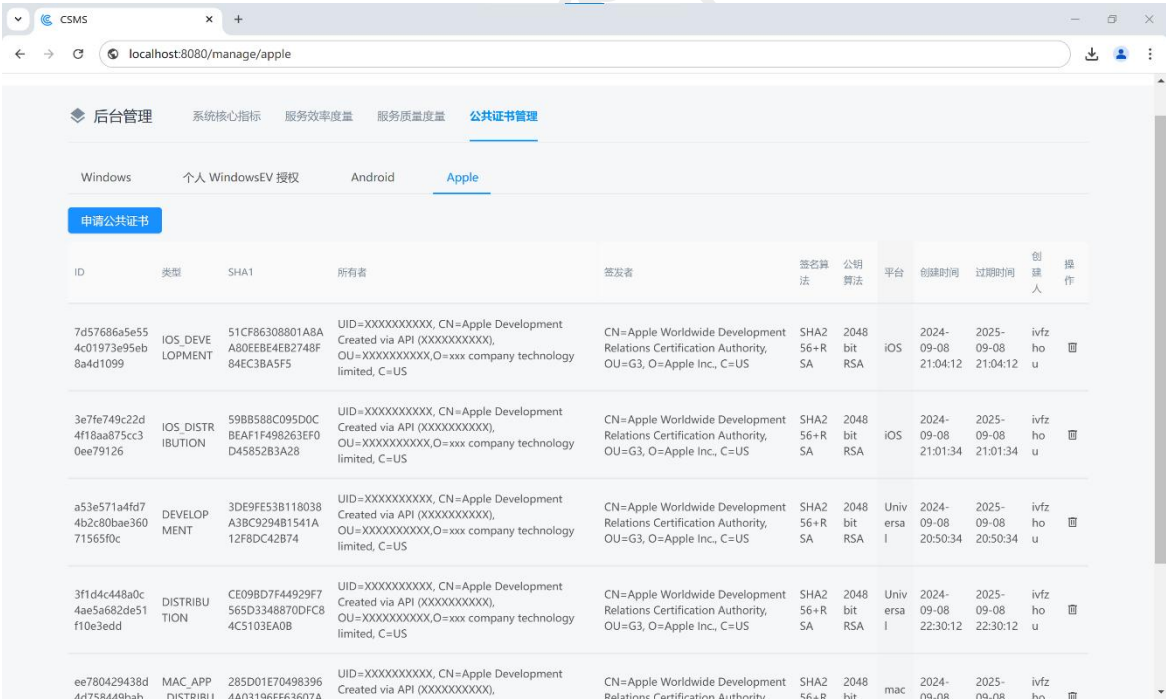


图 5-52 Apple 签名证书列表页面

浏览统计图表功能的逻辑流程。根据任务表中的创建时间 `created_time` 字段检索出在筛选时间范围内的所有已结束任务记录。将记录中的结束时间

finished_time 减去创建时间 created_time 计算出签名耗时，再根据统计时长粒度：一天还是一月等等，计算出平均耗时。相应的，成功率数据，则通过状态 status 字段区分任务成功与否，再计算出成功率。应用事件数量通过获取事件表各类型的记录数量得到。

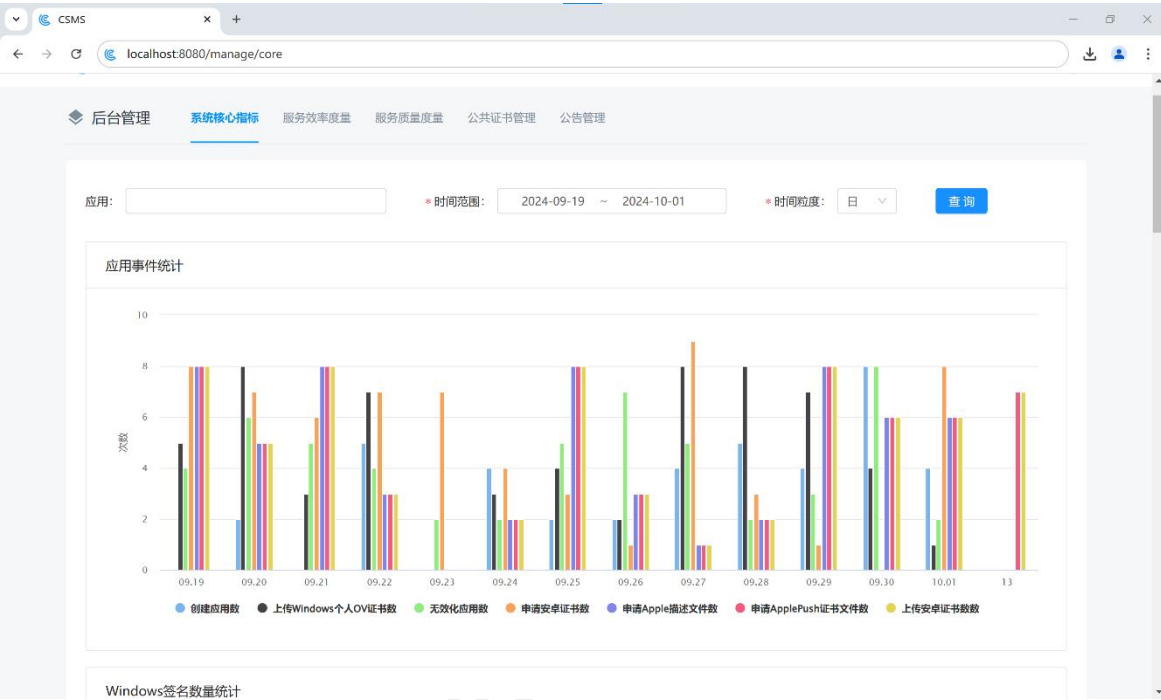


图 5-53 应用事件数量图页面

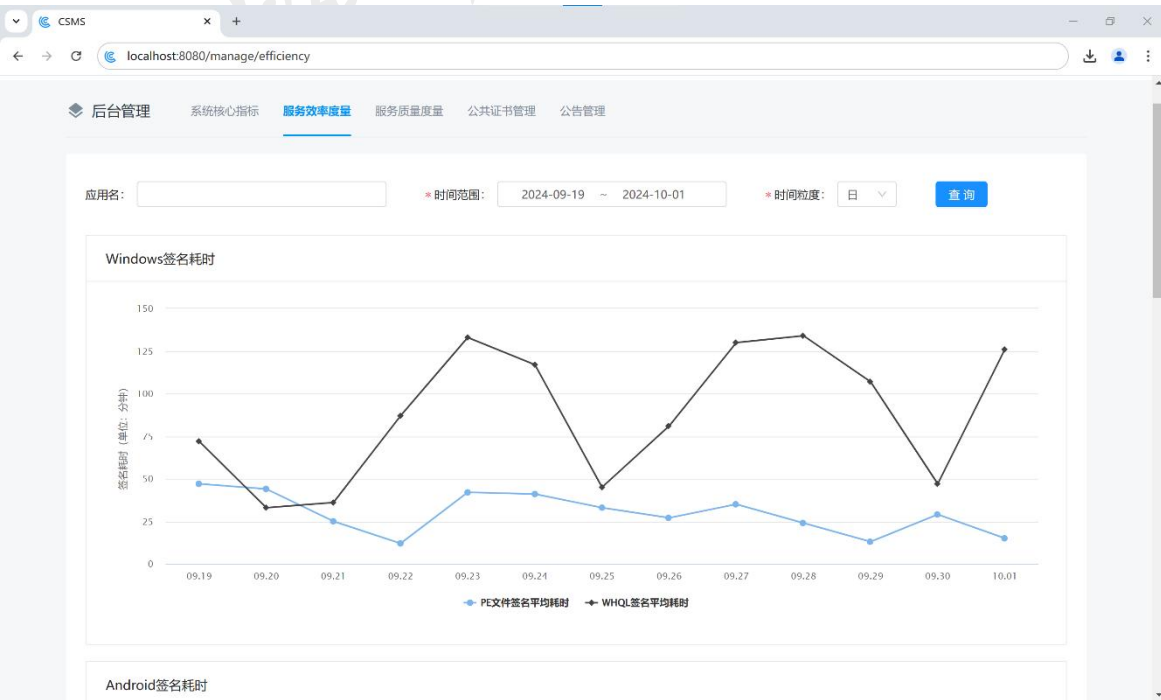


图 5-54 签名耗时图页面

公告添加功能的逻辑流程。将系统管理员添加的公告内容保存到公告信息表中。

公告删除功能的逻辑流程。根据请求参数中的公告 ID，删除公告表中对应记录。

公告列表功能的逻辑流程。按时间降序，将公告表所有记录查出，给页面展示。

公告展示功能的逻辑流程。查询公告表中，SQL 语句组织成 `order by id desc limit 1` 形式，获取处于生效时间，且没有超出过期时间的记录。若没符合条件的记录，则给页面返回空。

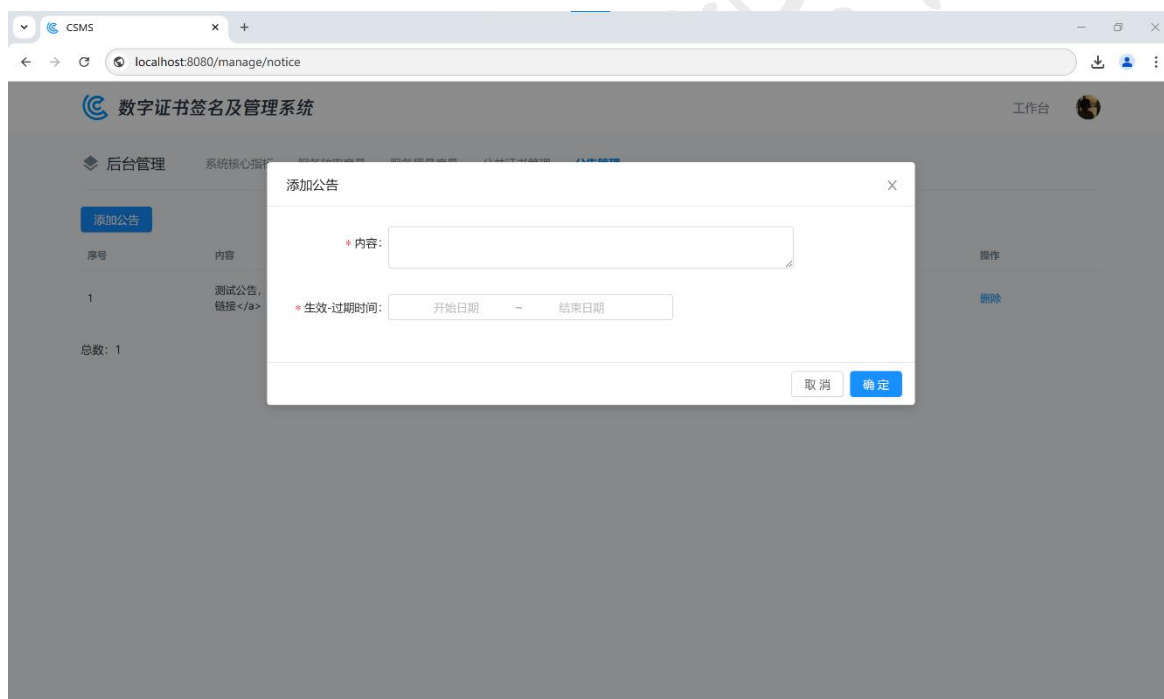


图 5-55 添加公告页面

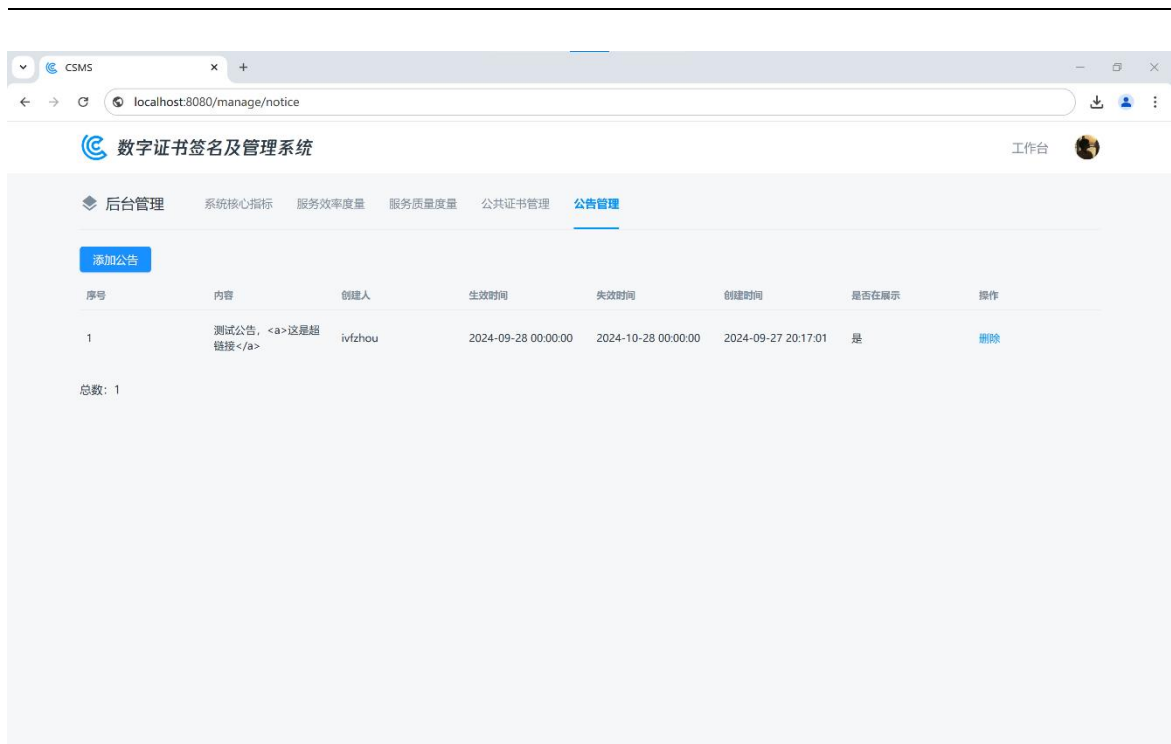


图 5-56 公告列表页面

5.4 系统测试

系统在开发过程中不可避免的会存在缺陷，因此通过测试能够发现并修复缺陷。良好的测试方法能尽可能地找出系统各种缺陷，从而有利于系统的稳定性，降低系统的维护成本。本系统采用单元测试、功能测试和集成测试方法完成测试。

单元测试属于白盒测试，测试者了解代码细节。在每一个 api 包中暴露的 HTTP 接口，都编写单元测试代码。Golang 语言提供了良好的测试框架，使用其提供的 `testing` 包能够调用系统代码中的方法函数。通过覆盖率测试能掌握业务代码的测试覆盖情况。使用 `httptest` 包代码能模拟 HTTP 的请求和响应，将它用于每次对接口的调用，之后比对响应结果是否符合预期。为了尽可能高的代码测试覆盖率，将每个业务接口的逻辑分支都进行测试，确保正常请求和异常请求都能覆盖到，请求结果都达到预期。

功能测试属于黑盒测试，站在使用者的角度测试该系统。测试前明确用户的实际操作和需求，然后模拟该行为，测试系统功能，确保系统的行为符合用户的预期。在 Chrome 浏览器中完成各项测试。

集成测试就是编写程序，对系统整体功能，连贯在一起测试。一个功能的

数据输出可能是另一个功能的数据输入，主要是测试系统的核心关键功能。同样采用 Golang 语言编写程序，向服务器发送 HTTP 请求，实现了从获取证书到执行签名的业务顺序测试。

经过单元测试、功能测试和集成测试后，将发现的系统缺陷进行了修复。实现了系统的功能需求和非功能需求。

周燮本科毕设

总 结

本论文研究了数字证书管理与自动化签名系统的背景与意义、需求分析和设计实现。根据功能需求设计了系统部署架构、网络拓扑，功能实现方法，和数据库表结构。最后，从编码实现层面研究了代码框架结构、技术实现细节和各功能接口的逻辑实现。开发编码出一套提供了良好的证书管理、自动化签名功能和良好运营管理功能的系统平台。

在本系统的实际环境中，由于 Windows 签名证书需要以企业的名义购买，用户使用在本系统上 Windows 签名功能成了刚需，因此签名量比较大。由于公司名义注册的 Apple 账号在本系统下使用，因而 Apple 的描述文件申请成了用户频繁使用的功能。

本论文主要围绕三个人们日常使用普遍的操作系统平台，随着生产生活前进发展，未来可能会出现其他流行的操作系统平台，例如华为的移动操作系统鸿蒙发展势头强劲，但本系统未支持到鸿蒙系统，提供更多操作系统支持是未来本系统进一步发展的方向之一。其次，各操作系统的签名策略随着时间推移会有优化升级，本系统需时常观察签名策略变动及可能需要的开发支持。

软件签名本质是计算文件摘要，使用私钥对摘要签名，本系统中并没有具体研究各应用的签名机制，而是采用官方开发的程序工具执行签名。对于 Windows PE 文件签名，市面上已有软件实现对文件摘要签名，客户端只要发送摘要而非整个文件，服务器签名摘要后客户端整合签名和文件，不需要文件上传下载，极大的加快了签名速度。所以研究各应用的签名机制，并针对性优化，满足企业的个性化需要，是本文后续研究的重点。例如签名信息上附上签名者，当证书签名泄露时方便追查责任人，进而开发出专用的签名程序。

此外，本系统仅注重证书管理与自动化签名，这一通常普适的领域。对于具体的企业而言，这些功能显得有些不足。能够融合企业内部环境，针对企业特定需求，开发出特定功能。由于为了精简篇幅，在数据库设计中，表结构设计偏大，可考虑进一步拆分细化表，并结合企业个性化需求设计，也是本系统的发展方向。

参考文献

- [1] 中华人民共和国. 商务数据中心. 数字中国发展报告[R/OL](2023-04)[2024-02-26].
<http://data.mofcom.gov.cn/report/%E6%95%B0%E5%AD%97%E4%B8%AD%E5%9B%BD%E5%8F%91%E5%B1%95%E6%8A%A5%E5%91%8A%EF%BC%882022%E5%B9%B4%EF%BC%89.pdf>.
- [2] 程朝辉. 数字签名技术概览[J]. 信息安全与通信保密. 2020(07).
- [3] 杨文清. 浅谈数字签名与数字证书[J]. 计算机产品与流通, 2020(11).
- [4] 周海东,王三超. 数字签名技术在网络通信安全中的应用[J]. 集成电路应用. 2023,40(03).
- [5] 暴金雨. RSA 公钥密码体制的原理及应用[J]. 科技传播. 2019,11(06).
- [6] 蔡昭炜. 数字签名技术在不动产登记业务中的应用与实现[D]. 江苏科技大学, 2023.
- [7] SCHNEIER B. Applied Cryptography: Protocols, Algorithms, and Source Code in C[M]. 2th ed. Hoboken New Jersey U.S: Wiley, 2015.
- [8] 中华人民共和国工业和信息化部. 电子认证服务业“十二五”发展规划[Z]. 2011.
- [9] 第十一届全国人民代表大会常务委员会第十一次会议. 中华人民共和国电子签名法[Z]. 2008.
- [10] 亚数信息科技(上海)有限公司. 亚洲诚信数字签名工具专业版[Z/OL]. [2024-02-26]. <https://www.trustasia.com/solution/sign-tools>.
- [11] 沃通电子认证服务有限公司.Windows 徽标认证服务(WHQL 认证)[Z/OL].[2024-02-26]. <https://www.wosign.com/Products/WHQL.html>.
- [12] 郝林. Go 并发编程实战[M]. 第二版. 北京:人民邮电出版社,2017.
- [13] Google. The Go Programming Language Specification[S/OL]. (2024-02-06)[2024-03-04]. <https://go.dev/ref/spec>.
- [14] 王明松,于营,秦永佩. 基于协程(goroutine)的并发编程模型及应用[J]. 电子质量. 2022(06).

-
- [15] jeanboydev. Android 签名机制 v1、v2、v3. (2019)[2024-01-19].
https://github.com/jeanboydev/Android-ReadTheFuckingSourceCode/blob/master/article/android/basic/09_signature.md.
- [16] Google Developers. Sign your app[Z/OL]. (2023-08-16)[2024-03-06].
<https://developer.android.com/studio/publish/app-signing.html>.
- [17] Internet Society. Internet Engineering Task Force. JSON Web Token (JWT): RFC 7519[S/OL]. [2024-01-22]. <https://datatracker.ietf.org/doc/html/rfc7519>.
- [18] Eastmount. PE 数字签名之(上)什么是数字签名及 Signtool 签名工具详解. (2021-12-03)[2024-01-19]. <https://cloud.tencent.com/developer/article/1910260>.
- [19] Google Developers. apksigner[Z/OL]. (2023-12-02)[2024-03-06].
<https://developer.android.com/tools/apksigner?hl=zh-cn>.
- [20] Google Developers. 应用签名 [Z/OL]. (2022-09-13)[2024-03-06].
<https://source.android.com/docs/security/features/apksigning?hl=zh-cn>.
- [21] 互联网小熊猫. Android apk 签名原理. (2022-02-09)[2024-01-19].
https://blog.csdn.net/weixin_42600398/article/details/122843107.
- [22] 红酒牛排. 深入理解 iOS 签名原理 [Z/OL]. (2019-11-07)[2024-01-19].
<https://juejin.cn/post/6844903989792735240>.
- [23] Daniel_Coder. iOS 应用签名原理浅析 [Z/OL]. (2020-10-10)[2024-01-19].
<https://blog.csdn.net/guoyongming925/article/details/108986876>.
- [24] PRATA S. C Primer Plus[M]. 姜佑,译. 第六版. 北京:人民邮电出版社,2016.